

Политика отдела технической инфраструктуры

Нормативный документ ИТ-блока: полномочия, ответственность, порядок работы и правила взаимодействия с подразделениями

Реквизит	Значение
Код документа	ПОЛ-ОТИ-01
Редакция	1.0 (проект для утверждения)
Дата введения в действие	_____ (заполняется при утверждении)
Владелец документа	Руководитель отдела технической инфраструктуры
Разработчик	Отдел технической инфраструктуры
Область действия	Все подразделения и сотрудники Компании, а также подрядчики, получающие доступ к ИТ-инфраструктуре
Периодичность пересмотра	Не реже одного раза в 12 месяцев, а также при существенных изменениях структуры или инфраструктуры
Гриф	Для внутреннего использования. Тиражирование вне Компании запрещено
Связанные документы	Перечень приведён в разделе 24 и в приложениях А–Т

Лист согласования и утверждения

Действие	Должность	Ф. И. О.	Подпись	Дата
Разработал	Руководитель отдела технической инфраструктуры			
Согласовал	ИТ-директор			
Согласовал	Начальник отдела информационной безопасности			
Утвердил	Генеральный директор			

Документ вступает в силу с даты утверждения. До утверждения применяется в режиме пилотного внедрения по решению ИТ-директора.

Контроль версий документа

Любое изменение Политики оформляется новой редакцией. Действующая редакция хранится в электронном виде на сетевом диске и в бумажном виде — в отделе информационной безопасности. Предыдущие редакции сохраняются в архиве и не удаляются.

Редакция	Дата	Автор изменений	Суть изменения	Утвердил
1.0		Руководитель ОТИ	Первая редакция документа	

Таблица 1. Журнал редакций Политики (заполняется при каждом изменении)

Порядок пересмотра

- плановый пересмотр — ежегодно, инициирует руководитель ОТИ;
- внеплановый пересмотр — при изменении организационной структуры, появлении новых критичных сервисов, изменении требований отдела информационной безопасности или требований регуляторов, по итогам крупного инцидента или внутреннего аудита;
- предложения по изменению Политики вправе подать любой сотрудник Компании через заявку в системе Итилиум на имя руководителя ОТИ;
- изменения, затрагивающие зоны ответственности других подразделений, согласуются с руководителями этих подразделений.

Термины и сокращения

Термин	Определение
ОТИ	Отдел технической инфраструктуры — подразделение, ответственное за серверную, сетевую и пользовательскую ИТ-инфраструктуру Компании
ИБ	Отдел информационной безопасности
ИТ-сервис (сервис)	Логически завершённая ИТ-услуга, потребляемая бизнесом (например, «Электронная почта», «Файловое хранилище», «Инфраструктура 1С», «Доступ в интернет»)
Владелец сервиса	Руководитель подразделения, для которого сервис создан и который определяет требования к нему со стороны бизнеса
Итилиум	Корпоративная система учёта обращений и заявок (HelpDesk / Service Desk)
Обращение	Любое зарегистрированное в Итилиуме сообщение пользователя: инцидент, запрос на обслуживание, запрос на изменение или консультация
Инцидент	Незапланированное нарушение или снижение качества работы ИТ-сервиса
Крупный инцидент (Sev-1)	Инцидент, останавливающий критичный бизнес-процесс или затрагивающий несколько площадок
Изменение	Любая модификация конфигурации инфраструктуры, способная повлиять на работу ИТ-сервисов
RFC	Request for Change — оформленная заявка на изменение с планами внедрения, тестирования и отката (приложение С)
Окно работ	Заранее согласованный интервал времени, в который допускается проведение работ с риском влияния на сервисы
Rollback (откат)	Заранее подготовленная последовательность действий по возврату системы в исходное работоспособное состояние
SLA	Service Level Agreement — соглашение о целевых параметрах обслуживания (время реакции, время решения, доступность)
RPO	Recovery Point Objective — допустимый объём потери данных, выраженный во времени
RTO	Recovery Time Objective — целевой срок восстановления сервиса
DRP	Disaster Recovery Plan — план аварийного восстановления
Технический совет по изменениям	Постоянно действующая рабочая группа ОТИ и ИБ, рассматривающая существенные изменения
Technology Standard	Внутренний стандарт допустимых технических решений: оборудование, операционные системы, платформы, ПО
Break-glass учётная запись	Аварийная административная учётная запись, применяемая только при невозможности штатного доступа
Паспорт сервиса	Формализованное описание сервиса: назначение, состав, класс критичности, ответственные, зависимости (приложение А)
Сервис-менеджер	Сотрудник, ответственный за склад ИТ-оборудования и ведение учёта техники
1-я линия	Служба поддержки пользователей: приём обращений, типовые операции, рабочие места
2-я линия	Системные администраторы и сетевой инженер: серверы, сеть, платформенные сервисы
3-я линия	Вендоры и подрядчики, привлекаемые к сложным работам

Приложения обозначены латинскими буквами А–Т, чтобы исключить путаницу со нумерацией разделов Политики.

Содержание

Контроль версий документа	2
Термины и сокращения	3
Содержание	4
1. Общие положения	9
1.1. Назначение документа	9
1.2. Задачи, которые решает Политика	9
1.3. Область действия	9
1.4. Принципы применения	10
1.5. Философия отдела: «Enterprise с человеческим подходом»	10
2. Цели, задачи и принципы работы ОТИ	12
2.1. Миссия и цели отдела	12
2.2. Основные задачи отдела	12
2.3. Принципы работы отдела	12
2.4. Что ОТИ ожидает от подразделений Компании	13
3. Организационная структура и роли	14
3.1. Место ОТИ в структуре Компании	14
3.2. Состав отдела и распределение зон	14
3.3. Линии поддержки и порядок передачи работ	15
3.4. Замещение и снижение зависимости от отдельных сотрудников	15
3.5. Развитие отдела	16
4. Полномочия и ответственность руководителя ОТИ	17
4.1. Полномочия	17
4.2. Право технической остановки работ	18
4.3. Решения, не принимаемые единолично	19
4.4. Ответственность руководителя ОТИ	19
4.5. Отчётность перед ИТ-директором	20
5. Границы ответственности и взаимодействие с подразделениями	21
5.1. Зона ответственности ОТИ	21
5.2. Что не входит в зону ответственности ОТИ	22
5.3. Разграничение с отделом информационной безопасности	22
5.4. Разграничение с отделом ИС и бизнес-приложениями	24
5.5. Матрица ответственности по сквозным процессам (RACI)	24
5.6. Порядок разрешения спорных зон ответственности	26

6. Каталог ИТ-сервисов	27
6.1. Требование описания сервисов	27
6.2. Классификация сервисов по критичности	27
6.3. Первичный перечень сервисов	28
6.4. Порядок ввода нового сервиса	30
6.5. Изменение и вывод сервиса из эксплуатации	30
6.6. Ежегодная ревизия каталога	31
7. Управление обращениями	32
7.1. Единая точка входа	32
7.2. Обращения, поступившие вне системы учёта	32
7.3. Категории обращений	33
7.4. Приоритеты обращений	33
7.5. Эскалация	35
7.6. Дисциплина ведения заявок	36
8. Управление изменениями инфраструктуры	37
8.1. Базовое требование	37
8.2. Классы изменений	37
8.3. Изменения, требующие обязательного согласования	38
8.4. Процесс управления изменениями	39
8.5. Технический совет по изменениям	40
8.6. Окна проведения работ и периоды запрета изменений	40
8.7. Аварийные изменения	41
8.8. Запрет несанкционированных изменений	41
9. Управление инфраструктурой: серверы, виртуализация, хранение	43
9.1. Обязательные принципы	43
9.2. Порядок создания сервера или виртуальной машины	43
9.3. Установка серверного программного обеспечения	44
9.4. Стандартизация конфигураций	44
9.5. Обновления и патч-менеджмент	44
9.6. Планирование ёмкости	45
9.7. Вывод систем из эксплуатации	45
10. Сеть, каналы связи и телеком	46
10.1. Единая ответственность за сетевую конфигурацию	46
10.2. Обязательная сетевая документация	46
10.3. Особенности распределённой инфраструктуры	47
10.4. Wi-Fi и гостевой доступ	47

10.5. Удалённый доступ	47
11. Управление доступом	48
11.1. Принцип минимально необходимых прав	48
11.2. Типы учётных записей	48
11.3. Правила административного доступа	49
11.4. Аварийная (break-glass) учётная запись	49
11.5. Предоставление, изменение и отзыв доступа	50
11.6. Регулярный пересмотр прав	50
11.7. Отчётность за действия в инфраструктуре	50
12. Информационная безопасность в зоне ответственности ОТИ	52
12.1. Модель разделения ответственности	52
12.2. Обязательные технические меры в зоне ОТИ	53
12.3. Правила для пользователей в части, обеспечиваемой ОТИ	53
12.4. Участие ОТИ в обработке инцидентов ИБ	54
12.5. Требования регуляторов и стандартов	54
13. Оборудование и программное обеспечение: жизненный цикл и учёт	55
13.1. Жизненный цикл оборудования	55
13.2. Программное обеспечение на рабочих местах	56
13.3. Учёт оборудования и лицензий	56
13.4. Инвентаризация	57
13.5. Нормативные сроки эксплуатации и обновление парка	58
13.6. Приём и увольнение сотрудников	58
14. Резервное копирование и восстановление	59
14.1. Ответственность	59
14.2. Принципы резервного копирования	59
14.3. Целевые параметры восстановления	60
14.4. Контроль результатов копирования	61
14.5. Обязательное тестирование восстановления	61
14.6. План аварийного восстановления (DRP)	61
14.7. Отказ площадки	62
15. Мониторинг, доступность и управление инцидентами	63
15.1. Принцип полного покрытия	63
15.2. Обязательный минимум наблюдения	64
15.3. Целевая доступность сервисов	65
15.4. Управление инцидентами	65
15.5. Дежурства и работа в нерабочее время	67

16. Работа с подрядчиками	68
16.1. Основания для привлечения подрядчика	68
16.2. Доступ подрядчика	68
16.3. Порядок проведения работ	69
16.4. Реестр подрядчиков и контроль качества	69
17. Закупки, бюджет и технические стандарты	70
17.1. Разграничение ролей	70
17.2. Последствия закупки в обход установленного порядка	70
17.3. Процесс закупки для проектной деятельности	71
17.4. Бюджет отдела технической инфраструктуры	71
17.5. Technology Standard: внутренний технический стандарт	72
17.6. Отклонение от стандарта	73
18. Документирование инфраструктуры	74
18.1. Базовый принцип	74
18.2. Место хранения	74
18.3. Обязательный перечень документов	76
18.4. Требования к оформлению документа	77
18.5. Контроль актуальности	77
18.6. Запрет уникального знания и передача знаний	77
19. Контроль, аудит и отчётность	78
19.1. Цикл отчётности	78
19.2. Состав ежемесячного отчёта	79
19.3. Внутренний аудит соблюдения Политики	79
20. SLA и KPI: рамочные положения	81
20.1. Статус SLA и KPI	81
20.2. Показатели-кандидаты	82
21. Ответственность за нарушение Политики	83
21.1. Виды нарушений	83
21.2. Гарантии для сотрудников	83
22. Исключения из Политики	84
23. Внедрение Политики: план-график	85
23.1. Условия успешного внедрения	85
24. Связанные регламенты и документы	86

Приложение А. Паспорт ИТ-сервиса	87
Приложение В. Реестр ИТ-сервисов	88
Приложение С. Заявка на изменение (RFC) с планами внедрения, тестирования и отката	89
Приложение D. Журнал изменений инфраструктуры	91
Приложение Е. Чек-лист ввода сервера или виртуальной машины в эксплуатацию	92
Приложение F. Матрица доступа к инфраструктуре	94
Приложение G. Заявка на предоставление, изменение или отзыв доступа	95
Приложение Н. Акт тестового восстановления из резервной копии	96
Приложение I. Отчёт о крупном инциденте (постмортем)	97
Приложение J. График дежурств и журнал дежурного	99
Приложение К. Журнал доступа подрядчика	101
Приложение L. Акт приёмки работ подрядчика	102
Приложение М. Акт инвентаризации оборудования	103
Приложение N. Акт передачи и возврата оборудования	106
Приложение О. Чек-лист приёма и увольнения сотрудника	107
Приложение Р. Техническое обоснование закупки	109
Приложение Q. Реестр исключений из Политики	110
Приложение R. Паспорт площадки	111
Приложение S. Лист ознакомления с Политикой	112
Приложение Т. Чек-лист внутреннего аудита соблюдения Политики	113

1. Общие положения

Назначение документа, область действия, порядок применения и введения в действие.

1.1. Назначение документа

Настоящая Политика устанавливает единые правила работы отдела технической инфраструктуры (далее — ОТИ), распределение полномочий и ответственности внутри отдела, порядок взаимодействия ОТИ с другими подразделениями Компании и внешними подрядчиками, а также обязательные требования к состоянию ИТ-инфраструктуры и её документированию.

Документ не является инструкцией системного администратора и не заменяет политику информационной безопасности. Он определяет **управленческий контур**: кто принимает решения, что обязательно согласуется, что фиксируется, что документируется и за что отвечает каждая роль. Технические детали выносятся в отдельные регламенты и стандарты (раздел 24), что позволяет менять их без переиздания Политики.

1.2. Задачи, которые решает Политика

Политика разработана для решения следующих управленческих задач, определённых руководством ИТ-блока:

- **навести порядок** — заменить стихийные договорённости и устные поручения прозрачными, единообразными правилами;
- **формализовать ответственность** — закрепить, какая роль за что отвечает, включая границы с отделом информационной безопасности, отделом 1С и закупками;
- **регламентировать изменения** — исключить незапланированные и несогласованные работы в инфраструктуре, ведущие к простоям;
- **ввести отчётность за действия** — обеспечить, чтобы каждое действие в инфраструктуре имело документальный след: заявку, RFC, запись в журнале;
- **описать все сервисы** — сформировать и поддерживать каталог ИТ-сервисов, включая вновь вводимые, с паспортом, владельцем и классом критичности.

1.3. Область действия

Политика распространяется на:

- сотрудников ОТИ — в полном объёме;
- всех сотрудников Компании (более 600 пользователей ИТ на 11 площадках, включая удалённых сотрудников) — в части правил обращения в ИТ, использования оборудования и программного обеспечения, порядка запроса доступов и изменений;
- подразделения Компании — в части порядка постановки задач ИТ, согласования изменений, закупок ИТ-решений и приёмки результатов работ;
- подрядчиков и поставщиков услуг — в части порядка получения доступа, проведения работ, документирования и приёмки результата;
- объекты ИТ-инфраструктуры — серверы, виртуальные машины, сетевое оборудование, системы хранения, рабочие места, периферия, телефония, видеонаблюдение, каналы связи, облачные сервисы и инфраструктурные компоненты прикладных систем.

Что находится вне области действия

Политика не регулирует прикладную функциональность бизнес-систем (в том числе конфигурации и доработки 1С), требования и контроль информационной безопасности, а также закупочные процедуры. Эти области закреплены за отделом 1С, отделом информационной безопасности и подразделением закупок соответственно. Границы подробно описаны в разделе 5.

1.4. Принципы применения

- Политика обязательна к исполнению с даты утверждения; незнание её положений не освобождает от их соблюдения;
- в случае противоречия между Политикой и устным поручением приоритет имеет Политика; при необходимости отклонения применяется порядок исключений (раздел 22);
- в случае противоречия между Политикой и требованиями отдела информационной безопасности приоритет имеют требования ИБ; выявленное противоречие устраняется совместным решением руководителей ОТИ и ИБ;
- все сроки, указанные в Политике, исчисляются в рабочих днях, если явно не указано иное;
- формы приложений А–Т являются обязательными к применению; их состав может дополняться решением руководителя ОТИ без переиздания Политики.

1.5. Философия отдела: «Enterprise с человеческим подходом»

Целевая модель ОТИ — зрелые процессы уровня Enterprise без превращения отдела в бюрократическую машину. Это означает одновременное соблюдение двух групп принципов.

Enterprise-составляющая	Человеческая составляющая
Единая точка входа и единая очередь работ	Пользователю всегда понятно, что происходит с его заявкой и когда ждать решения
Изменения — только через согласование и план	Согласование быстрое: стандартные изменения проходят по упрощённой процедуре
Каталог сервисов, паспорта, документация	Документируем для того, чтобы коллегам было проще, а не «для галочки»
Мониторинг, SLA, отчётность	Метрики применяются для улучшения процессов, а не для наказания сотрудников
Разбор инцидентов обязателен	Разбор проводится без поиска виновных: ищем причину, а не «кто нажал»
Стандарты и запрет самодетальности	Инженер имеет право предложить и обосновать отклонение от стандарта
Дисциплина исполнения и фиксация действий	Право на ошибку сохраняется, если действие было согласовано и зафиксировано

Таблица 2. Два контура целевой модели ОТИ

Принцип

Правило отдела: жёстко к процессам, бережно к людям. Требования предъявляются к порядку работы, а не к личностям. Нарушение процесса разбирается как дефект процесса, пока не доказано умышленное или повторное игнорирование правил.



Рис. 1. Оценка текущего уровня зрелости процессов ОТИ и целевое состояние на горизонте 12 месяцев. Оценка выполняется руководителем ОТИ ежегодно и служит основой для плана развития отдела.

2. Цели, задачи и принципы работы ОТИ

Что отдел обеспечивает для бизнеса и по каким правилам работает.

2.1. Миссия и цели отдела

Миссия ОТИ — обеспечивать непрерывную, безопасную и предсказуемую работу технической ИТ-инфраструктуры Компании при прозрачных для бизнеса правилах и понятной стоимости.

Цель	Содержание	Как измеряется (после ввода SLA и KPI)
Непрерывность	Критичные сервисы доступны в рабочее время, простои минимизированы и предсказуемы	Доступность сервисов класса А, количество и длительность простоев
Управляемость	Все изменения инфраструктуры выполняются по согласованному плану и фиксируются	Доля изменений с оформленным RFC, число несанкционированных изменений
Прозрачность	Бизнес понимает, какие сервисы существуют, кто за них отвечает и в какие сроки решаются задачи	Полнота каталога сервисов, выполнение целевых сроков по заявкам
Восстанавливаемость	Данные и сервисы можно восстановить в заданные сроки	Успешность резервного копирования, результаты тестовых восстановлений
Независимость от персонала	Инфраструктура документирована, у каждой области есть основной и резервный ответственный	Полнота документации, наличие замещения по всем областям
Развитие	Инфраструктура планомерно обновляется и соответствует задачам бизнеса	Выполнение плана обновления, доля оборудования за пределами срока службы

Таблица 3. Цели ОТИ и способы их измерения

2.2. Основные задачи отдела

- эксплуатация и развитие серверной инфраструктуры, виртуализации и систем хранения;
- эксплуатация и развитие локальных сетей, каналов связи, Wi-Fi, VPN и телефонии на всех площадках;
- администрирование доменной инфраструктуры, служб DNS/DHCP, почтовой системы и файловых хранилищ;
- обеспечение работоспособности инфраструктурного уровня прикладных систем, включая серверы и базы данных 1С;
- поддержка пользователей, рабочих мест, периферии и печати;
- резервное копирование, контроль его результатов и восстановление данных;
- мониторинг инфраструктуры и сервисов, реагирование на инциденты;
- реализация технических мер защиты по требованиям отдела информационной безопасности;
- техническое сопровождение видеонаблюдения и систем контроля доступа в части ИТ-составляющей;
- ведение учёта оборудования и лицензий совместно с сервис-менеджером;
- формирование технических требований к закупаемым ИТ-решениям и бюджета отдела;
- привлечение и сопровождение подрядчиков по сложным работам;
- документирование инфраструктуры и поддержание документации в актуальном состоянии.

2.3. Принципы работы отдела

Принципы имеют силу правил: на них ссылаются при разборе спорных ситуаций и при оценке работы сотрудников.

№	Принцип	Практическое следствие
1	Единая точка входа	Все обращения — только через help@exon-group.ru и систему Итилиум; задача без заявки не существует
2	Изменение — только по плану	Перед существенным изменением готовятся план внедрения, план тестирования и план отката; работы проводятся в согласованное окно

№	Принцип	Практическое следствие
3	Не навреди действующей инфраструктуре	Любое изменение проектируется так, чтобы не нарушать работу существующих сервисов; при невозможности — согласуется простой
4	Не задокументировано — не сделано	Работа считается завершённой только после обновления документации
5	Каждое действие оставляет след	Действия в инфраструктуре подтверждаются заявкой, RFC или записью в журнале
6	Минимально необходимые права	Доступ выдаётся в минимальном объёме, на минимальный срок и персонально
7	Мониторится всё, что эксплуатируется	Сервис без мониторинга не считается введённым в эксплуатацию
8	Стандартизация вместо разнообразия	Применяются только решения, входящие в Technology Standard; исключения согласуются отдельно
9	Нет знаний «в голове»	Каждая область имеет основного и резервного ответственного и описанные процедуры
10	Разбор вместо поиска виновных	После инцидентов проводится разбор, результат — корректирующие меры
11	Приоритет — бизнес-влияние, а не должность заявителя	Приоритет определяется масштабом влияния и срочностью по матрице приоритетов
12	Безопасность не обсуждается	Требования отдела ИБ исполняются; при технических противоречиях решение принимается совместно руководителями ОТИ и ИБ

Таблица 4. Принципы работы ОТИ

2.4. Что ОТИ ожидает от подразделений Компании

Работоспособность инфраструктуры — результат двустороннего взаимодействия. От подразделений Компании требуется:

- направлять обращения через единую точку входа, а не персонально сотрудникам ИТ;
- заранее уведомлять ОТИ о планах, влияющих на инфраструктуру: открытие или переезд площадки, набор персонала, внедрение новых систем, проведение массовых мероприятий;
- не приобретать ИТ-оборудование и программное обеспечение самостоятельно;
- назначать владельцев сервисов и участвовать в определении класса критичности и целевых параметров восстановления;
- предоставлять сотрудников для приёмочного тестирования при изменениях;
- своевременно инициировать блокировку доступов при увольнении и перемещении сотрудников по установленному порядку.

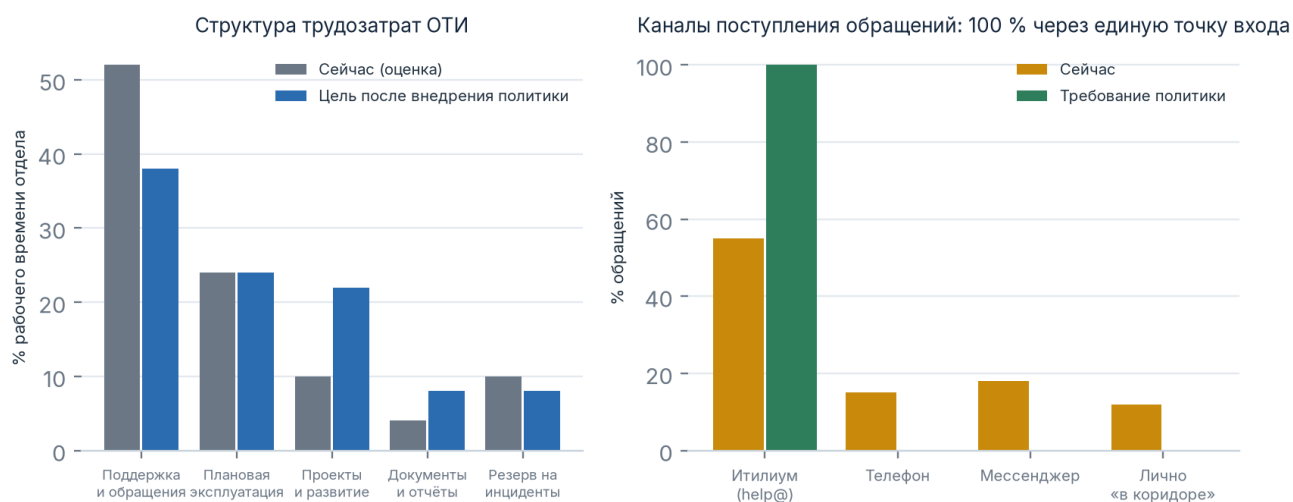


Рис. 2. Структура трудозатрат отдела и каналы поступления обращений: текущее состояние и целевое состояние после внедрения Политики. Перевод 100 % обращений в единую точку входа высвобождает ресурс на плановую эксплуатацию и проекты.

3. Организационная структура и роли

Состав отдела, подчинённость, линии поддержки, зоны ответственности и замещение.

3.1. Место ОТИ в структуре Компании

ОТИ входит в ИТ-блок Компании. Руководитель отдела технической инфраструктуры подчиняется непосредственно ИТ-директору. Отделы информационной безопасности, 1С и бизнес-приложений, подразделение закупок и сервис-менеджер не входят в состав ОТИ; взаимодействие с ними строится на основе настоящей Политики и матрицы ответственности (раздел 5).



Рис. 3. Организационная структура ОТИ и смежные подразделения. Штатная численность отдела — 7 сотрудников, включая руководителя.

3.2. Состав отдела и распределение зон

Роль	Кол-во	Зона ответственности	Линия
Руководитель ОТИ	1	Управление отделом, техническая архитектура, согласование изменений, бюджет, подрядчики, отчётность перед ИТ-директором	—
Ведущий системный администратор	2	Серверы, виртуализация, СХД, доменная инфраструктура, почтовая система, файловые хранилища, резервное копирование, мониторинг, инфраструктура 1С	2-я
Ведущий сетевой инженер	1	ЛВС и VLAN, маршрутизация, межсетевые экраны, Wi-Fi, VPN, каналы связи и провайдеры, телефония, сетевая документация и схемы	2-я
Руководитель службы поддержки	1	Управление 1-й линией, дисциплина обработки заявок, качество приёма обращений, распределение нагрузки, рабочие места пользователей	1-я
Специалист службы поддержки	2	Приём и классификация обращений, поддержка пользователей, установка ПО, выдача и приём оборудования, печать и периферия	1-я

Таблица 5. Штатный состав ОТИ и закреплённые зоны ответственности

Правило

Закрепление зон ответственности за конкретными ролями обязательно. Персональное закрепление (какой именно сотрудник отвечает за какую область) оформляется приказом или распоряжением руководителя ОТИ и поддерживается в актуальном состоянии в матрице замещения. Область без назначенного ответственного считается риском и подлежит закрытию в течение 10 рабочих дней.

3.3. Линии поддержки и порядок передачи работ

В Компании действует трёхлинейная модель поддержки. Обращение передаётся на следующую линию только после выполнения работ предыдущей линией и с приложением результатов диагностики.

Маршрут обращения и линии поддержки

Обращение передаётся на следующую линию только с результатами диагностики предыдущей



Рис. 4. Маршрут обращения и распределение работ между линиями поддержки.

Линия	Кто	Что делает	Что не делает
1-я линия	Руководитель службы поддержки, 2 специалиста	Приём и регистрация обращений, классификация и приоритизация, консультации, работа с рабочими местами, установка ПО из разрешённого перечня, выдача и приём оборудования, типовые операции по инструкциям (runbook)	Не изменяет конфигурацию серверов, сети, доменных политик и средств защиты
2-я линия	2 ведущих системных администратора, ведущий сетевой инженер	Диагностика и устранение инцидентов на уровне серверов, сети и платформенных сервисов, выполнение согласованных изменений, резервное копирование и восстановление, мониторинг	Не выполняет изменения без RFC (кроме аварийных с последующим оформлением), не изменяет прикладную логику 1С
3-я линия	Вендоры, подрядчики	Сложные работы, выходящие за пределы компетенций или ресурсов отдела; поддержка по договору	Не получает постоянный доступ, не проводит работы без куратора от ОТИ и решения отдела ИБ

Таблица 6. Разграничение линий поддержки

3.4. Замещение и снижение зависимости от отдельных сотрудников

Для каждой технологической области назначаются основной и резервный ответственные. Резервный ответственный обязан иметь достаточный доступ и знания для выполнения критичных операций в отсутствие основного, включая восстановление из резервной копии.

Матрица замещения по областям: О — основной ответственный, Р — резерв
(заполняется руководителем ОТИ, обязательна для каждой области)

Виртуализация и серверы	О	Р			
AD / DNS / DHCP	О	Р			
Exchange	Р	О			
Файловые хранилища	Р	О			
Резервное копирование	Р	О			
Сеть и firewall			О		
Wi-Fi		Р	О		
Телефония		Р	О		
Рабочие места				О	Р
Мониторинг	Р	Р	Р		
	Сист. админ. 1	Сист. админ. 2	Сетевой инженер	Рук. 1-й линии	1-я линия

Рис. 5. Матрица замещения по технологическим областям. Ведётся руководителем ОТИ, пересматривается при изменении состава отдела и не реже одного раза в полгода.

- передача знаний оформляется инструкцией или runbook в разделе документации, а не устно;
- перед плановым отпуском сотрудник передаёт резервному ответственному статус работ и незакрытые задачи; передача фиксируется в заявке или служебной записке;
- при отсутствии резервного ответственного по области руководитель ОТИ обязан инициировать обучение, привлечение подрядчика по договору поддержки либо включить риск в отчёт ИТ-директору.

3.5. Развитие отдела

Расширение состава отдела планируется по мере роста инфраструктуры и числа пользователей. Обоснованием служат объективные показатели, а не субъективная загрузка.

Основание для расширения	Показатель-триггер	Приоритет роли
Рост количества обращений	Устойчивое превышение нормы обращений на специалиста 1-й линии в течение 3 месяцев	Специалист 1-й линии
Рост парка серверов и виртуальных машин	Превышение управляемого объёма на одного администратора	Системный администратор (2-я линия)
Отсутствие замещения по критичной области	Область с единственным ответственным и классом критичности А	Профильный инженер либо договор поддержки
Развитие мониторинга и автоматизации	Ручные операции, повторяющиеся более 20 раз в месяц	Инженер по автоматизации / DevOps-компетенция
Открытие новых площадок	Более 11 площадок либо площадка с собственной серверной	Выездной инженер или расширение 1-й линии

Таблица 7. Триггеры расширения штата ОТИ

Конкретные нормативы численности (количество обращений и виртуальных машин на сотрудника) устанавливаются отдельным документом вместе с KPI отдела.

4. Полномочия и ответственность руководителя ОТИ

Официальное закрепление прав, границ единоличных решений и персональной ответственности.

4.1. Полномочия

Руководителю отдела технической инфраструктуры предоставляются следующие полномочия:

- **управление работами отдела** — распределение задач между сотрудниками, определение и изменение приоритетов работ, утверждение планов на период;
- **техническая архитектура** — определение архитектуры инфраструктуры и технических стандартов Компании (Technology Standard), выбор технических решений в рамках утверждённого бюджета;
- **согласование изменений** — техническое согласование любых изменений инфраструктуры, определение класса изменения и требований к плану внедрения, тестирования и отката;
- **остановка небезопасных изменений** — приостановка любых работ в инфраструктуре, выполняемых без согласования, без плана отката, вне согласованного окна или создающих риск для критичных сервисов и данных;
- **требование соблюдения стандартов** — предъявление обязательных к исполнению требований к сотрудникам ОТИ, подрядчикам и подразделениям в части эксплуатации инфраструктуры и документирования;
- **доступ к технической информации** — получение любой технической информации об инфраструктуре, включая конфигурации, журналы, схемы, данные учёта и договоры технической поддержки;
- **инициирование закупок** — формирование потребности, технических требований и обоснования, инициирование закупки в рамках утверждённого бюджета;
- **выбор подрядчика по техническим критериям** — оценка компетенций и решений, формирование технического задания, право отклонить подрядчика по техническим основаниям;
- **участие в подборе персонала отдела** — техническая оценка кандидатов, участие в собеседованиях, право отклонить кандидата по профессиональным основаниям;
- **оценка сотрудников отдела** — участие в оценке результативности, формирование предложений по развитию, обучению и мотивации;
- **назначение ответственных** — закрепление зон ответственности и схемы замещения, утверждение графика дежурств и окон работ;
- **инициирование разбора инцидентов** — назначение разбора, запрос объяснений по существу технических действий, утверждение корректирующих мер в зоне ОТИ.

Полномочия руководителя ОТИ и границы единоличных решений

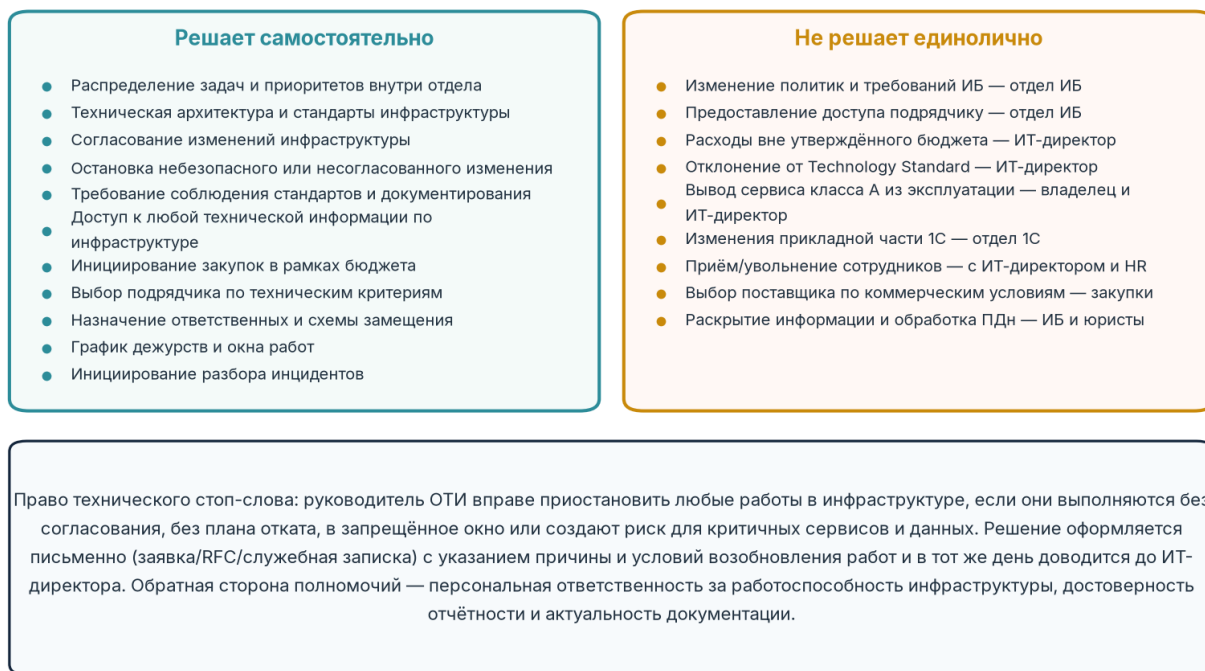


Рис. 6. Карта полномочий: решения в единоличной компетенции руководителя ОТИ и решения, требующие участия других подразделений.

4.2. Право технической остановки работ

Руководитель ОТИ вправе немедленно приостановить работы в инфраструктуре в случаях:

- работы выполняются без согласованного RFC либо с отклонением от согласованного плана;
- отсутствует проработанный план отката для изменения, влияющего на сервисы классов А и В;
- работы проводятся в рабочее время или вне согласованного окна без оснований для аварийного изменения;
- выявлен риск потери данных, длительного простоя критичного сервиса или нарушения требований информационной безопасности;
- подрядчик выполняет работы без куратора от ОТИ, без предоставленного в установленном порядке доступа или выходит за границы согласованных работ.

Порядок применения

Остановка работ оформляется письменно в течение рабочего дня: комментарий в заявке или RFC либо служебная записка с указанием основания, последствий и условий возобновления работ. Руководитель ОТИ в тот же день информирует ИТ-директора. Право остановки не может использоваться для блокирования решений, принятых ИТ-директором или отделом ИБ в пределах их компетенции: в этом случае руководитель ОТИ обязан письменно зафиксировать технические риски.

4.3. Решения, не принимаемые единолично

Решение	Кто участвует в принятии	Роль руководителя ОТИ
Изменение требований и политик информационной безопасности	Отдел ИБ	Техническая экспертиза, оценка реализуемости
Предоставление административного доступа подрядчику	Отдел ИБ (решение), ОТИ (согласование объёма)	Обоснование необходимости, определение объёма и срока, контроль работ
Расходы вне утверждённого бюджета	ИТ-директор	Обоснование, расчёт, приоритизация
Отклонение от Technology Standard	ИТ-директор	Оценка риска, оформление исключения (приложение Q)
Вывод из эксплуатации сервиса класса А	Владелец сервиса, ИТ-директор	Технический план, план миграции данных
Изменения прикладной части 1С и бизнес-приложений	Отдел 1С, владелец процесса	Обеспечение инфраструктурной части
Приём, перевод и увольнение сотрудников отдела	ИТ-директор, служба персонала	Техническая оценка, предложение решения
Выбор поставщика по коммерческим условиям	Закупки, ИТ-директор	Технические требования и техническая оценка
Раскрытие информации, обработка персональных данных	Отдел ИБ, юридическая служба	Техническое исполнение решения
Изменение организационной структуры ИТ-блока	ИТ-директор	Предложения по структуре и численности

Таблица 8. Решения, требующие участия других подразделений

4.4. Ответственность руководителя ОТИ

- работоспособность и развитие технической инфраструктуры в пределах выделенных ресурсов и утверждённых решений;
- соблюдение сотрудниками отдела настоящей Политики и связанных регламентов;
- достоверность и полноту отчётности перед ИТ-директором;
- актуальность технической документации и каталога сервисов;
- наличие работоспособного резервного копирования критичных систем и подтверждённую восстанавливаемость данных;
- исполнение требований отдела информационной безопасности в технической части;
- своевременную эскалацию рисков, которые невозможно закрыть силами и ресурсами отдела.

Разграничение ответственности по рискам

Риск, о котором руководитель ОТИ письменно уведомил ИТ-директора с описанием последствий и предложением по устранению, но по которому не выделены ресурсы, переходит в зону ответственности лица, принявшего решение об отказе. Уведомления о рисках ведутся в отдельном реестре и включаются в ежеквартальную отчётность.

4.5. Отчётность перед ИТ-директором

Периодичность	Содержание отчёта	Форма
Еженедельно	Статус работ и проектов, просроченные заявки, инциденты недели, планируемые изменения	Краткая сводка (письмо или встреча)
Ежемесячно	Доступность сервисов, статистика обращений, изменения, инциденты, состояние резервного копирования, риски	Отчёт ОТИ (раздел 19)
Ежеквартально	Результаты тестовых восстановлений, пересмотр прав доступа, состояние документации, исполнение бюджета, реестр рисков	Сводный отчёт с приложениями
Ежегодно	Итоги года, оценка зрелости процессов, план развития и бюджет на следующий период, пересмотр Политики	Годовой отчёт и план
Немедленно	Крупный инцидент, инцидент ИБ, риск срыва критичного бизнес-процесса, остановка работ	Уведомление по согласованному каналу связи

Таблица 9. Регламент отчётности руководителя ОТИ

5. Границы ответственности и взаимодействие с подразделениями

Что входит в зону ОТИ, что не входит, как разграничены «серые» зоны и как разрешаются спорные ситуации.

5.1. Зона ответственности ОТИ

ОТИ отвечает за всю техническую ИТ-инфраструктуру Компании, за исключением областей, прямо отнесённых настоящим разделом к другим подразделениям.

Контур ответственности ОТИ и границы со смежными подразделениями

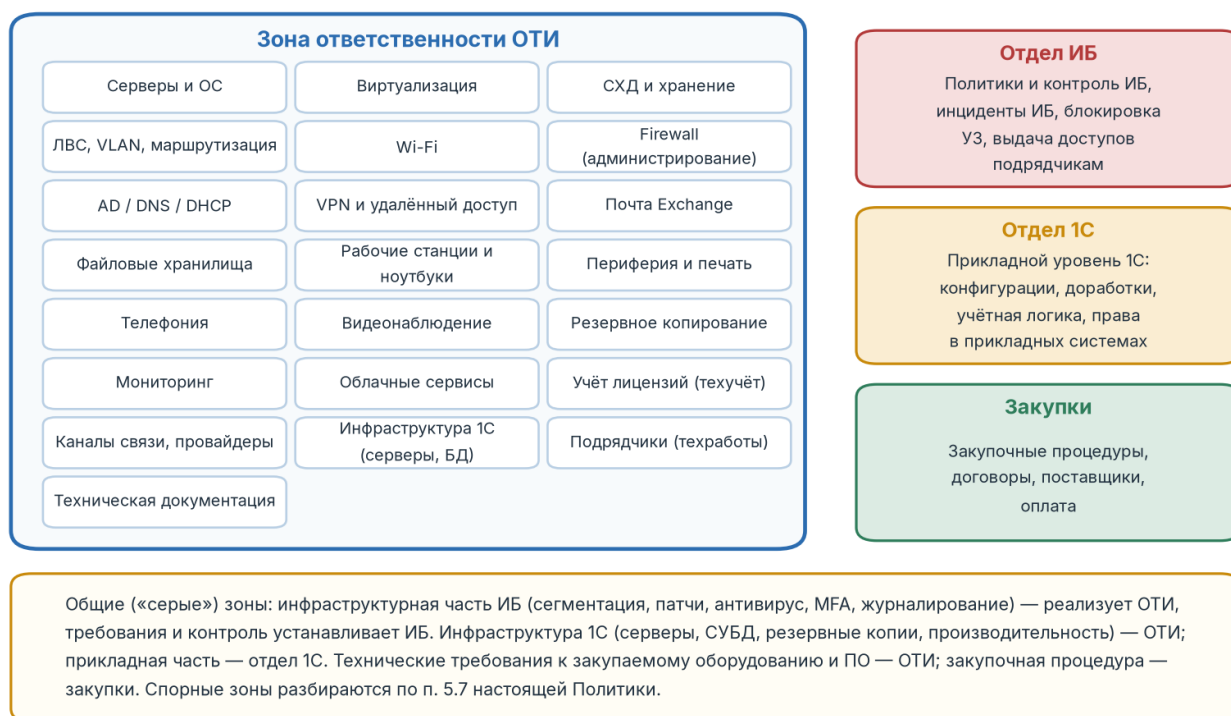


Рис. 7. Контур ответственности ОТИ и границы со смежными подразделениями.

Область	Что именно входит в ответственность ОТИ
Серверы и ОС	Физические серверы, серверные операционные системы, обновления, конфигурации, аппаратный мониторинг, гарантийное обслуживание
Виртуализация	Платформа виртуализации, кластеры, хосты, жизненный цикл виртуальных машин, шаблоны, ресурсные пулы
Системы хранения	СХД, дисковые массивы, тома, права на уровне хранения, производительность и ёмкость
Сеть	ЛВС, коммутаторы, VLAN, маршрутизация, межсетевые экраны (администрирование), Wi-Fi, каналы связи и взаимодействие с провайдерами
Службы каталога	Доменная инфраструктура, контроллеры домена, DNS, DHCP, групповые политики, структура подразделений и групп
Почта и совместная работа	Почтовый сервер Exchange, почтовые ящики, правила транспорта, списки рассылки, календари
Файловые хранилища	Файловые серверы, структура каталогов, права на ресурсы (технически), квоты, теневые копии
Удалённый доступ	VPN, шлюзы удалённого доступа, публикация сервисов, доступ удалённых сотрудников
Рабочие места	Рабочие станции, ноутбуки, мониторы, периферия, установка и обновление ПО, образы и настройка

Область	Что именно входит в ответственность ОТИ
Печать	Принтеры, МФУ, серверы печати, расходные материалы (техническая часть)
Телефония	Корпоративная телефония, номерной план, маршрутизация вызовов, абонентские устройства
Видеонаблюдение	ИТ-составляющая: серверы записи, хранилища, сеть, доступ к архиву по согласованию с ИБ
Резервное копирование	Система резервного копирования, расписания, контроль выполнения, восстановление данных
Мониторинг	Система мониторинга, объекты наблюдения, пороги, оповещения, отчёты о доступности
Облачные сервисы	Инфраструктурные облачные сервисы, подключение, интеграция с корпоративной сетью, учётные записи (технически)
Инфраструктура прикладных систем	Серверы приложений и баз данных, включая серверы и СУБД 1С, их производительность, доступность и резервное копирование
Учёт лицензий (технический)	Технический учёт установленного ПО, соответствие количества установок приобретённым лицензиям
Документация	Схемы, паспорта, реестры, инструкции по всей зоне ответственности ОТИ
Подрядчики (техработы)	Формирование технических требований, сопровождение работ, техническая приёмка

Таблица 10. Детализация зоны ответственности ОТИ

5.2. Что не входит в зону ответственности ОТИ

Область	Ответственное подразделение	Что остаётся за ОТИ
Информационная безопасность: политики, требования, контроль, инциденты ИБ, расследования, блокировка учётных записей, предоставление доступа подрядчикам	Отдел информационной безопасности	Техническая реализация требований ИБ, предоставление данных и журналов, выполнение указаний ИБ при инцидентах
Прикладной уровень 1С: конфигурации, доработки, обновления прикладных решений, учётная логика, права пользователей в прикладных системах	Отдел 1С и бизнес-приложений	Серверы, СУБД, дисковые ресурсы, сеть, резервное копирование, производительность инфраструктурного уровня
Закупочная деятельность: выбор поставщика по коммерческим условиям, договоры, оплата, претензионная работа	Подразделение закупок	Технические требования, техническая оценка предложений, приёмка по техническим параметрам

Таблица 11. Области вне зоны ответственности ОТИ

5.3. Разграничение с отделом информационной безопасности

Базовый принцип разграничения: **отдел ИБ устанавливает требования и контролирует их соблюдение, ОТИ реализует и эксплуатирует технические меры.** Решения о предоставлении доступа, о классификации инцидентов ИБ и о допустимости конкретных технических решений с точки зрения защищённости принимает отдел ИБ.

Разделение ответственности между ОТИ и отделом ИБ по доменам защиты
(схема ориентирована на разграничение роли «кто делает» и «кто требует и проверяет»)

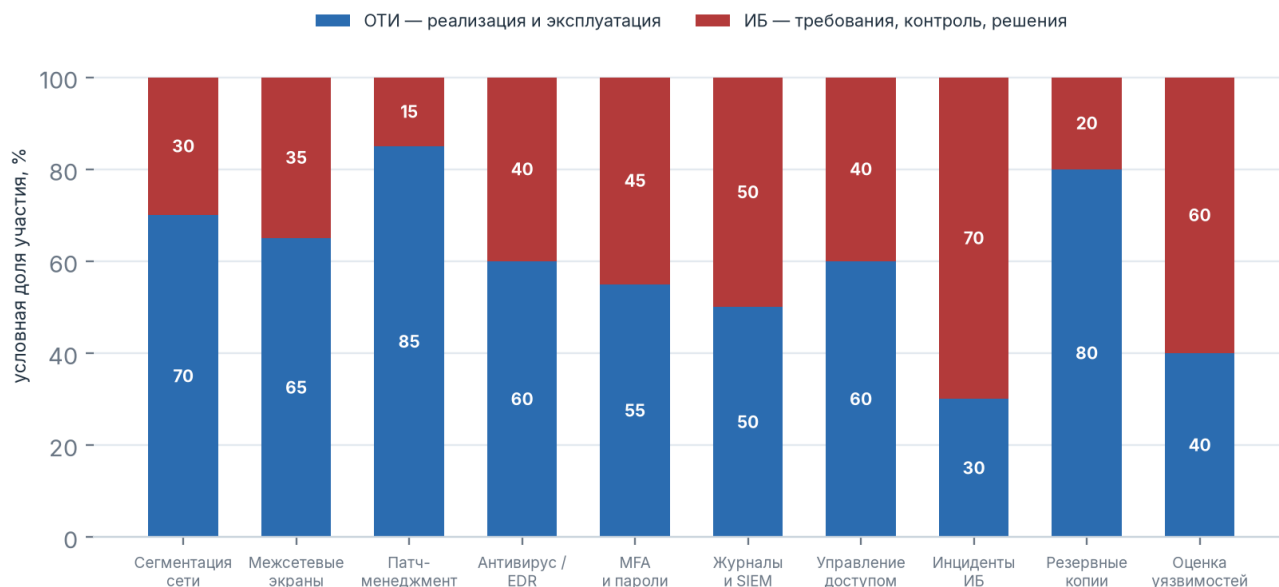


Рис. 8. Разделение ответственности между ОТИ и отделом ИБ по доменам защиты: «кто выполняет» и «кто устанавливает требования и проверяет».

Домен	Отдел ИБ	ОТИ
Сегментация сети	Требования к сегментам, правила взаимодействия, согласование схемы	Проектирование и реализация VLAN, ACL, маршрутизации, поддержание схемы
Межсетевые экраны	Согласование правил, контроль изменений, аудит	Администрирование, внесение согласованных правил, документирование
Обновления и уязвимости	Требования к срокам устранения, приоритизация по критичности	Планирование и установка обновлений, тестирование, отчёт об установке
Антивирус и EDR	Выбор решения, политики, контроль покрытия, реакция на срабатывания	Развёртывание агентов, поддержание работоспособности, устранение отклонений
Аутентификация, MFA, пароли	Парольная политика, требования к MFA, контроль соблюдения	Настройка политик в домене и сервисах, техническая поддержка MFA
Журналирование	Состав собираемых событий, срок хранения, анализ	Настройка источников, передача журналов, сохранность инфраструктуры сбора
Управление доступом	Правила предоставления, согласование доступа к защищаемым ресурсам, ревизия прав	Техническое предоставление и отзыв прав, ведение матрицы доступа
Инциденты ИБ	Классификация, расследование, координация, взаимодействие с руководством	Технические действия по указанию ИБ, сохранение следов, восстановление сервисов
Резервные копии	Требования к защите, изоляции и хранению копий, контроль	Настройка, выполнение, контроль заданий, восстановление, тестирование
Доступ подрядчиков	Решение о предоставлении доступа, выдача учётных данных	Обоснование состава и срока, сопровождение работ, отзыв по завершении

Таблица 12. Матрица разграничения ОТИ и отдела ИБ

Учётное исключение

Общая административная учётная запись в инфраструктуре сохраняется исключительно как аварийная (break-glass). Пароль хранится в отделе ИБ, порядок применения описан в разделе 11. Повседневное администрирование под общей учётной записью запрещено.

5.4. Разграничение с отделом 1С и бизнес-приложениями

Объект	ОТИ	Отдел 1С
Сервер приложений 1С	ОС, ресурсы, доступность, обновления ОС, мониторинг, резервное копирование	Служба 1С, её настройки, публикации, версии платформы (по согласованию)
СУБД	Установка, ресурсы, обслуживание, резервное копирование, производительность на уровне инфраструктуры	Структура данных прикладного решения, регламентные задания прикладного уровня
Конфигурация 1С	—	Доработки, обновления, тестирование, права в прикладном решении
Права пользователей	Доменные учётные записи и группы	Роли и права внутри прикладного решения
Производительность	Диагностика на уровне сервера, СХД, сети, ресурсов	Оптимизация запросов и прикладной логики
Инцидент «1С не работает»	Первичная диагностика инфраструктуры: сервер, сеть, СУБД, доступность службы	Диагностика прикладного уровня после подтверждения работоспособности инфраструктуры

Таблица 13. Разграничение по инфраструктуре и прикладному уровню 1С

Практическое правило

Порядок разбора обращений по 1С: 1-я линия регистрирует обращение, 2-я линия проверяет инфраструктурный уровень (доступность сервера, службы, СУБД, сети, ресурсов) и фиксирует результат в заявке. Если инфраструктура работоспособна, заявка передаётся в отдел 1С с приложением результатов проверки. Передача «без диагностики» не допускается ни в одну сторону.

5.5. Матрица ответственности по сквозным процессам (RACI)

Обозначения: **R** — исполняет, **A** — отвечает за результат, **C** — согласует или консультирует, **I** — информируется.

Процесс / действие	Рук. ОТИ	2-я линия	1-я линия	Сервис-менеджер	Отдел ИБ	Отдел 1С	Закупки	ИТ-директор	Владелец процесса
Приём и регистрация обращения	I	C	R/A	—	—	—	—	—	I
Определение приоритета заявки	A	C	R	—	C	—	—	I	C
Устранение инцидента инфраструктуры	A	R	C	—	I	—	—	I	I
Объявление крупного инцидента (Sev-1)	R/A	C	I	—	C	C	—	I	I
Оформление и согласование RFC	A	R	C	—	C	C	—	C	C
Выполнение изменения	A	R	C	—	I	C	—	I	I
Согласование изменения с влиянием на защищённость	R	C	—	—	A	—	—	I	I
Создание сервера / виртуальной машины	A	R	—	—	C	C	—	I	C
Изменение сетевой конфигурации	A	R	—	—	C	—	—	I	I
Предоставление доступа сотруднику	A	R	R	—	C	C	—	I	C
Блокировка учётной записи при увольнении	I	R	R	C	R/A	C	—	I	C
Резервное копирование критичных систем	A	R	—	—	C	C	—	I	I
Тестовое восстановление из копии	A	R	—	—	C	C	—	I	I
Мониторинг и реагирование на события	A	R	C	—	I	—	—	I	—
Выдача оборудования сотруднику	I	—	R	R/A	I	—	—	—	C
Учёт и инвентаризация оборудования	C	C	R	R/A	C	—	C	I	—
Формирование технических требований к закупке	R/A	C	C	C	C	C	I	C	C
Закупочная процедура и договор	C	—	—	—	C	—	R/A	A	I
Привлечение подрядчика	R/A	C	—	—	C	—	C	C	I
Предоставление доступа подрядчику	C	C	—	—	R/A	—	—	I	I
Приёмка результата работ подрядчика	C	C	—	—	C	C	C	I	R/A
Ведение каталога сервисов	R/A	C	C	—	C	C	—	I	C
Определение класса критичности сервиса	R	C	—	—	C	C	—	A	C
Документирование инфраструктуры	A	R	R	C	C	—	—	I	—
Разбор инцидента (постмортем)	R/A	R	C	—	C	C	—	I	C
Формирование бюджета отдела	R	C	C	C	C	—	C	A	—
Внутренний аудит соблюдения Политики	R	C	C	C	C	—	—	A	—

Таблица 14. RACI-матрица сквозных процессов (утверждается вместе с Политикой; изменения вносятся решением ИТ-директора)

5.6. Порядок разрешения спорных зон ответственности

Спорная ситуация — случай, когда принадлежность задачи к зоне ответственности подразделения неочевидна или оспаривается. Порядок действий:

- задача не останавливается: до разрешения спора её ведёт подразделение, первым принявшее обращение, а при инциденте — подразделение, чья зона наиболее вероятна по первичной диагностике;
- руководители затронутых подразделений принимают решение в течение одного рабочего дня (для инцидентов класса А — незамедлительно);
- при отсутствии согласия решение принимает ИТ-директор, а в части информационной безопасности — руководитель отдела ИБ;
- принятое решение фиксируется в заявке и, если ситуация типовая, вносится в матрицу ответственности при следующем пересмотре Политики.

Запрет

Запрещённая практика: возврат обращения пользователю с формулировкой «это не наша зона» без указания ответственного подразделения и без передачи заявки. Ответственность за маршрутизацию обращения лежит на ИТ, а не на пользователе.

6. Каталог ИТ-сервисов

Все существующие и вновь вводимые сервисы должны быть описаны, классифицированы и иметь ответственных.

6.1. Требование описания сервисов

Базовое требование раздела

Каждый ИТ-сервис Компании должен быть внесён в каталог сервисов, иметь паспорт (приложение А), назначенного владельца со стороны бизнеса, ответственного инженера со стороны ОТИ и присвоенный класс критичности. Сервис, не внесённый в каталог, не принимается на поддержку: обращения по нему обрабатываются как консультации, целевые сроки и параметры доступности к нему не применяются.

Каталог сервисов ведёт руководитель ОТИ. Каталог хранится в электронном виде (раздел 18), актуализируется при каждом вводе, изменении или выводе сервиса и полностью пересматривается не реже одного раза в год.

6.2. Классификация сервисов по критичности

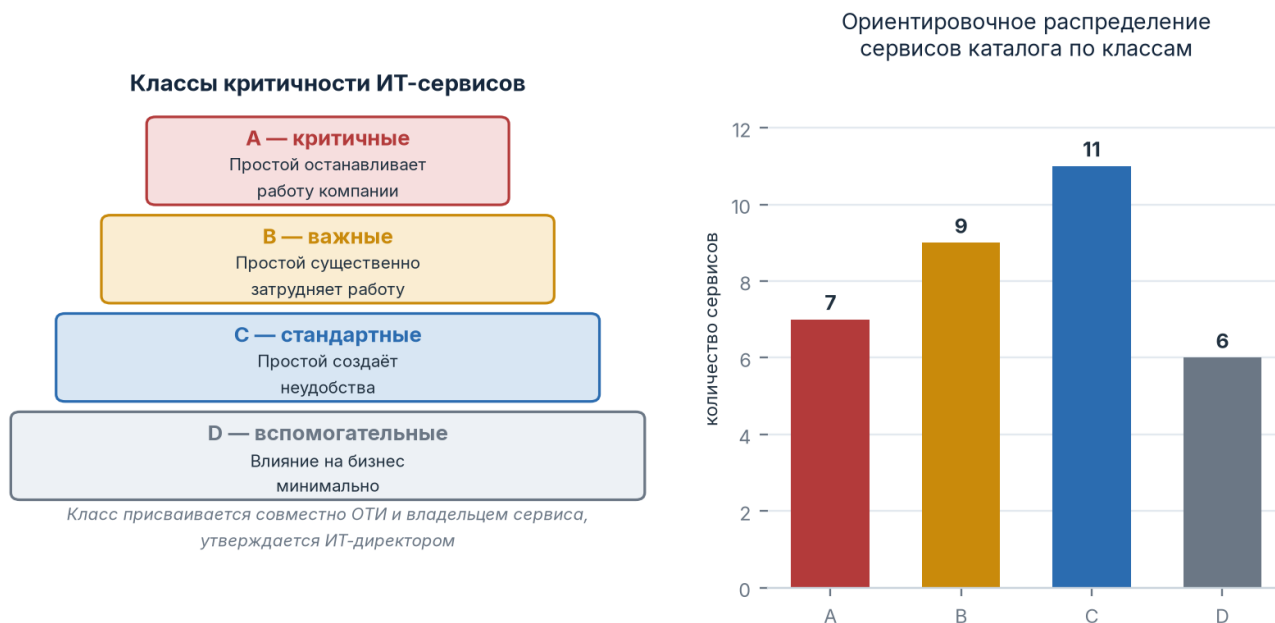


Рис. 9. Классы критичности ИТ-сервисов и ориентировочное распределение сервисов каталога по классам.

Класс	Определение	Целевая доступность	Приоритет при инциденте	Требования
A — критичный	Простой останавливает деятельность Компании или площадки, либо ведёт к потере данных	99,5 % в рабочее время	P1	Мониторинг уровней 1–3, резервирование, ежедневное копирование, тестовое восстановление ежеквартально, документированный DRP-сценарий
B — важный	Простой существенно затрудняет работу подразделений, но деятельность продолжается	99,0 % в рабочее время	P2	Мониторинг уровней 1–3, ежедневное копирование, тестовое восстановление раз в полгода
C — стандартный	Простой создаёт неудобства, есть обходные варианты работы	98,0 % в рабочее время	P3	Мониторинг уровней 1–2, регулярное копирование, документация
D — вспомогательный	Влияние на деятельность минимально: тестовые, демонстрационные, вспомогательные системы	не нормируется	P4	Базовый мониторинг, копирование по решению ответственного инженера

Таблица 15. Классы критичности и связанные требования

Класс критичности предлагается руководителем ОТИ совместно с владельцем сервиса и утверждается ИТ-директором. Пересмотр класса выполняется при изменении роли сервиса в бизнес-процессах.

6.3. Первичный перечень сервисов

Ниже приведён первичный перечень сервисов, подлежащих описанию в первую очередь. Перечень является отправной точкой: окончательный состав, владельцы и классы фиксируются в реестре (приложение В) по результатам инвентаризации.

№	Сервис	Состав / компоненты	Класс (проект)	Ответственный ОТИ	Владелец со стороны бизнеса	RPO / RTO (проект)
1	Инфраструктура 1С: базы данных и серверы	Серверы приложений, СУБД, дисковые ресурсы, резервные копии	A	Системный администратор (осн.)	Отдел 1С совместно с финансовым блоком	1 ч / 2 ч
2	Доменная инфраструктура	Контроллеры домена, DNS, DHCP, групповые политики	A	Системный администратор (осн.)	ИТ-блок	4 ч / 2 ч
3	Корпоративная электронная почта	Exchange, транспорт, почтовые ящики, антиспам	A	Системный администратор	Административный блок	4 ч / 4 ч
4	Файловые хранилища	Файловые серверы, общие ресурсы, права, квоты	A	Системный администратор	Руководители подразделений	8 ч / 8 ч
5	Система резервного копирования	Сервер резервного копирования, хранилища копий, расписания	A	Системный администратор	ИТ-блок	24 ч / 12 ч
6	Локальная сеть площадок	Коммутаторы, VLAN, СКС, ИБП сетевого оборудования	A	Сетевой инженер	ИТ-блок	— / 1 ч
7	Доступ в интернет и межсетевое экранирование	Каналы связи, маршрутизаторы, межсетевые экраны	A	Сетевой инженер	ИТ-блок	— / 1 ч
8	Удалённый доступ (VPN)	Шлюзы VPN, профили, MFA	B	Сетевой инженер	ИТ-блок и руководители подразделений	— / 4 ч
9	Платформа виртуализации	Хосты, кластеры, хранилища, шаблоны	A	Системный администратор	ИТ-блок	24 ч / 4 ч
10	Системы хранения данных	СХД, тома, репликация	A	Системный администратор	ИТ-блок	— / 4 ч
11	Wi-Fi корпоративный и гостевой	Точки доступа, контроллер, гостевой сегмент	B	Сетевой инженер	ИТ-блок	— / 8 ч
12	Корпоративная телефония	Сервер телефонии, номерной план, абонентские устройства	B	Сетевой инженер	Административный блок	— / 8 ч
13	Рабочие места пользователей	Рабочие станции, ноутбуки, образы, ПО	B	Руководитель 1-й линии	Руководители подразделений	— / 8 ч
14	Печать и МФУ	Серверы печати, принтеры, МФУ	C	Специалист 1-й линии	Руководители подразделений	— / 8 ч
15	Видеонаблюдение (ИТ-составляющая)	Серверы записи, хранилища, сеть	B	Системный администратор	Служба безопасности	24 ч / 8 ч
16	Мониторинг инфраструктуры	Сервер мониторинга, агенты, оповещения	B	Системный администратор	ИТ-блок	24 ч / 8 ч
17	Служба каталога печати и файловых сервисов на площадках	Локальные серверы площадок	B	Системный администратор	Руководители площадок	24 ч / 8 ч
18	Корпоративные облачные сервисы	Подписки, интеграция, учётные записи	C	Системный администратор	Владельцы сервисов	по условиям провайдера
19	Итилиум (HelpDesk)	Сервер приложения, база данных, почтовый шлюз	B	Системный администратор	ИТ-блок	8 ч / 8 ч
20	Тестовые и демонстрационные среды	Виртуальные машины, изолированные сегменты	D	Системный администратор	Инициатор среды	не нормируется

Таблица 16. Первичный перечень ИТ-сервисов, подлежащих описанию (классы и параметры указаны как проект для утверждения)

6.4. Порядок ввода нового сервиса

Жизненный цикл ИТ-сервиса

Сервис считается введённым в эксплуатацию только при наличии паспорта, мониторинга, резервного копирования и документации



Рис. 10. Жизненный цикл ИТ-сервиса: от потребности до вывода из эксплуатации.

Новый сервис вводится в эксплуатацию только при одновременном выполнении всех условий приёмки:

№	Контрольный пункт	Выполнено (да/нет)	Дата	Ответственный
1	Оформлен паспорт сервиса (приложение А), назначен владелец и ответственный инженер			
2	Присвоен класс критичности, определены целевые RPO и RTO			
3	Выполнено проектирование, согласован RFC на ввод сервиса			
4	Проведено тестирование по плану, результаты зафиксированы			
5	Сервис включён в систему мониторинга (уровни 1–3 согласно классу)			
6	Настроено и проверено резервное копирование, выполнено контрольное восстановление			
7	Разработаны инструкции по типовым операциям (runbook) и восстановлению			
8	Определены и настроены права доступа, внесены в матрицу доступа			
9	Согласование отдела ИБ получено (при обработке защищаемой информации)			
10	Сервис внесён в реестр (приложение В), документация размещена на сетевом диске			
11	Назначен резервный ответственный, проведена передача знаний			
12	Сервис учтён в бюджете эксплуатации (лицензии, поддержка, ресурсы)			

Форма 1. Чек-лист приёмки нового сервиса в эксплуатацию

6.5. Изменение и вывод сервиса из эксплуатации

- изменение состава, класса критичности или ответственных за сервис оформляется изменением паспорта сервиса и фиксируется в реестре;
- вывод сервиса из эксплуатации выполняется по RFC с планом миграции или архивации данных, отзывом доступов, снятием с мониторинга и резервного копирования, исключением из учёта и высвобождением лицензий;
- вывод сервиса класса А согласуется с владельцем сервиса и ИТ-директором;
- данные выведенного сервиса хранятся в соответствии с требованиями отдела ИБ и нормативными сроками хранения; уничтожение данных оформляется актом.

6.6. Ежегодная ревизия каталога

Не реже одного раза в год руководитель ОТИ проводит ревизию каталога, в ходе которой:

- подтверждается актуальность перечня сервисов, владельцев и ответственных;
- проверяется соответствие классов критичности реальной роли сервисов;
- выявляются неучтённые («теневые») сервисы и системы, вводится план их легализации или вывода из эксплуатации;
- оценивается фактическая достижимость заявленных RPO и RTO по результатам тестовых восстановлений;
- результаты оформляются отчётом ИТ-директору с планом корректирующих действий.

7. Управление обращениями

Единая точка входа, классификация, приоритеты, эскалация и дисциплина ведения заявок.

7.1. Единая точка входа

Правило единой точки входа

Единственный официальный канал обращения в ИТ — электронная почта **help@exon-group.ru** с автоматической регистрацией обращения в системе **Итилиум**. Целевое требование: **100 % обращений** проходят через систему учёта. Работа по устным и частным просьбам без регистрации заявки не допускается.



Рис. 11. Процесс обработки обращения и типовые ответвления.

7.2. Обращения, поступившие вне системы учёта

Пользователи продолжают обращаться лично, по телефону и в мессенджерах. Цель Политики — не наказать пользователя, а обеспечить учёт работы. Порядок действий сотрудника ОТИ:

Ситуация	Действие сотрудника ОТИ	Что недопустимо
Обращение лично или по телефону, задача занимает до 10 минут	Помочь, после чего самостоятельно создать заявку с пометкой канала поступления и попросить в дальнейшем писать на help@	Выполнить работу и не зафиксировать её
Обращение лично или по телефону, задача требует времени	Попросить направить обращение на help@ либо создать заявку от имени пользователя и сообщить её номер	Принять задачу «на память»
Обращение в мессенджере	Создать заявку, в ответе указать номер и далее вести переписку в заявке	Вести обсуждение задачи только в мессенджере
Критичный сбой, сообщённый устно	Немедленно приступить к устранению, заявку оформить параллельно или сразу после стабилизации	Ждать заявку при остановке бизнес-процесса
Задача, поставленная руководителем устно	Зафиксировать заявкой (в том числе от своего имени) с указанием инициатора	Выполнять поручение без следа в системе учёта

Таблица 17. Обработка обращений, поступивших вне единой точки входа

Показатель «доля обращений, зарегистрированных в системе учёта» включается в отчётность отдела. Ответственность за перевод обращений в систему учёта несёт 1-я линия и её руководитель.

7.3. Категории обращений

Категория	Содержание	Примеры	Целевой результат
Инцидент	Нарушение или снижение качества работы сервиса	Не работает почта, недоступен файловый ресурс, не печатает МФУ, отсутствует сеть на площадке	Восстановление работоспособности
Запрос на обслуживание	Штатная операция из перечня услуг ОТИ	Выдача ноутбука, установка ПО из разрешённого перечня, создание почтового ящика, подключение принтера	Выполнение услуги в целевой срок
Запрос на изменение	Требуется изменение инфраструктуры или конфигурации	Новая виртуальная машина, новое правило межсетевого экрана, изменение структуры прав, новый VLAN	Оформление и выполнение RFC (раздел 8)
Консультация	Вопрос, не требующий вмешательства в инфраструктуру	Как подключиться к VPN, как настроить подпись в почте	Ответ и, при повторяемости, инструкция для пользователей
Инцидент ИБ	Признаки нарушения информационной безопасности	Фишинг, подозрительное ПО, шифрование файлов, утечка данных, компрометация учётной записи	Немедленная передача в отдел ИБ, технические действия по указанию ИБ

Таблица 18. Категории обращений и целевые результаты их обработки

7.4. Приоритеты обращений

Приоритет определяется формально — по масштабу влияния и срочности, а не по должности заявителя. Приоритет присваивает 1-я линия при регистрации; изменить приоритет вправе руководитель службы поддержки и руководитель ОТИ.

Матрица определения приоритета заявки

Срочность	Критическая	P2	P2	P1	P1
	Высокая	P3	P3	P2	P1
	Средняя	P4	P3	P3	P2
	Низкая	P4	P4	P3	P2
		Один пользователь	Группа пользователей	Площадка / подразделение	Компания / критичный сервис
		Влияние (масштаб)			

P1 — критический · P2 — высокий · P3 — обычный · P4 — низкий

Рис. 12. Матрица определения приоритета: влияние (масштаб) × срочность.

Приоритет	Когда присваивается	Целевое время реакции	Целевое время решения	Кто уведомляется
P1 — критический	Остановлен критичный сервис или бизнес-процесс; затронута площадка или несколько площадок	15 минут	4 часа	Руководитель ОТИ, ИТ-директор, владелец процесса, при необходимости отдел ИБ
P2 — высокий	Существенное затруднение работы подразделения или группы пользователей; критичный сервис работает с деградацией	30 минут	8 часов (1 рабочий день)	Руководитель ОТИ, руководитель подразделения
P3 — обычный	Влияние на отдельных пользователей, есть обходной вариант	4 часа	3 рабочих дня	Инициатор
P4 — низкий	Запросы на обслуживание, консультации, плановые работы	1 рабочий день	5–10 рабочих дней (по согласованию)	Инициатор

Таблица 19. Приоритеты и целевые параметры обработки (проект значений; окончательные закрепляются в SLA)

Статус значений

Указанные в таблице значения — **проект целевых параметров** для последующего закрепления в SLA. До утверждения SLA они применяются как внутренние ориентиры отдела и используются для сбора статистики, но не как обязательства перед бизнесом.

Право присвоения критического приоритета

- приоритет P1 присваивается автоматически при срабатывании мониторинга по критичному сервису класса А;
- присвоить или подтвердить P1 вправе: руководитель ОТИ, руководитель службы поддержки, дежурный сотрудник (в нерабочее время), отдел ИБ (для инцидентов ИБ), ИТ-директор;
- владелец бизнес-процесса вправе **запросить** повышение приоритета до P1 с обоснованием влияния на процесс; решение принимает руководитель ОТИ и фиксирует в заявке;
- снижение приоритета с P1 выполняется только после подтверждения восстановления либо после установления, что влияние оценено неверно; основание фиксируется в заявке.

Обращения руководителей

Обращения руководителей обрабатываются по общим правилам: приоритет определяется по матрице влияния и срочности. При этом учитываются два объективных обстоятельства:

- если неработоспособность рабочего места руководителя блокирует принятие решений или согласование документов, влияние оценивается как «подразделение», что даёт приоритет P2;
- для руководителей, участвующих в непрерывных процессах (например, при проведении совещаний, переговоров, внешних мероприятий), допускается предоставление подменного оборудования из резервного фонда как обходное решение — это фиксируется в заявке.

Принцип

Недопустимо существование «негласной очереди вне правил»: любое повышение приоритета фиксируется в заявке с указанием основания и лица, принявшего решение. Это защищает и бизнес (предсказуемость), и сотрудников ОТИ (прозрачная загрузка).

7.5. Эскалация



Эскалация — штатный рабочий инструмент, а не жалоба. Неэскалированная просроченная заявка считается нарушением дисциплины исполнения

Рис. 13. Схема эскалации по уровням и основания для перехода.

- эскалация выполняется автоматически по истечении целевого времени и вручную — при риске нарушения сроков;
- эскалация не является жалобой на исполнителя; отсутствие эскалации при просроченной заявке считается нарушением дисциплины исполнения;
- для заявок P1 руководитель ОТИ информируется немедленно, независимо от времени суток;
- в нерабочее время и в праздничные дни эскалация выполняется по схеме дежурств (раздел 15).

7.6. Дисциплина ведения заявок

Требование	Содержание
Обязательные поля	Категория, приоритет, сервис (из каталога), инициатор, исполнитель, описание проблемы
Ход работ	Существенные действия и результаты диагностики фиксируются в заявке в день их выполнения
Ожидание	Перевод заявки в статус ожидания допускается с указанием, чего именно и от кого ждём, и с установленным сроком контроля
Закрытие заявки	Обязательны: описание причины, описание выполненных действий, отметка сервиса и категории; для запросов на обслуживание — подтверждение пользователя
Повторное обращение	При повторении проблемы в течение 5 рабочих дней инцидент связывается с предыдущим, анализируется причина
Массовые обращения	Однотипные обращения связываются с одним «родительским» инцидентом; коммуникация ведётся централизованно
Запрет	Закрытие заявки без описания решения, закрытие «за давностью» без связи с инициатором, удаление заявок

Таблица 20. Обязательные требования к ведению заявок в системе учёта

Руководитель службы поддержки ежедневно контролирует качество ведения заявок, руководитель ОТИ — еженедельно выборочно. Систематические нарушения дисциплины ведения заявок рассматриваются как нарушение Политики (раздел 21).

8. Управление изменениями инфраструктуры

Ключевой раздел Политики: ни одно существенное изменение не выполняется без согласования, плана внедрения, плана тестирования и плана отката.

8.1. Базовое требование

Требование раздела 8

Любое изменение инфраструктуры должно быть **согласовано до начала работ** и выполнено так, чтобы **не нарушить работу действующей инфраструктуры**. До начала работ разрабатываются: план внедрения, план тестирования, план отката и порядок ввода в эксплуатацию. Изменение, выполненное без согласования и без плана, считается несанкционированным.

Изменением считается любая модификация конфигурации инфраструктуры, способная повлиять на работу ИТ-сервисов: изменение параметров оборудования и систем, установка и обновление программного обеспечения на серверах, изменение сетевой конфигурации и правил доступа, создание и удаление систем, изменение схем резервного копирования и мониторинга.

8.2. Классы изменений

Класс	Определение	Согласование	Оформление	Окно работ
Стандартное	Типовая, многократно выполнявшаяся операция с известным результатом и низким риском; входит в утверждённый перечень стандартных изменений	Предварительно согласовано перечнем; отдельное согласование не требуется	Заявка в системе учёта	Рабочее время, если нет влияния на пользователей
Обычное	Изменение с ограниченным влиянием на один сервис класса B–D	Руководитель ОТИ	RFC (приложение C) с планом внедрения и отката	Стандартное окно
Существенное	Изменение, затрагивающее сервисы класса A, несколько сервисов, площадку или требующее простоя	Руководитель ОТИ, отдел ИБ (при влиянии на защищённость), ИТ-директор, владелец сервиса	RFC с полным комплектом планов и критериями успеха	Расширенное окно по согласованию
Аварийное	Изменение, необходимое для устранения инцидента или предотвращения его развития	Устное согласование руководителя ОТИ (или дежурного руководителя) до начала работ, если это возможно без увеличения простоя	RFC оформляется по факту, не позднее следующего рабочего дня	Немедленно

Таблица 21. Классы изменений и требования к их оформлению

Перечень стандартных изменений утверждается руководителем ОТИ отдельным документом и пересматривается не реже одного раза в год. Включение операции в перечень стандартных изменений возможно только при наличии инструкции (runbook) и подтверждённой практики безошибочного выполнения.

8.3. Изменения, требующие обязательного согласования

Область	Что именно требует согласования	Дополнительное согласование
Сеть	Создание и изменение VLAN, изменение маршрутизации, изменение схемы коммутации, замена сетевого оборудования, изменение параметров каналов связи	Отдел ИБ — при изменении границ сегментов
Межсетевые экраны	Любое изменение правил, публикация сервисов наружу, изменение политик NAT и VPN	Отдел ИБ — обязательно
Серверы	Ввод, вывод, перенос серверов, изменение конфигурации оборудования, обновление гипервизора и прошивок, изменение параметров кластеров	Владелец сервиса — при простое
Доменная инфраструктура	Изменение структуры домена, схемы, групповых политик, политик паролей и блокировок, доверительных отношений	Отдел ИБ — обязательно
Виртуальные машины	Создание, удаление, изменение ресурсов, перенос между хостами и хранилищами, изменение сетевых подключений	Руководитель ОТИ
Резервное копирование	Изменение расписаний, состава копируемых данных, сроков хранения, схемы хранения копий	Отдел ИБ — обязательно
Критичные бизнес-системы	Работы, затрагивающие серверы и базы данных 1С, почтовую систему, файловые хранилища	Владелец сервиса, отдел 1С — в части прикладного уровня
Системы защиты	Изменение параметров антивируса, EDR, средств контроля, журналирования	Отдел ИБ — обязательно
Учётные записи и доступы	Изменение схемы прав, создание административных учётных записей, изменение состава привилегированных групп	Отдел ИБ — обязательно
Рабочие места	Массовые изменения конфигураций, развёртывание нового ПО на группу пользователей, изменение образов	Руководитель ОТИ; отдел ИБ — при изменении средств защиты
Облачные сервисы	Подключение новых сервисов, изменение интеграций с корпоративной сетью, изменение схемы хранения данных	Отдел ИБ — обязательно

Таблица 22. Перечень изменений, требующих обязательного предварительного согласования

8.4. Процесс управления изменениями



Рис. 14. Сквозной процесс управления изменениями: от потребности до закрытия RFC и обновления документации.

Обязательный состав RFC (приложение С):

Раздел RFC	Содержание
Описание и обоснование	Что меняем, зачем, какую проблему решаем, что произойдёт при отказе от изменения
Затрагиваемые сервисы	Перечень сервисов из каталога, их классы критичности, зависимые системы и площадки
Оценка влияния и риска	Ожидаемое влияние на пользователей, вероятность и последствия неуспеха, меры снижения риска
План внедрения	Пошаговая последовательность работ с исполнителями и оценкой времени каждого шага
План тестирования	Что и как проверяем после изменения, кто подтверждает работоспособность, участие пользователей
Критерии успеха и неуспеха	Измеримые признаки успешного изменения и условия, при которых выполняется откат
План отката (rollback)	Пошаговый возврат в исходное состояние, время отката, точка невозврата, резервные копии перед работами
Окно работ и простой	Дата, время начала и окончания, планируемый простой, порядок уведомления пользователей
Ввод в эксплуатацию	Условия перевода изменения в штатную эксплуатацию, обновление мониторинга и резервного копирования
Документирование	Какие документы и схемы подлежат обновлению, ответственный и срок

Таблица 23. Обязательные разделы заявки на изменение (RFC)

Требование к плану отката

Для изменений, затрагивающих сервисы класса А, наличие плана отката обязательно. Если откат технически невозможен, это указывается в RFC отдельно, вместе с компенсирующими мерами (резервная копия, тестовый стенд, окно с минимальным влиянием, присутствие подрядчика), и такое изменение согласуется ИТ-директором.

8.5. Технический совет по изменениям

Для рассмотрения существенных изменений создаётся технический совет по изменениям — рабочая группа, действующая в облегчённом формате (принцип «Enterprise с человеческим подходом»: минимум бюрократии при сохранении контроля).

Параметр	Значение
Состав (постоянный)	Руководитель ОТИ (председатель), ведущие системные администраторы, ведущий сетевой инженер, руководитель службы поддержки
Состав (приглашаемые)	Представитель отдела ИБ — при влиянии на защищённость; представитель отдела 1С и владелец сервиса — при влиянии на бизнес-системы
Периодичность	Один раз в неделю, продолжительность до 30 минут; внеплановое заседание — по решению руководителя ОТИ
Предмет рассмотрения	Существенные изменения, изменения с простоем, изменения с неполным планом отката, аварийные изменения прошедшей недели (постконтроль)
Решения	Согласовать; согласовать с условиями (доработать план, изменить окно); отклонить с указанием причины; вернуть на доработку
Фиксация	Решение фиксируется в RFC; отдельный протокол не ведётся, кроме отклонённых и условно согласованных изменений
Срочные согласования	Вне заседаний: согласование руководителем ОТИ в системе учёта в течение 1 рабочего дня

Таблица 24. Регламент технического совета по изменениям

8.6. Окна проведения работ и периоды запрета изменений

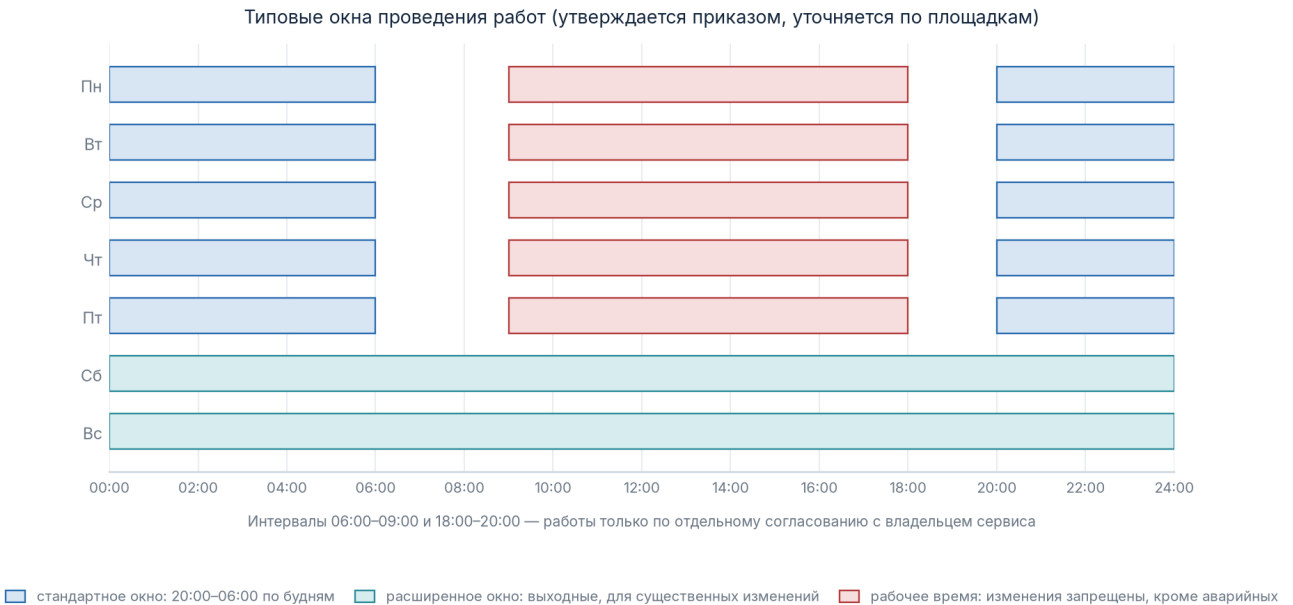


Рис. 15. Типовые окна проведения работ в течение недели. Конкретные интервалы по площадкам уточняются с учётом режима их работы.

Период	Что допускается	Основание
Стандартное окно: рабочие дни, 20:00–24:00 и 06:00–09:00	Обычные изменения, стандартные изменения с влиянием на пользователей	Согласованный RFC
Расширенное окно: выходные дни	Существенные изменения, работы с простоем, миграции	RFC, согласованный руководителем ОТИ и владельцем сервиса
Рабочее время: 09:00–18:00	Только стандартные изменения без влияния на пользователей и аварийные изменения	Перечень стандартных изменений или статус аварийного изменения
Период запрета изменений (freeze): закрытие периода в учётных системах, инвентаризация, пиковые дни бизнеса, праздничные периоды, дни массовых мероприятий	Только аварийные изменения	Решение руководителя ОТИ по согласованию с ИТ-директором; график публикуется заранее

Таблица 25. Окна работ и периоды запрета изменений

График периодов запрета изменений на календарный год формирует руководитель ОТИ на основании данных владельцев процессов и публикует его в разделе документации и в системе учёта.

8.7. Аварийные изменения

- аварийное изменение допускается только для устранения инцидента или предотвращения его развития;
- перед выполнением сотрудник обязан уведомить руководителя ОТИ (в нерабочее время — дежурного руководителя), если это не увеличивает простой;
- при невозможности предварительного уведомления сотрудник действует самостоятельно и уведомляет руководителя сразу после стабилизации ситуации;
- RFC на аварийное изменение оформляется по факту не позднее следующего рабочего дня и включает описание фактически выполненных действий;
- все аварийные изменения рассматриваются на ближайшем техническом совете в порядке постконтроля: оценивается обоснованность и то, можно ли было предотвратить ситуацию плановыми мерами.

Гарантия для инженера

Сотрудник, действовавший в аварийной ситуации в интересах восстановления сервиса, зафиксировавший свои действия и уведомивший руководителя, не может быть привлечён к ответственности за сам факт внепланового вмешательства. Ответственность возникает при сокрытии действий, отсутствии фиксации или использовании «аварийного» статуса для обхода процедуры согласования.

8.8. Запрет несанкционированных изменений

- запрещается изменение конфигурации в продуктивной среде без заявки или RFC, включая «мелкие» настройки;
- запрещается выполнение изменений в обход согласования по устной просьбе, независимо от должности обратившегося;
- запрещается отклонение от согласованного плана без уведомления руководителя ОТИ; при выявлении необходимости отклонения работы приостанавливаются;
- запрещается проведение экспериментов и тестирование новых решений в продуктивной среде; для этого используются тестовые среды;
- выявленные несанкционированные изменения фиксируются, анализируются на техническом совете и учитываются в отчётности отдела.

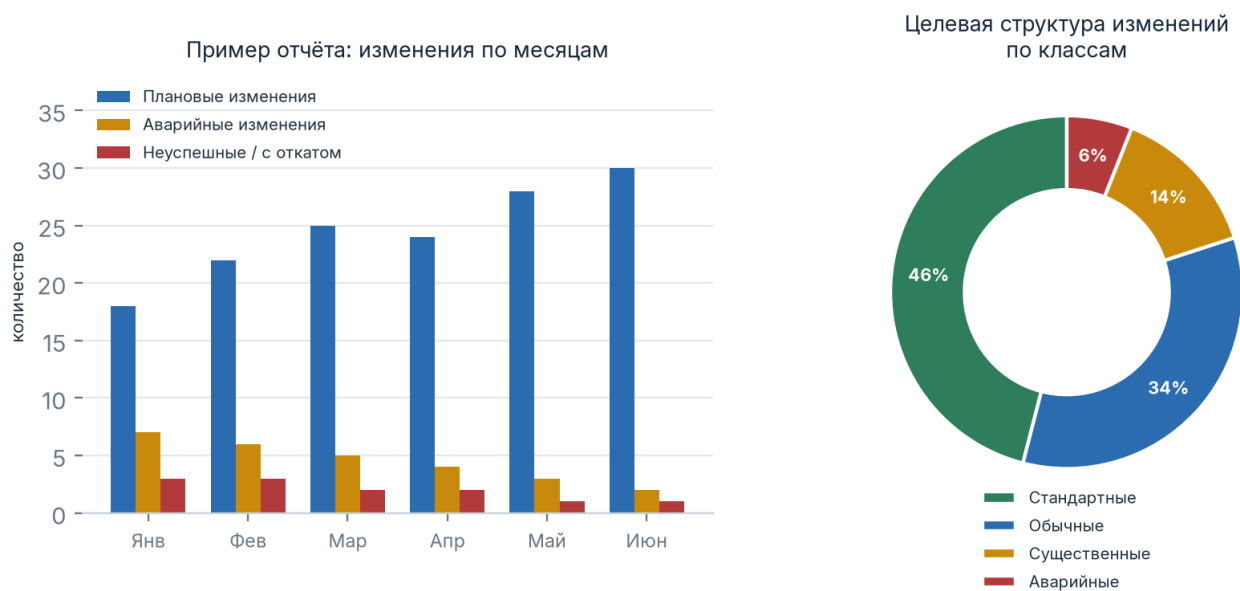


Рис. 16. Пример отчётности по изменениям: динамика плановых, аварийных и неуспешных изменений, а также целевая структура изменений по классам. Рост доли стандартных изменений и снижение доли аварийных — индикатор зрелости процесса.

9. Управление инфраструктурой: серверы, виртуализация, хранение

Принципы централизованного управления, порядок создания и вывода систем, стандарты и планирование ресурсов.

9.1. Обязательные принципы

Принцип	Содержание	Как проверяется
Только централизованное управление	Все серверы и виртуальные машины находятся под управлением ОТИ, входят в корпоративную схему управления, обновлений и мониторинга	Сверка перечня систем с реестром и системой мониторинга
Никаких «серверов под столом»	Размещение серверного оборудования вне серверных помещений и оборудованных мест запрещено; самовольно размещённое оборудование выявляется и выводится из эксплуатации или легализуется	Плановые обходы площадок, инвентаризация, анализ сетевой активности
Обязательная инвентаризация	Каждая единица оборудования и каждая виртуальная машина учтены с указанием назначения, ответственного, размещения и параметров	Ежеквартальная выборочная и ежегодная полная инвентаризация
Обязательный мониторинг	Каждая система включена в мониторинг в объёме, соответствующем классу критичности сервиса	Сверка реестра систем с объектами мониторинга
Обязательное резервное копирование	Для каждой системы определён режим копирования либо зафиксировано обоснованное решение о его отсутствии (для класса D)	Сверка реестра систем с заданиями резервного копирования
Обязательное документирование конфигурации	Для каждой системы поддерживается паспорт с назначением, конфигурацией, зависимостями и порядком восстановления	Аудит документации, проверка при вводе в эксплуатацию

Таблица 26. Принципы управления серверной инфраструктурой

Правило

Новые серверы и виртуальные машины создаются **только силами ОТИ** и только на основании согласованного RFC. Самостоятельное развёртывание серверных систем подразделениями, включая виртуальные машины в облачных сервисах и развёртывание на пользовательских компьютерах, не допускается.

9.2. Порядок создания сервера или виртуальной машины

Последовательность: заявка инициатора → определение требований ОТИ → RFC → создание → настройка по стандарту → включение в мониторинг и резервное копирование → документирование → передача инициатору. Полный чек-лист приведён в приложении Е.

Этап	Что выполняется	Ответственный
Определение требований	Назначение, ресурсы, требования к доступности и восстановлению, сетевое размещение, состав доступа	2-я линия совместно с инициатором
Согласование	Оценка влияния на ёмкость и лицензирование, согласование с ИБ при обработке защищаемой информации	Руководитель ОТИ
Развёртывание	Создание из утверждённого шаблона, применение стандартной конфигурации и политик безопасности	2-я линия
Включение в контуры управления	Домен, обновления, антивирус, мониторинг, резервное копирование, журналирование	2-я линия
Документирование	Паспорт системы, внесение в реестр, обновление схем	2-я линия
Передача	Проверка соответствия требованиям, уведомление инициатора, закрытие RFC	Руководитель ОТИ

Таблица 27. Этапы создания серверной системы

9.3. Установка серверного программного обеспечения

Подразделения не вправе самостоятельно устанавливать серверное программное обеспечение. Порядок легального ввода нового серверного ПО:

- инициатор направляет заявку с описанием назначения, ожидаемого результата и требований;
- ОТИ оценивает совместимость, требования к ресурсам, влияние на существующие сервисы и лицензионную чистоту;
- **обязательное согласование отдела информационной безопасности** — установка любого серверного ПО, а также ПО, обрабатывающего защищаемую информацию, выполняется только после решения отдела ИБ;
- при положительном решении оформляется RFC, ПО устанавливается силами ОТИ (или подрядчика под контролем ОТИ) с последующим документированием;
- при отрицательном решении инициатору направляется мотивированный ответ с предложением альтернативы, если она существует.

9.4. Стандартизация конфигураций

Объект стандартизации	Что фиксируется в стандарте
Именование	Единая схема имён серверов, виртуальных машин, сетевого оборудования, дисковых ресурсов и учётных записей с указанием площадки и назначения
Адресация	Структура IP-адресации по площадкам, диапазоны для серверов, рабочих мест, оборудования, гостевых сегментов, резервы
Базовая конфигурация серверов	Разметка дисков, параметры ОС, обязательные службы, параметры журналирования, локальные политики
Шаблоны виртуальных машин	Утверждённые образы, состав предустановленного ПО, параметры по умолчанию
Резервирование	Требования к отказоустойчивости для систем классов А и В: кластеризация, дублирование каналов, ИБП
Размещение	Требования к серверным помещениям: электропитание, охлаждение, контроль доступа, мониторинг температуры

Таблица 28. Объекты технической стандартизации (детализируются в *Technology Standard*, раздел 17)

9.5. Обновления и патч-менеджмент

Объект	Плановая периодичность	Критичные обновления безопасности	Особые условия
Серверы (ОС)	Ежемесячно, в согласованное окно	В срок, установленный отделом ИБ	Обязательное тестирование на системах класса А, наличие резервной копии до установки
Гипервизоры и прошивки	Раз в квартал или по рекомендации вендора	По решению ОТИ и ИБ	Поочерёдное обновление узлов кластера без простоя
Сетевое оборудование	Раз в полгода или по рекомендации вендора	По решению ОТИ и ИБ	Только в расширенное окно, с планом отката и резервной копией конфигурации
Рабочие места	Ежемесячно, централизованно	В срок, установленный отделом ИБ	Поэтапное развёртывание: сначала пилотная группа, затем остальные
Прикладное ПО	По согласованию с владельцем сервиса	По решению отдела ИБ	Согласование с отделом ИС для прикладных систем

Таблица 29. Цикл установки обновлений

9.6. Планирование ёмкости

ОТИ ведёт контроль утилизации вычислительных ресурсов, дискового пространства, портов коммутации и пропускной способности каналов. Превышение порога планирования является основанием для включения расширения в бюджет, а превышение критического порога — для внеплановой эскалации ИТ-директору.

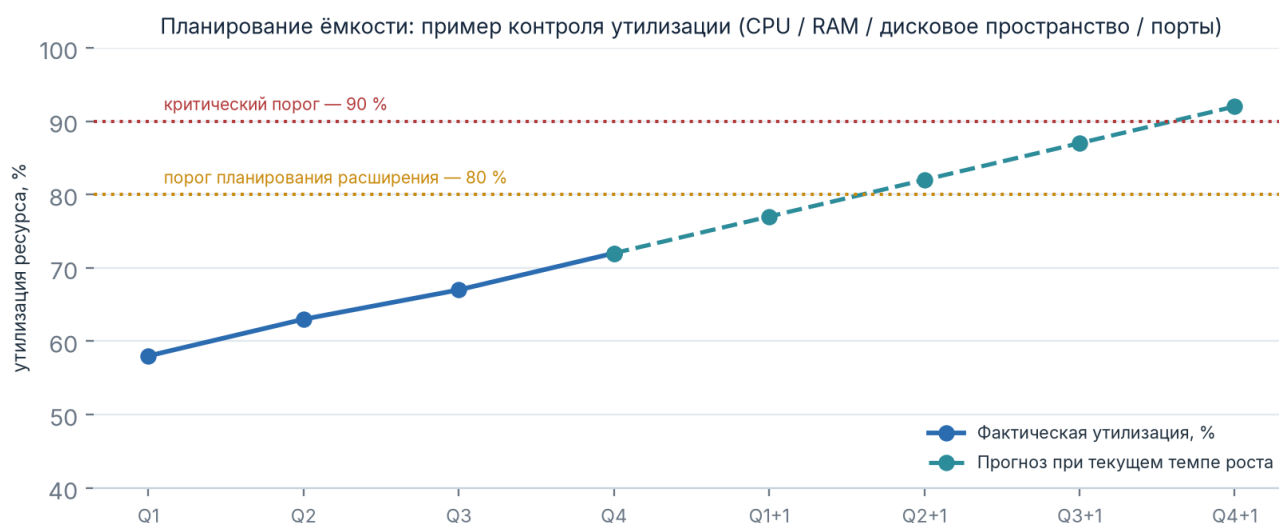


Рис. 17. Контроль утилизации ресурсов и прогноз: пороги 80 % (планирование расширения) и 90 % (критический уровень, требующий немедленных решений).

Ресурс	Порог планирования	Критический порог	Периодичность контроля
Процессорные ресурсы кластера виртуализации	70 %	85 %	Ежемесячно
Оперативная память кластера	75 %	90 %	Ежемесячно
Дисковое пространство СХД	75 %	85 %	Еженедельно
Дисковое пространство хранилища резервных копий	70 %	85 %	Еженедельно
Порты коммутаторов на площадке	80 %	95 %	Ежеквартально
Пропускная способность канала связи	70 % в пике	90 % в пике	Ежемесячно
Лицензии (на пользователя или устройство)	90 %	100 %	Ежеквартально

Таблица 30. Пороговые значения контроля ёмкости (проект значений для утверждения)

9.7. Вывод систем из эксплуатации

- вывод выполняется по RFC с планом: перенос или архивация данных, отзыв доступов, снятие с мониторинга и резервного копирования, высвобождение лицензий и ресурсов, исключение из реестра;
- перед выключением системы создаётся финальная резервная копия со сроком хранения, согласованным с владельцем сервиса и отделом ИБ;
- оборудование, выводимое из эксплуатации, передаётся сервис-менеджеру с актом; носители информации обрабатываются по требованиям отдела ИБ;
- система, отключённая «до выяснения», не может находиться в неопределённом состоянии более 30 календарных дней: по истечении срока принимается решение о вводе в эксплуатацию или о выводе.

10. Сеть, каналы связи и телеком

Единая ответственность за сетевую конфигурацию, обязательные схемы и порядок изменений.

10.1. Единая ответственность за сетевую конфигурацию

Правило раздела 10

Изменения сетевой конфигурации выполняет **только ответственный сетевой инженер** (или лицо, официально назначенное его замещающим) при обязательном предварительном согласовании и обязательной актуализации схемы. Изменение сетевой конфигурации другими сотрудниками, подразделениями или подрядчиками без участия ответственного сетевого инженера не допускается.

Объект изменения	Кто выполняет	Кто согласует	Обязательные артефакты
VLAN, схема коммутации	Ведущий сетевой инженер	Руководитель ОТИ; отдел ИБ — при изменении границ сегментов	Обновлённая схема L2, реестр VLAN, RFC
Маршрутизация	Ведущий сетевой инженер	Руководитель ОТИ	Обновлённая схема L3, таблица маршрутов, RFC
Правила межсетевого экрана	Ведущий сетевой инженер	Отдел ИБ (обязательно), руководитель ОТИ	Реестр правил с обоснованием и сроком действия, RFC
VPN и удалённый доступ	Ведущий сетевой инженер	Отдел ИБ, руководитель ОТИ	Схема доступа, перечень профилей, RFC
Wi-Fi	Ведущий сетевой инженер	Руководитель ОТИ	Схема покрытия, параметры сегментов, RFC
DNS и DHCP	Системный администратор совместно с сетевым инженером	Руководитель ОТИ	Реестр зон и диапазонов, RFC
Каналы связи и провайдеры	Ведущий сетевой инженер	Руководитель ОТИ, ИТ-директор — при изменении договоров	Паспорт площадки, схема подключения, реестр договоров

Таблица 31. Разграничение прав на изменение сетевой конфигурации

10.2. Обязательная сетевая документация

Отсутствие актуальной сетевой документации рассматривается как критический риск. Обязательный состав документации:

Документ	Содержание	Периодичность актуализации
Схема L1 (физическая)	Размещение оборудования, стойки, патч-панели, трассы, порты, маркировка	При каждом изменении, сверка ежегодно
Схема L2 (коммутация)	Коммутаторы, VLAN, агрегированные каналы, связи между узлами	При каждом изменении
Схема L3 (маршрутизация)	Подсети, шлюзы, маршруты, межсетевые экраны, точки выхода в интернет	При каждом изменении
IP-план	Распределение адресных диапазонов по площадкам и назначению, резервы	При каждом изменении
Реестр VLAN	Номер, назначение, площадка, адресный диапазон, ответственный	При каждом изменении
Реестр правил межсетевого экрана	Правило, обоснование, инициатор, дата, срок действия, согласование ИБ	При каждом изменении; ревизия раз в полгода
Паспорт площадки (приложение R)	Каналы связи, оборудование, серверная, электропитание, контакты, схема	При каждом изменении; сверка ежегодно

Документ	Содержание	Периодичность актуализации
Реестр договоров с провайдерами	Провайдер, услуга, параметры, SLA, контакты поддержки, срок действия	При изменении договоров

Таблица 32. Обязательный состав сетевой документации

Требование

Правило отрисовки схемы: изменение сетевой конфигурации считается завершённым только после обновления соответствующей схемы. Схема прикладывается к RFC до начала работ (проектное состояние) и обновляется после работ (фактическое состояние). Работа без схемы не принимается.

10.3. Особенности распределённой инфраструктуры

Компания эксплуатирует инфраструктуру на 11 площадках и обеспечивает работу удалённых сотрудников. Для каждой площадки ведётся паспорт (приложение R) и определяется уровень локальной автономности.

Параметр площадки	Что фиксируется в паспорте
Категория площадки	Основная (с серверной), крупная (локальные сервисы), малая (только доступ в сеть)
Каналы связи	Основной и резервный провайдер, пропускная способность, тип подключения, SLA провайдера, контакты поддержки
Сетевое оборудование	Перечень, модели, версии прошивок, схема подключения, резервные копии конфигураций
Серверная и электропитание	Помещение, стойки, ИБП, время автономной работы, охлаждение, контроль доступа, мониторинг среды
Локальные сервисы	Серверы, печать, видеонаблюдение, телефония
Ответственные	Ответственный инженер ОТИ, контактное лицо на площадке, подрядчик по обслуживанию
Порядок действий при отказе связи	Схема перехода на резервный канал, обходные варианты работы, порядок уведомления

Таблица 33. Обязательные сведения в паспорте площадки

10.4. Wi-Fi и гостевой доступ

- корпоративный и гостевой Wi-Fi разделены на уровне сети; гостевой сегмент не имеет доступа к корпоративным ресурсам;
- подключение личных устройств сотрудников к корпоративному сегменту допускается только по правилам, установленным отделом ИБ;
- параметры доступа к гостевой сети выдаются по заявке принимающего подразделения на ограниченный срок;
- размещение личных точек доступа и сетевого оборудования в корпоративной сети запрещено; выявленные устройства отключаются, факт фиксируется и передаётся в отдел ИБ.

10.5. Удалённый доступ

- удалённый доступ предоставляется только по заявке, согласованной руководителем сотрудника и отделом ИБ, с применением многофакторной аутентификации;
- доступ предоставляется к конкретным ресурсам по принципу минимально необходимых прав, а не «ко всей сети»;
- все подключения журналируются; состав журналируемых событий определяет отдел ИБ;
- для подрядчиков применяется отдельный порядок (раздел 16): временный доступ, сопровождение куратором, отзыв сразу после работ;
- использование личных средств удалённого доступа и сторонних сервисов удалённого управления запрещено без согласования отдела ИБ.

11. Управление доступом

Принцип минимально необходимых прав, типы учётных записей, административный доступ и отчётность за действия.

11.1. Принцип минимально необходимых прав

Базовый принцип раздела 11

Доступ предоставляется в минимально необходимом для выполнения обязанностей объёме, на минимально необходимый срок, персонально и на основании зарегистрированной заявки. Расширение прав «на будущее», предоставление доступа «как у коллеги» без анализа состава прав и бессрочный доступ к критичным ресурсам не допускаются.

Управление доступом: от заявки до отзыва



Рис. 18. Полный цикл управления доступом: от заявки до отзыва, включая типы учётных записей и порядок применения аварийной учётной записи.

11.2. Типы учётных записей

Тип	Назначение	Требования
Пользовательская	Повседневная работа сотрудника	Персональная, соответствует парольной политике, блокируется при увольнении по инициативе отдела ИБ
Административная	Администрирование инфраструктуры сотрудниками ОТИ	Персональная, отдельная от пользовательской, многофакторная аутентификация, запрет повседневной работы (почта, интернет, документы), журналирование действий
Сервисная	Работа служб и приложений	Без интерактивного входа, минимальные права, документированное назначение, владелец из числа сотрудников ОТИ, регламентированная смена пароля
Техническая	Управление оборудованием (коммутаторы, ИБП, СХД, камеры)	Индивидуальные учётные данные, хранение в защищённом хранилище секретов, запрет заводских паролей
Подрядчика	Выполнение работ внешним исполнителем	Временная, персонифицированная, предоставляется отделом ИБ, срок ограничен периодом работ, действия журналируются
Аварийная (break-glass)	Доступ при невозможности штатной аутентификации	Единственная общая административная запись, сложный пароль, хранение в отделе ИБ, особый порядок применения (п. 11.4)

Таблица 34. Типы учётных записей и требования к ним

11.3. Правила административного доступа

- каждый сотрудник ОТИ работает под персональной административной учётной записью; использование чужих учётных данных запрещено;
- административные права предоставляются в объёме зоны ответственности сотрудника, а не «полные права на всё»;
- повседневные задачи (электронная почта, интернет, офисные документы) выполняются только под пользовательской учётной записью;
- административный доступ к системам класса А предоставляется по согласованию с руководителем ОТИ и фиксируется в матрице доступа (приложение F);
- реестр административных учётных записей ведёт руководитель ОТИ, ревизия проводится не реже одного раза в квартал совместно с отделом ИБ;
- пароли административных, сервисных и технических учётных записей хранятся в защищённом хранилище секретов; хранение в файлах, таблицах, заметках, переписке и мессенджерах запрещено.

11.4. Аварийная (break-glass) учётная запись

В инфраструктуре сохраняется одна общая административная учётная запись, предназначенная исключительно для аварийных ситуаций, когда штатный персональный доступ невозможен (отказ службы каталога, недоступность средств многофакторной аутентификации, отсутствие ответственного сотрудника).

Элемент порядка	Требование
Пароль	Сложный, соответствующий требованиям отдела ИБ, известен ограниченному кругу лиц; передан в отдел ИБ и хранится в запечатанном виде (конверт или защищённое хранилище)
Основание применения	Невозможность штатного доступа при инциденте; применение допускается только для восстановления работоспособности
Порядок получения	Обращение к отделу ИБ (в нерабочее время — по согласованной схеме связи) с уведомлением руководителя ОТИ
Фиксация	Факт применения фиксируется в заявке или журнале с указанием причины, времени, исполнителя и выполненных действий
Действия после применения	Смена пароля в течение 24 часов, передача нового пароля в отдел ИБ, разбор причины невозможности штатного доступа
Контроль	Ежеквартальная проверка отделом ИБ факта хранения, целостности упаковки и актуальности пароля
Запрет	Повседневное администрирование, использование для удобства, передача пароля подрядчику

Таблица 35. Порядок обращения с аварийной административной учётной записью

11.5. Предоставление, изменение и отзыв доступа

Событие	Инициатор	Действия	Срок
Приём сотрудника	Руководитель подразделения (заявка)	Создание учётной записи, включение в группы по типовому профилю должности, выдача оборудования, подключение к сервисам	К дате начала работы, при заявке не позднее чем за 2 рабочих дня
Изменение должности или подразделения	Руководитель подразделения	Пересмотр прав: снятие ненужных, добавление необходимых; проверка доступа к файловым ресурсам	2 рабочих дня
Расширение прав	Руководитель сотрудника, согласование владельца ресурса	Предоставление минимально необходимого объёма, фиксация в матрице доступа	2 рабочих дня
Временный доступ	Руководитель сотрудника	Предоставление с указанием даты автоматического отзыва	В срок, указанный в заявке
Увольнение	Отдел ИБ — инициирует блокировку учётных записей; 1-я линия — принимает и проверяет оборудование	Блокировка учётных записей, отзыв доступа, приём оборудования, обработка данных по требованиям ИБ	В день увольнения (для рискованных случаев — незамедлительно)
Длительное отсутствие	Руководитель подразделения или служба персонала	Приостановка доступа по решению отдела ИБ	По решению ИБ

Таблица 36. Порядок работы с доступами при кадровых событиях

11.6. Регулярный пересмотр прав

Объект пересмотра	Периодичность	Кто проводит	Результат
Административные учётные записи	Ежеквартально	Руководитель ОТИ совместно с отделом ИБ	Актуализированный реестр, отзыв излишних прав
Доступ к сервисам класса А	Ежеквартально	Ответственный инженер, владелец сервиса	Подтверждение или отзыв прав
Права на файловые ресурсы	Раз в полгода	1-я линия по запросу руководителей подразделений	Актуализированная структура прав
Учётные записи подрядчиков	Ежемесячно	Руководитель ОТИ и отдел ИБ	Отзыв неиспользуемых учётных записей
Сервисные и технические учётные записи	Раз в полгода	2-я линия	Актуальный реестр, смена устаревших паролей
Неактивные учётные записи (нет входа более 45 дней)	Ежемесячно	2-я линия, решение — отдел ИБ	Блокировка или подтверждение необходимости

Таблица 37. Регламент ревизии прав доступа

11.7. Отчётность за действия в инфраструктуре

Принцип отчётности за действия

Каждое действие в инфраструктуре должно оставлять след, позволяющий однозначно установить: что было сделано, кем, когда, на каком основании и с каким результатом. Это не инструмент контроля личности, а условие управляемости инфраструктуры и защиты самого инженера при разборе инцидентов.

Вид действия	Где остаётся след	Ответственный за фиксацию
Обработка обращения	Заявка в системе учёта: действия, результат, время	Исполнитель заявки
Изменение конфигурации	RFC и журнал изменений (приложение D)	Исполнитель
Аварийное вмешательство	Заявка с признаком аварийного изменения, RFC по факту	Исполнитель

Вид действия	Где остаётся след	Ответственный за фиксацию
Предоставление и отзыв доступа	Заявка, матрица доступа (приложение F)	Исполнитель
Применение аварийной учётной записи	Журнал применения, уведомление ИБ	Исполнитель и отдел ИБ
Работы подрядчика	Журнал доступа подрядчика (приложение K), акт приёмки (приложение L)	Куратор от ОТИ
Восстановление из резервной копии	Заявка и акт восстановления (приложение H)	Исполнитель
Технические действия в системах	Системные журналы; состав и срок хранения определяет отдел ИБ	2-я линия (обеспечение работоспособности журналирования)

Таблица 38. Обязательные следы действий в инфраструктуре

Отключение или изменение параметров журналирования допускается только по согласованию с отделом информационной безопасности и оформляется как изменение с обязательным согласованием.

12. Информационная безопасность в зоне ответственности ОТИ

Требования устанавливает и контролирует отдел ИБ, техническую реализацию и эксплуатацию обеспечивает ОТИ.

12.1. Модель разделения ответственности

В Компании действует отдел информационной безопасности. Настоящая Политика закрепляет **глубокий уровень** проработки вопросов безопасности в части обязанностей ОТИ: это означает, что ОТИ не ограничивается общими формулировками, а исполняет конкретные технические требования и предоставляет отделу ИБ возможность контроля.

- отдел ИБ определяет требования, политики, допустимые решения и сроки устранения недостатков; принимает решения о доступах к защищаемым ресурсам; классифицирует и расследует инциденты ИБ;
- ОТИ проектирует, внедряет и эксплуатирует технические меры; обеспечивает работоспособность средств защиты и журналирования; выполняет указания отдела ИБ при инцидентах; предоставляет данные для контроля;
- при технической невозможности выполнить требование ИБ руководитель ОТИ письменно информирует отдел ИБ с описанием ограничений и предложением компенсирующих мер; решение принимает отдел ИБ;
- при расхождении между требованием ИБ и работоспособностью критичного сервиса решение принимается совместно руководителями ОТИ и ИБ; при отсутствии согласия — ИТ-директором и руководителем отдела ИБ.

12.2. Обязательные технические меры в зоне ОТИ

Мера	Содержание обязанности ОТИ	Контроль
Сегментация сети	Реализация и поддержание сегментов: продуктивный, пользовательский, гостевой, управление оборудованием, сегменты подрядчиков; ограничение взаимодействия согласованными правилами	Схема сегментации согласована с ИБ, ревизия правил раз в полгода
Управление обновлениями	Плановая установка обновлений, приоритетная установка обновлений безопасности в сроки, определённые ИБ, отчёт о покрытии	Ежемесячный отчёт об установленных обновлениях и отклонениях
Антивирусная защита и EDR	Установка агентов на все серверы и рабочие места, контроль покрытия и актуальности, устранение отклонений	Ежемесячный отчёт о покрытии; расследование срабатываний ведёт ИБ
Усиление конфигураций (hardening)	Отключение неиспользуемых служб, смена заводских паролей, ограничение локальных административных прав, настройка политик по стандарту	Проверка при вводе в эксплуатацию и при аудите
Аутентификация и пароли	Настройка парольных политик, многофакторной аутентификации для удалённого и административного доступа	Соответствие требованиям парольной политики отдела ИБ
Управление секретами	Эксплуатация защищённого хранилища паролей и технических учётных данных, исключение хранения секретов в файлах и переписке	Выборочная проверка совместно с ИБ
Журналирование	Настройка источников событий, обеспечение доставки и сохранности журналов, контроль работоспособности сбора	Состав событий и срок хранения определяет ИБ
Защита резервных копий	Изоляция копий от продуктивного контура, ограничение доступа, реализация требований к неизменяемости копий	Проверка при тестовом восстановлении, контроль ИБ
Контроль съёмных носителей	Техническая реализация ограничений, установленных отделом ИБ	Контроль ИБ
Контроль устанавливаемого ПО	Ограничение прав пользователей, применение перечня разрешённого ПО, выявление неразрешённого ПО	Ежеквартальный отчёт об установленном ПО
Устранение уязвимостей	Устранение выявленных отделом ИБ уязвимостей в установленные сроки либо применение компенсирующих мер по согласованию	План устранения с отметками о выполнении

Таблица 39. Обязательные технические меры информационной безопасности, реализуемые ОТИ

12.3. Правила для пользователей в части, обеспечиваемой ОТИ

- пользователь не имеет прав локального администратора на рабочем месте, за исключением случаев, согласованных отделом ИБ и оформленных как исключение;
- самостоятельная установка программного обеспечения пользователями запрещена; установка выполняется силами 1-й линии из перечня разрешённого ПО;
- использование личных устройств для работы с корпоративными данными допускается только по правилам отдела ИБ;
- пользователь обязан незамедлительно сообщать в ИТ о подозрительных письмах, сообщениях и поведении систем через единую точку входа; обращение с признаками инцидента ИБ передаётся в отдел ИБ незамедлительно;
- передача учётных данных другим лицам запрещена; при необходимости доступа оформляется заявка.

12.4. Участие ОТИ в обработке инцидентов ИБ

Этап	Действия ОТИ	Ограничения
Выявление	Немедленная передача в отдел ИБ признаков инцидента, предоставление технической информации	Не проводить самостоятельное расследование
Локализация	Выполнение технических действий по указанию ИБ: изоляция узла, отключение доступа, блокировка правил	Не уничтожать следы: не переустанавливать систему, не очищать журналы, не удалять файлы без разрешения ИБ
Сохранение данных	Создание копий образов и журналов по запросу ИБ	Хранение копий в порядке, указанном ИБ
Восстановление	Восстановление сервисов из проверенных резервных копий после разрешения ИБ	Восстановление до разрешения ИБ не допускается
Разбор	Участие в разборе, реализация технических корректирующих мер	Итоговые выводы по инциденту ИБ формулирует отдел ИБ

Таблица 40. Роль ОТИ при инцидентах информационной безопасности

12.5. Требования регуляторов и стандартов

Применимость требований регуляторов и отраслевых стандартов к деятельности Компании определяет отдел информационной безопасности совместно с юридической службой. ОТИ обязан учитывать в своей работе требования, признанные применимыми, и реализовывать их техническую часть.

Требование / стандарт	Возможная область влияния на инфраструктуру	Что обеспечивает ОТИ при признании применимости
Законодательство о персональных данных	Размещение и защита систем, обрабатывающих персональные данные, ограничение доступа, журналирование, резервное копирование	Учёт таких систем в каталоге, реализация технических мер, подтверждение размещения данных
Требования ФСТЭК России	Состав и настройка средств защиты, сегментация, контроль целостности, аттестационные требования к системам	Настройка по согласованным профилям защиты, поддержание документации по конфигурациям
Требования ФСБ России (криптография)	Применение сертифицированных средств криптографической защиты для каналов и данных	Эксплуатация указанных отделом ИБ средств, недопущение замены решений без согласования
ISO/IEC 27001	Процессы управления изменениями, доступом, инцидентами, непрерывностью, документированность	Поддержание процессов и записей в состоянии, пригодном для аудита
PCI DSS (при обработке платёжных данных)	Изолированный сегмент, ограничение доступа, журналирование, контроль изменений	Выделение и поддержание сегмента, предоставление записей для аудита
Отраслевые и договорные требования заказчиков	Дополнительные требования к защите, доступности и хранению данных	Реализация согласованных с ИБ технических мер

Таблица 41. Требования регуляторов и стандартов: область влияния и обязанности ОТИ (перечень применимых требований подтверждается отделом ИБ)

Правило

Практическое правило: если требование признано применимым, оно приравнивается к обязательному техническому стандарту Компании. Отклонение от него возможно только через процедуру исключений (раздел 22) с обязательным согласованием отдела ИБ.

13. Оборудование и программное обеспечение: жизненный цикл и учёт

Порядок обеспечения сотрудников техникой, учёт, инвентаризация и списание.

13.1. Жизненный цикл оборудования

Жизненный цикл оборудования и ПО



Рис. 19. Жизненный цикл оборудования: заявка, согласование, выдача, эксплуатация, ремонт, возврат, списание. Каждый переход фиксируется в системе учёта.

Этап	Кто выполняет	Что фиксируется	Документ
Заявка	Руководитель подразделения через единую точку входа	Потребность, обоснование, срок, для кого	Заявка в системе учёта
Согласование	Руководитель подразделения, ОТИ (технические требования), ИТ-директор (при отсутствии в бюджете)	Соответствие стандарту, наличие на складе, бюджет	Отметки в заявке
Выдача	1-я линия получает технику у сервис-менеджера и передаёт сотруднику	Инвентарный номер, серийный номер, комплектность, получатель, дата	Акт передачи (приложение N)
Эксплуатация	Пользователь — использование по назначению; ОТИ — обновления, обслуживание, поддержка	Изменения состава, перемещения между сотрудниками и площадками	Записи в системе учёта
Ремонт	1-я линия — диагностика и передача в ремонт; сервис-менеджер — подменный фонд	Дата, причина, исполнитель ремонта, срок, выданная подмена	Заявка, отметка в учёте
Возврат	1-я линия принимает технику и проверяет комплектность и работоспособность	Состояние, комплектность, дата, основание (увольнение, замена)	Акт возврата (приложение N)
Списание	Сервис-менеджер, комиссия; ОТИ — техническое заключение	Основание, состояние, обработка носителей информации, утилизация	Акт списания, отметка ИБ об уничтожении данных

Таблица 42. Этапы жизненного цикла оборудования и распределение ролей

Кто за что отвечает

Разделение ролей: **сервис-менеджер** отвечает за склад, наличие, движение и учётные данные оборудования; **1-я линия** получает технику у сервис-менеджера, выдаёт её сотруднику, устанавливает и настраивает программное обеспечение, принимает оборудование при возврате и проверяет его комплектность; **руководитель ОТИ** определяет технические требования и стандарты.

13.2. Программное обеспечение на рабочих местах

- установку и обновление программного обеспечения выполняет 1-я линия; самостоятельная установка пользователями запрещена;
- устанавливается только программное обеспечение из перечня разрешённого, имеющее лицензию и согласованное отделом ИБ;
- запрос на новое программное обеспечение оформляется заявкой с обоснованием; ОТИ проверяет совместимость и лицензионные условия, отдел ИБ — допустимость;
- бесплатное и свободное программное обеспечение также подлежит согласованию: проверяются лицензионные условия использования в коммерческой организации;
- выявленное неразрешённое программное обеспечение удаляется; факт фиксируется и передаётся руководителю подразделения и в отдел ИБ.

13.3. Учёт оборудования и лицензий

Учёт ведётся в единой системе учёта. Ответственный за полноту и актуальность учётных данных — сервис-менеджер; ответственный за достоверность технических характеристик и состава программного обеспечения — ОТИ.

Класс объектов учёта	Обязательные атрибуты учёта	Учитывается
Рабочие станции и ноутбуки	Инвентарный и серийный номер, модель, конфигурация, дата ввода, ответственный сотрудник, площадка, состояние, гарантия	Да
Мониторы и периферия	Инвентарный и серийный номер, модель, закреплённое место или сотрудник	Да

Класс объектов учёта	Обязательные атрибуты учёта	Учитывается
Серверы	Инвентарный и серийный номер, модель, размещение (стойка, юнит), конфигурация, назначение, гарантия и поддержка	Да
Сетевое оборудование	Модель, серийный номер, площадка, размещение, версия прошивки, назначение, порты	Да
Системы хранения	Модель, серийный номер, конфигурация, дисковые группы, гарантия	Да
Телефоны и мобильные устройства	Модель, серийный номер, номер SIM, ответственный сотрудник	Да
Оборудование видеонаблюдения	Модель, серийный номер, размещение, подключение	Да
ИБП и инфраструктура серверных	Модель, серийный номер, дата установки батарей, площадка	Да
Расходные материалы и запасные части	Наименование, количество, место хранения	Да (складской учёт)
Лицензии на программное обеспечение	Наименование, тип лицензии, количество, срок действия, привязка (пользователь/устройство), документы	Да
Договоры технической поддержки	Поставщик, объект поддержки, срок, условия реагирования, контакты	Да
Виртуальные машины	Имя, назначение, ресурсы, размещение, ответственный, класс критичности сервиса	Да (реестр ОТИ)

Таблица 43. Объекты учёта и обязательные атрибуты

13.4. Инвентаризация

Вид	Периодичность	Объём	Кто проводит	Результат
Выборочная	Ежеквартально	Не менее 10 % парка, приоритетно — оборудование классов А и В и площадки с высокой ротацией	1-я линия совместно с сервис-менеджером	Отчёт о расхождениях
Полная	Ежегодно	Всё оборудование и лицензии	Комиссия с участием сервис-менеджера, ОТИ и бухгалтерии	Акт инвентаризации (приложение М)
Внеплановая	По решению руководителя ОТИ или ИТ-директора	Определяется приказом (например, после кражи, при смене ответственного или при выявленных расхождениях)	Назначенная комиссия	Акт и план устранения расхождений

Таблица 44. Виды и порядок инвентаризации

Расхождения, выявленные при инвентаризации, подлежат обязательному разбору: устанавливается причина, определяются ответственные и корректирующие меры. Результаты включаются в ежеквартальную отчётность.

13.5. Нормативные сроки эксплуатации и обновление парка

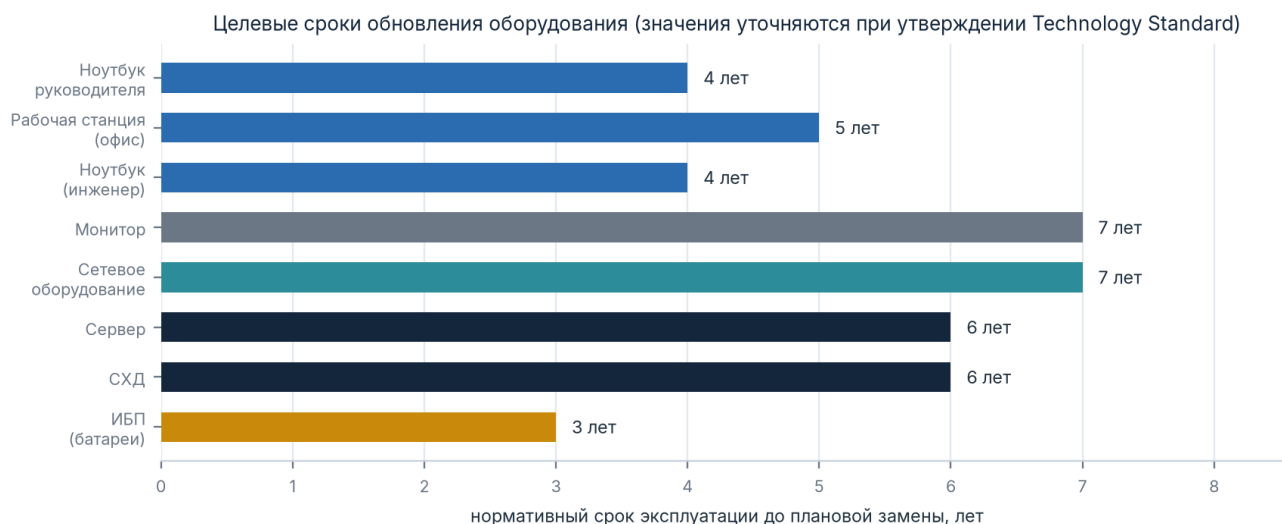


Рис. 20. Целевые сроки эксплуатации оборудования до плановой замены. Значения уточняются при утверждении Technology Standard и используются для планирования бюджета.

- оборудование, эксплуатируемое за пределами нормативного срока, включается в план замены при формировании бюджета;
- оборудование, снятое с поддержки производителем, для систем классов А и В подлежит приоритетной замене; при невозможности замены оформляется исключение с описанием компенсирующих мер;
- высвобождаемое работоспособное оборудование переводится в подменный фонд или используется для задач более низкого класса критичности;
- подменный фонд поддерживается на уровне не менее 3 % парка рабочих мест (значение уточняется по статистике отказов).

13.6. Приём и увольнение сотрудников

Событие	Инициатор	ОТИ (1-я линия)	Отдел ИБ	Сервис-менеджер
Приём	Заявка от руководителя подразделения не позднее чем за 2 рабочих дня	Подготовка рабочего места, установка ПО, выдача оборудования, инструктаж по обращению в ИТ	Согласование профиля доступа	Выдача оборудования со склада
Перевод	Заявка от руководителя	Перенос рабочего места, пересмотр установленного ПО	Пересмотр прав доступа	Перемещение оборудования в учёт
Увольнение	Служба персонала информирует ИТ-блок и отдел ИБ	Приём и проверка оборудования, подготовка данных к передаче по указанию руководителя	Инициирование блокировки учётных записей, требования к обработке данных	Приём оборудования на склад, отметка в учёт

Таблица 45. Распределение действий при кадровых событиях

Порядок offboarding

Порядок при увольнении: блокировку учётных записей инициирует **отдел информационной безопасности**; технически блокировку выполняет ОТИ; оборудование принимает и проверяет **1-я линия**, после чего передаёт сервис-менеджеру на склад. Данные сотрудника обрабатываются по указанию отдела ИБ и руководителя подразделения. Чек-лист — приложение О.

14. Резервное копирование и восстановление

Ответственность, принципы, целевые параметры и обязательное тестирование восстановления.

14.1. Ответственность

Резервное копирование обеспечивает 2-я линия ОТИ совместно с отделом информационной безопасности:

- 2-я линия — проектирование схемы копирования, настройка заданий, ежедневный контроль результатов, устранение сбоев, выполнение восстановления, проведение тестовых восстановлений, документирование;
- отдел ИБ — требования к защите, изоляции и хранению копий, контроль соблюдения требований, участие в тестовых восстановлении, согласование изменений схемы копирования;
- руководитель ОТИ — контроль исполнения, отчётность перед ИТ-директором, эскалация рисков;
- владелец сервиса — согласование целевых параметров RPO и RTO и подтверждение корректности восстановленных данных при тестовом восстановлении.

14.2. Принципы резервного копирования

Целевая схема резервного копирования (принцип 3-2-1)



Рис. 21. Целевая схема резервного копирования по принципу 3-2-1 с изолированной копией вне продуктивного контура.

- не менее двух копий критичных данных, минимум на двух разных носителях или хранилищах, минимум одна копия — вне продуктивного контура;
- копии критичных систем недоступны из продуктивного домена под обычными административными правами; требования к изоляции и неизменяемости определяет отдел ИБ;
- перед любым существенным изменением создаётся внеплановая резервная копия затрагиваемых систем;
- восстановление данных выполняется только по зарегистрированной заявке с подтверждением владельца данных; для восстановления после инцидента ИБ — по разрешению отдела ИБ;
- копии хранятся в течение сроков, согласованных с владельцами сервисов, отделом ИБ и требованиями законодательства.

14.3. Целевые параметры восстановления

Целевые RPO / RTO по критичным системам (проект значений для утверждения)

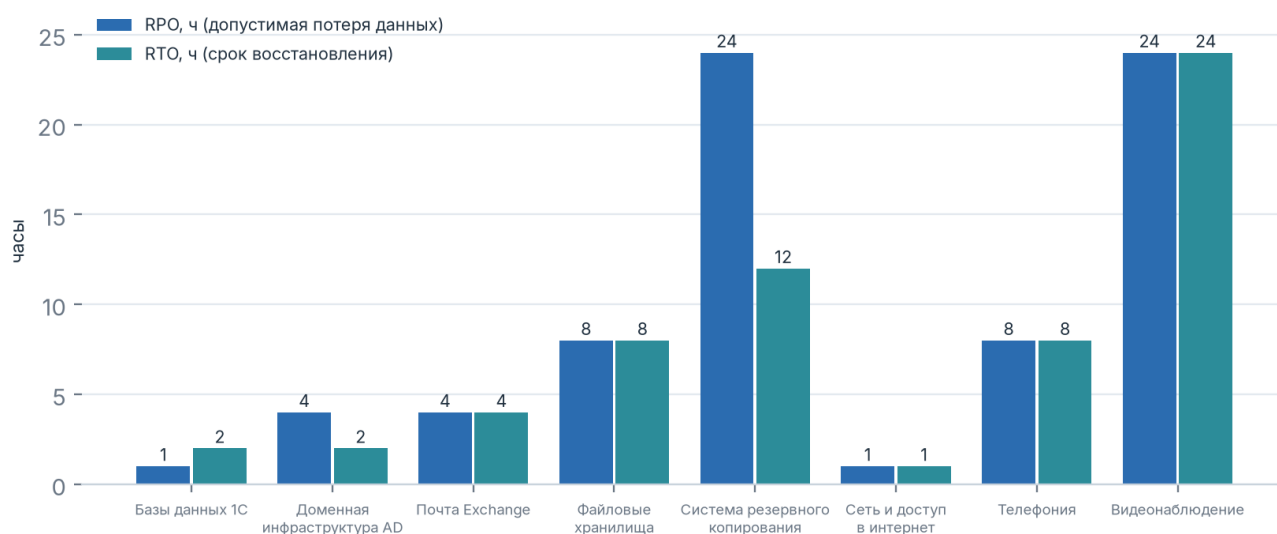


Рис. 22. Проект целевых значений RPO и RTO по критичным системам. Значения утверждаются совместно с владельцами сервисов и закрепляются в SLA.

Система / данные	Периодичность копирования	Хранение	RPO	RTO	Тестовое восстановление
Базы данных 1С	Полное — ежедневно, журналы транзакций — каждый час	30 дней; месячные копии — 12 месяцев	1 ч	2 ч	Ежеквартально
Доменная инфраструктура (AD, DNS, DHCP)	Ежедневно, системное состояние контроллеров	30 дней	4 ч	2 ч	Ежеквартально
Почтовый сервер Exchange	Ежедневно	30 дней; архив — по требованиям ИБ и законодательства	4 ч	4 ч	Ежеквартально
Файловые хранилища	Ежедневно, инкрементально; теневые копии — несколько раз в день	30 дней; архив — 12 месяцев	8 ч	8 ч	Раз в полгода
Система резервного копирования (конфигурация и каталог)	Ежедневно, с хранением вне основного хранилища	30 дней	24 ч	12 ч	Раз в полгода
Конфигурации сетевого оборудования	При каждом изменении и ежемесячно по расписанию	12 месяцев, не менее 12 версий	—	1 ч	Ежеквартально (проверка применимости)
Виртуальные машины сервисов класса А	Ежедневно	14–30 дней	24 ч	4 ч	Ежеквартально
Виртуальные машины сервисов класса В	Ежедневно или через день	14 дней	24 ч	8 ч	Раз в полгода
Системы видеонаблюдения (конфигурация)	Ежемесячно	3 месяца	—	8 ч	Ежегодно
Рабочие места пользователей	Копирование рабочих данных обеспечивается хранением на файловых ресурсах; локальные диски не резервируются	—	—	—	—

Таблица 46. Регламент резервного копирования критичных систем (проект для утверждения)

Важное ограничение

Правило информирования пользователей: рабочие файлы, хранящиеся только на локальном диске компьютера, не резервируются и при отказе оборудования могут быть утрачены. 1-я линия обязана информировать об этом пользователей при выдаче техники и при обращениях, связанных с хранением данных.

14.4. Контроль результатов копирования

- результаты заданий проверяются ежедневно в первой половине дня; неуспешные задания разбираются в день выявления;
- неустранённый в течение 24 часов сбой копирования системы класса А эскалируется руководителю ОТИ, в течение 48 часов — ИТ-директору и отделу ИБ;
- ежемесячно формируется сводный отчёт: успешность заданий, объёмы, инциденты копирования, результаты тестовых восстановлений;
- отсутствие резервной копии критичной системы за период более 48 часов рассматривается как инцидент с приоритетом P2.

14.5. Обязательное тестирование восстановления**Требование**

Резервная копия считается работоспособной только после подтверждённого восстановления. Тестовое восстановление обязательно: для систем класса А — ежеквартально, класса В — раз в полгода. Результат оформляется актом (приложение Н) с указанием фактического времени восстановления и отметкой владельца сервиса о корректности данных.

Параметр теста	Что проверяется
Полнота	Восстановление системы целиком либо восстановление на тестовый стенд с проверкой целостности данных
Время	Фактическое время восстановления сопоставляется с целевым RTO; расхождение фиксируется и разбирается
Корректность данных	Владелец сервиса или назначенный им сотрудник подтверждает корректность данных на контрольную дату
Документированность	Проверяется применимость инструкции по восстановлению: тест выполняется строго по инструкции
Независимость от исполнителя	Не реже одного раза в год тест выполняет резервный ответственный, а не основной
Изоляция	Тестовое восстановление не влияет на продуктивную среду; порядок изоляции согласован с отделом ИБ

Таблица 47. Обязательные параметры тестового восстановления

14.6. План аварийного восстановления (DRP)

План аварийного восстановления в Компании подлежит разработке. Настоящая Политика закрепляет требование его наличия, структуру и порядок разработки.

Раздел DRP	Содержание
Область и сценарии	Перечень аварийных сценариев: отказ сервера, отказ СХД, отказ площадки, потеря канала связи, шифровальщик, утрата серверного помещения
Приоритеты восстановления	Очередность восстановления сервисов по классам критичности с указанием зависимостей
Роли и оповещение	Кто объявляет аварийную ситуацию, кто руководит восстановлением, схема оповещения и связи (в том числе при недоступности корпоративной почты)
Технические процедуры	Пошаговые инструкции восстановления по каждому критичному сервису с указанием источников копий
Ресурсы	Необходимое оборудование, резервные площадки, подменный фонд, договоры поддержки и контакты подрядчиков
Проверка	Порядок и периодичность учений, критерии успешности
Восстановление штатной работы	Порядок возврата к нормальному режиму, проверка целостности данных, разбор

Таблица 48. Обязательная структура плана аварийного восстановления

Этап разработки DRP	Содержание этапа	Ответственный	Срок
1. Анализ влияния	Определение критичных сервисов, зависимостей и допустимых простоев совместно с владельцами	Руководитель ОТИ	М+6 от даты утверждения Политики
2. Сценарии и решения	Разработка сценариев отказа и технических решений, оценка требуемых ресурсов	2-я линия под руководством руководителя ОТИ	М+7
3. Процедуры	Разработка пошаговых инструкций восстановления по каждому критичному сервису	2-я линия	М+8
4. Согласование	Согласование с отделом ИБ, владельцами сервисов и ИТ-директором	Руководитель ОТИ	М+9
5. Учения	Проведение первых учений по одному сценарию, корректировка плана	Руководитель ОТИ	М+10

Таблица 49. План разработки DRP (сроки указаны в месяцах от даты утверждения Политики)

14.7. Отказ площадки

- для каждой площадки в паспорте (приложение R) фиксируются обходные варианты работы при отказе канала связи и при недоступности локальных сервисов;
- для основной площадки с серверной разрабатывается сценарий полного отказа: порядок восстановления критичных сервисов, необходимые ресурсы, ожидаемое время;
- до утверждения DRP при отказе площадки действует упрощённый порядок: руководитель ОТИ объявляет крупный инцидент, назначает координатора, информирует ИТ-директора и владельцев процессов, восстановление ведётся по приоритету классов критичности;
- результаты фактических отказов обязательно разбираются и используются для доработки DRP.

15. Мониторинг, доступность и управление инцидентами

Полное покрытие мониторингом, целевые параметры доступности, порядок работы с инцидентами и система дежурств.

15.1. Принцип полного покрытия

Требование раздела 15

Мониторингом должно быть покрыто **всё**, что эксплуатируется: оборудование, каналы связи, платформы, службы, сервисы и ключевые бизнес-операции. Сервис, не покрытый мониторингом, не считается введённым в эксплуатацию. Отсутствие мониторинга по действующему сервису классов А и В рассматривается как риск и подлежит устранению в приоритетном порядке.

Уровни мониторинга: от оборудования к бизнес-процессу

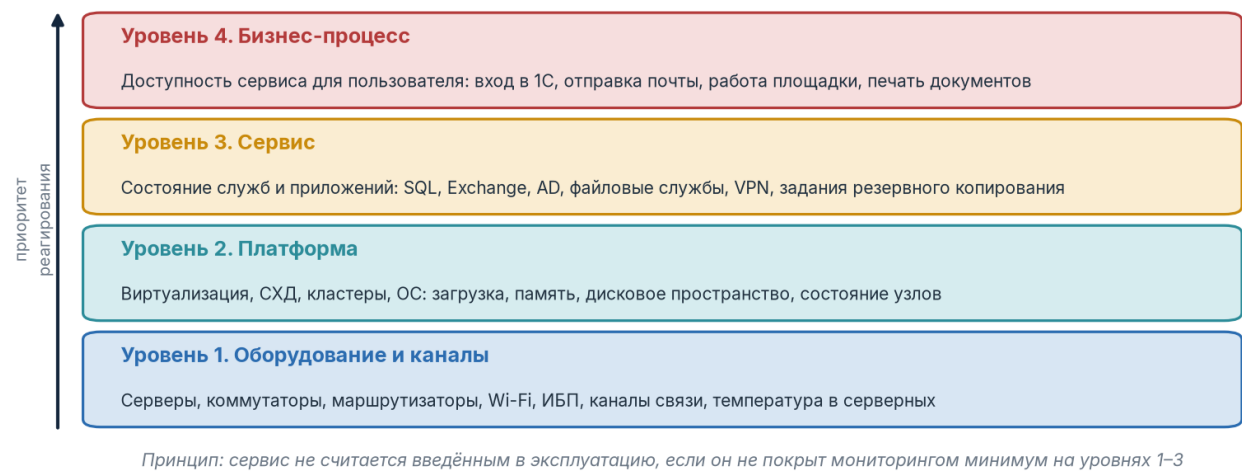


Рис. 23. Четыре уровня мониторинга: от оборудования и каналов до доступности бизнес-операции для пользователя.

15.2. Обязательный минимум наблюдения

Объект	Обязательные параметры наблюдения	Оповещение
Серверы	Доступность, загрузка процессора и памяти, дисковое пространство, состояние дисковых массивов, температура, состояние блоков питания	Немедленно при отказе; предупреждение при достижении порога
Виртуализация	Состояние хостов и кластеров, доступность хранилищ, утилизация ресурсов, состояние виртуальных машин сервисов А и В	Немедленно
Системы хранения	Состояние контроллеров и дисков, свободное пространство, производительность, состояние репликации	Немедленно
Сетевое оборудование	Доступность, состояние портов и агрегированных каналов, утилизация, ошибки, температура	Немедленно
Каналы связи	Доступность, потери пакетов, задержка, утилизация, переключение на резервный канал	Немедленно
Службы каталога	Доступность контроллеров, репликация, время, работа DNS и DHCP, свободные адреса в диапазонах	Немедленно
Почтовая система	Доступность служб, очереди сообщений, состояние баз, свободное пространство	Немедленно
Базы данных	Доступность экземпляров, состояние баз, длительные блокировки, свободное пространство, выполнение регламентных заданий	Немедленно
Файловые ресурсы	Доступность, свободное пространство, состояние квот, теневые копии	Немедленно при отказе
Резервное копирование	Результат выполнения заданий, объёмы, свободное место в хранилище копий	Ежедневный отчёт + оповещение при неуспехе
Инфраструктура серверных	Электропитание, состояние ИБП и батарей, температура и влажность, протечки	Немедленно
Бизнес-операции (синтетические проверки)	Вход в 1С, отправка и получение тестового письма, открытие файлового ресурса, печать контрольного документа, доступ к интернету по площадкам	Немедленно
Средства защиты	Работоспособность агентов, актуальность баз, доставка журналов (по требованиям отдела ИБ)	Немедленно, с уведомлением отдела ИБ

Таблица 50. Обязательный минимум объектов и параметров мониторинга

- оповещения направляются ответственным инженерам и на общий канал дежурства; состав получателей документируется;
- пороги настраиваются так, чтобы исключить шум: каждое оповещение должно требовать действия, иначе порог или правило подлежат пересмотру;
- ежемесячно анализируются наиболее частые оповещения и принимаются меры по устранению их причин, а не по «привыканию» к ним.

15.3. Целевая доступность сервисов

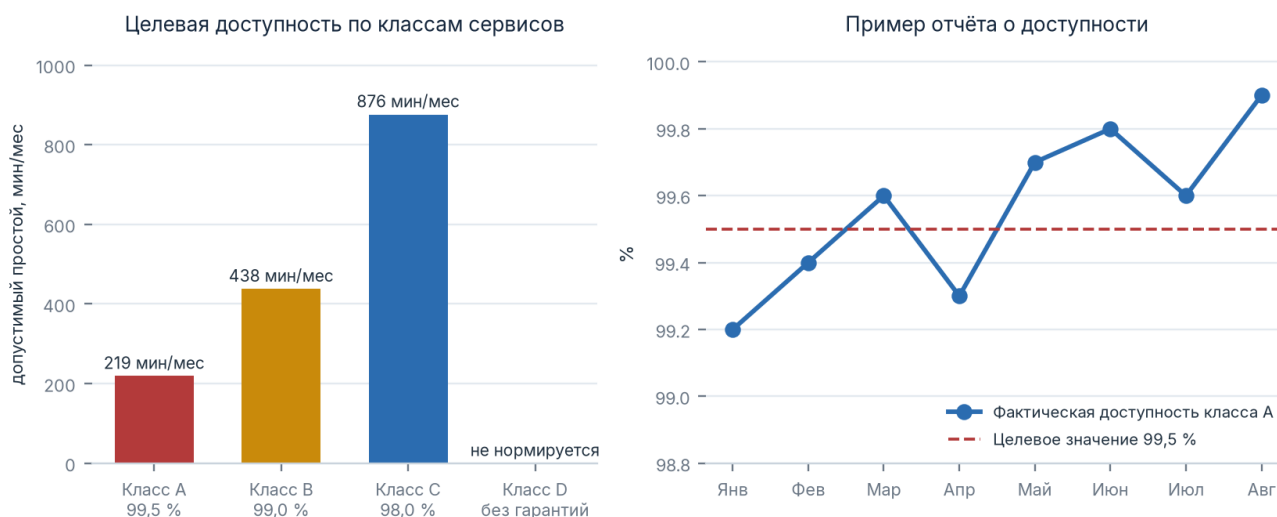


Рис. 24. Целевые значения доступности по классам сервисов, соответствующий допустимый простой и пример ежемесячного отчёта о фактической доступности.

- доступность рассчитывается за календарный месяц по данным системы мониторинга;
- плановые работы в согласованных окнах не учитываются как простой при условии заблаговременного уведомления пользователей;
- простой, вызванный отказом внешнего поставщика услуг, учитывается отдельно, с указанием ответственности поставщика и результатов претензионной работы;
- целевые значения в настоящей редакции являются проектом и приобретают статус обязательств после утверждения SLA (раздел 20).

15.4. Управление инцидентами

Управление инцидентами, включая крупные (major)



Рис. 25. Процесс управления инцидентами, порядок работы с крупными инцидентами и обязательный разбор.

Уровень	Критерий	Кто координирует	Уведомление	Разбор
Sev-1	Остановлен критичный сервис или бизнес-процесс; затронуто несколько площадок; есть риск потери данных	Руководитель ОТИ или дежурный руководитель	ИТ-директор, отдел ИБ, владельцы затронутых процессов — немедленно; статус каждые 30 минут	Обязателен, 5 рабочих дней
Sev-2	Существенная деградация критичного сервиса или отказ важного сервиса класса В	Ответственный инженер 2-й линии	Руководитель ОТИ, руководители затронутых подразделений	Обязателен, 5 рабочих дней
Sev-3	Локальные инциденты, единичные пользователи, отсутствие влияния на процессы	Исполнитель заявки	Инициатор	По решению руководителя ОТИ (при повторяемости — обязателен)

Таблица 51. Классификация инцидентов и порядок реагирования

Крупные инциденты

- право объявить крупный инцидент имеют: руководитель ОТИ, руководитель службы поддержки, дежурный сотрудник, отдел ИБ, ИТ-директор;
- при объявлении назначается координатор, который не занимается технической работой, а управляет восстановлением и коммуникациями;
- открывается единый канал коммуникаций (конференция или чат); статус доводится заинтересованным сторонам не реже одного раза в 30 минут;
- приоритет действий — восстановление сервиса; сбор технической информации для последующего разбора ведётся параллельно и не должен задерживать восстановление, за исключением инцидентов ИБ, где порядок определяет отдел ИБ;
- после восстановления координатор фиксирует хронологию и обеспечивает подготовку разбора.

Разбор инцидентов (постмортем)

Разбор обязателен для инцидентов Sev-1 и Sev-2 и проводится в течение 5 рабочих дней. Принцип разбора — поиск причины, а не виновного.

Раздел разбора	Содержание
Хронология	Последовательность событий с указанием времени: возникновение, обнаружение, локализация, восстановление, закрытие
Влияние	Затронутые сервисы, пользователи, площадки, процессы; длительность простоя; потери данных
Причина	Непосредственная техническая причина и системные причины (отсутствие мониторинга, устаревшая документация, пробел в процедуре, нехватка ресурса)
Что сработало	Действия, средства и процедуры, которые помогли; их закрепление как практики
Что не сработало	Пробелы в мониторинге, документации, доступах, резервировании, коммуникации
Корректирующие меры	Конкретные меры с ответственными и сроками; меры оформляются заявками и контролируются
Оценка повторяемости	Возможность повторения, необходимость изменения архитектуры или процессов

Таблица 52. Обязательная структура разбора инцидента (форма — приложение I)

Правило безопасной среды разбора

Результаты разбора не используются как основание для дисциплинарного взыскания, если сотрудник действовал в рамках согласованных процедур и зафиксировал свои действия. Ответственность наступает при сокрытии информации, искажении хронологии или умышленном нарушении Политики.

15.5. Дежурства и работа в нерабочее время

Дежурства организуются на праздничные периоды и продолжительные выходные, а также по решению руководителя ОТИ — на периоды повышенного риска (массовые мероприятия, крупные внедрения, периоды закрытия отчётности).

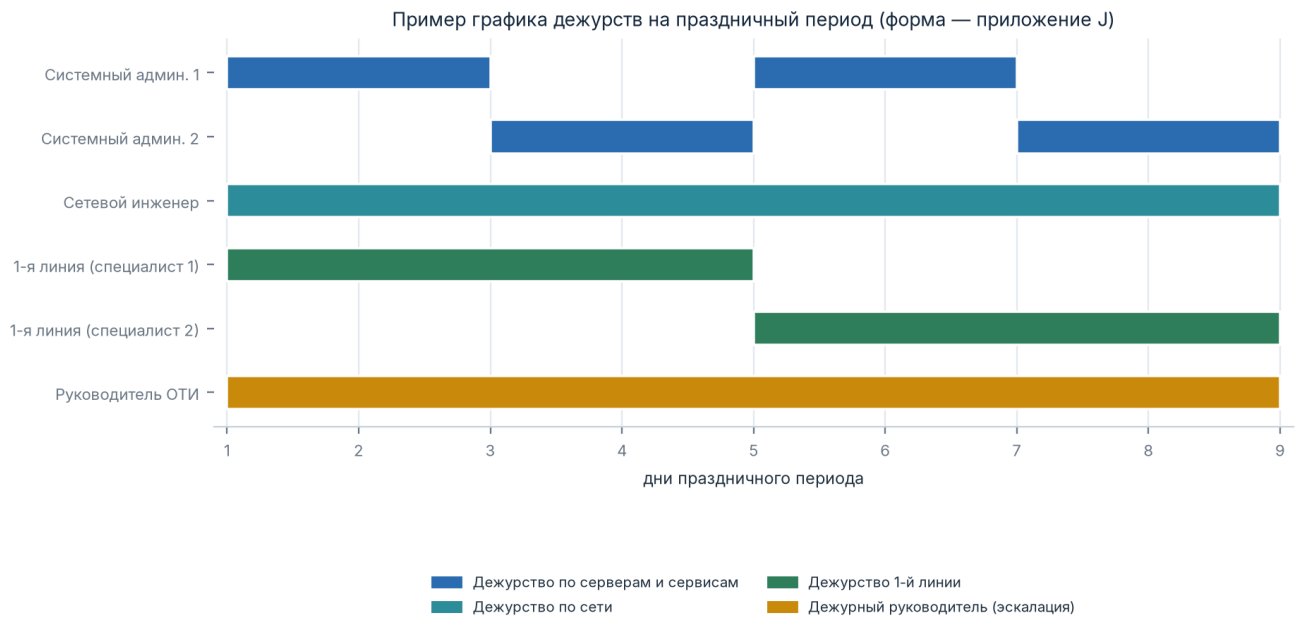


Рис. 26. Пример графика дежурств на праздничный период с распределением по областям и дежурным руководителем для эскалации.

Параметр	Требование
Формат дежурства	Дежурство на связи (on-call) с возможностью удалённого подключения; выезд на площадку — при невозможности устранения удалённо
Состав смены	Дежурный по серверам и сервисам, дежурный по сети, дежурный 1-й линии, дежурный руководитель (эскалация)
Время реакции	Подтверждение получения оповещения — 30 минут; начало работ — 1 час (значения уточняются при утверждении SLA)
График	Формируется руководителем ОТИ не позднее чем за 10 рабочих дней до начала периода, согласуется с ИТ-директором, доводится до сотрудников под подпись (приложение J)
Обязанности дежурного	Контроль оповещений мониторинга, реагирование на инциденты, ведение журнала дежурства, передача смены, эскалация по схеме
Права дежурного	Выполнение аварийных изменений с последующим оформлением; привлечение других сотрудников при необходимости; объявление крупного инцидента
Передача смены	Журнал дежурства с описанием событий, незакрытых вопросов и выполненных действий
Компенсация	Порядок компенсации дежурств (доплата или отгул) устанавливается отдельным решением Компании; настоящая Политика фиксирует обязательность такого порядка
Запрет	Дежурство без доступа к необходимым системам, без актуальных инструкций и без согласованной схемы эскалации

Таблица 53. Требования к организации дежурств

Подготовка к дежурству

Дежурство обеспечивается ресурсами: перед началом периода дежурный обязан проверить наличие доступов, работоспособность удалённого подключения, актуальность контактов эскалации и инструкций. Выявленные пробелы устраняются до начала дежурства. Это ответственность руководителя ОТИ.

16. Работа с подрядчиками

Когда привлекаем, как предоставляется доступ, кто сопровождает работы и кто принимает результат.

16.1. Основания для привлечения подрядчика

Подрядчики привлекаются для выполнения сложных работ, которые не могут быть проведены силами отдела:

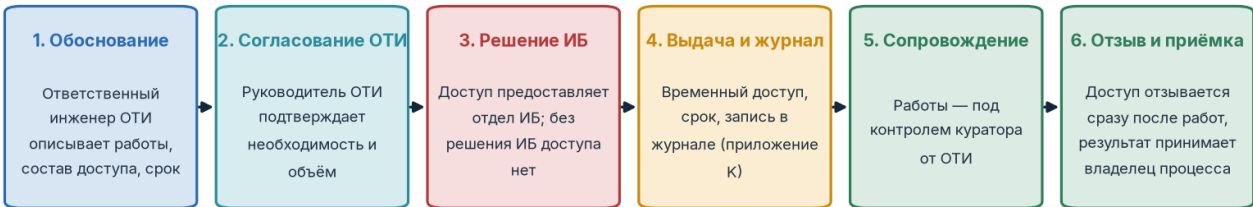
- работы требуют компетенций, отсутствующих в отделе (специализированные платформы, сложные миграции, проектирование нестандартных решений);
- работы требуют ресурсов и сроков, несовместимых с текущей загрузкой отдела (масштабные проекты, одновременные работы на нескольких площадках);
- работы требуют сертифицированного исполнителя либо являются условием сохранения гарантии и поддержки производителя;
- работы относятся к монтажным и инфраструктурным (СКС, электропитание, монтаж оборудования, пусконаладка);
- требуется независимая экспертиза, аудит или второе мнение по техническому решению.

Ключевое ограничение

Привлечение подрядчика не передаёт ему ответственность за результат перед Компанией: ответственность за техническую корректность решения и его соответствие стандартам Компании остаётся за ОТИ. Поэтому у каждой работы подрядчика есть куратор от ОТИ.

16.2. Доступ подрядчика

Порядок предоставления доступа подрядчику



Обязательные условия: доступ только временный и персонифицированный; общие учётные записи подрядчику не выдаются; все действия журналируются; удалённые работы проводятся через контролируемый канал с записью сессии, если это технически возможно; после завершения работ подрядчик передаёт документацию и описание внесённых изменений — без этого работы не считаются принятыми.

Рис. 27. Порядок предоставления доступа подрядчику: обоснование, согласование ОТИ, решение отдела ИБ, журналирование, сопровождение и отзыв.

Требование	Содержание
Решение о доступе	Административный доступ предоставляет отдел информационной безопасности . Без решения отдела ИБ доступ подрядчику не предоставляется
Согласование ОТИ	Состав, объём и срок доступа обязательно согласуются с руководителем ОТИ; обоснование готовит ответственный инженер
Временность	Доступ выдаётся только на период работ с указанием даты и времени автоматического отзыва
Персонификация	Учётные записи персонифицированы по сотрудникам подрядчика; выдача общих учётных записей запрещена
Минимальность	Права — только к системам, затрагиваемым работами; доступ «ко всей инфраструктуре» не предоставляется

Требование	Содержание
Журналирование	Факт выдачи, состав прав, период и все действия фиксируются в журнале доступа подрядчика (приложение К)
Контролируемый канал	Удалённые работы проводятся через согласованный отделом ИБ канал; при технической возможности ведётся запись сессии
Сопровождение	Работы выполняются в присутствии (в том числе удалённом) куратора от ОТИ; куратор вправе остановить работы при отклонении от согласованного плана
Отзыв доступа	Доступ отзывается сразу после завершения работ; факт отзыва фиксируется в журнале; при длительных договорах — ежемесячная ревизия учётных записей
Конфиденциальность	Работы выполняются при наличии оформленных обязательств о конфиденциальности; контроль — отдел ИБ и юридическая служба

Таблица 54. Обязательные требования к доступу подрядчиков

16.3. Порядок проведения работ

Этап	Что требуется	Ответственный
Техническое задание	Описание работ, требования к результату, ограничения, требования к документации и передаче знаний	ОТИ (руководитель, ответственный инженер)
План работ	Согласованный план с окном работ, планом тестирования и планом отката; при влиянии на сервисы — оформляется RFC	Подрядчик совместно с куратором ОТИ
Проведение работ	Работы строго в согласованном объёме и окне; любое расширение объёма — только после согласования	Подрядчик под контролем куратора
Контроль	Куратор фиксирует ход работ, отклонения и инциденты; при риске для сервисов — приостанавливает работы	Куратор ОТИ
Документация	Подрядчик передаёт схемы, конфигурации, описание внесённых изменений, инструкции по эксплуатации	Подрядчик
Передача знаний	Инструктаж сотрудников ОТИ по эксплуатации внедрённого решения	Подрядчик, приёмка — куратор ОТИ
Приёмка	Проверка соответствия результата техническому заданию; приёмку результата выполняет владелец процесса , техническую приёмку — ОТИ	Владелец процесса и ОТИ

Таблица 55. Порядок выполнения и приёмки работ подрядчика

Условие приёмки

Работы не считаются принятыми, если не передана документация и описание внесённых изменений. Отсутствие документации — основание для отказа в приёмке и для задержки оплаты по согласованию с подразделением закупок.

16.4. Реестр подрядчиков и контроль качества

- ОТИ ведёт реестр подрядчиков: предмет договора, условия поддержки и реагирования, контакты, срок действия, ответственный куратор;
- по договорам поддержки контролируется фактическое соблюдение заявленных сроков реагирования; систематические нарушения фиксируются и учитываются при продлении;
- оценка подрядчика по итогам крупных работ оформляется куратором в свободной форме и учитывается при последующем выборе исполнителя;
- подрядчик, допустивший инцидент по своей вине, участвует в разборе; результаты разбора учитываются в претензионной работе.

17. Закупки, бюджет и технические стандарты

Технические требования определяет ИТ, закупочную процедуру — закупки, бюджет отдела формирует руководитель ОТИ.

17.1. Разграничение ролей

Процесс от потребности до ввода в эксплуатацию



Рис. 28. Процесс от возникновения потребности до ввода в эксплуатацию.

Правило раздела 17

ИТ-архитектура и технические стандарты определяются ИТ-отделом. Технические требования ккупаемому ИТ-оборудованию и программному обеспечению формирует исключительно ОТИ. Самостоятельная закупка ИТ-решений подразделениями не допускается.

Участник	Роль в процессе
Инициатор (подразделение)	Формулирует потребность и бизнес-обоснование, участвует в приёме
ОТИ	Определяет технические требования, проверяет соответствие стандарту и совместимость, готовит техническое обоснование, выполняет внедрение и ввод в эксплуатацию
Отдел ИБ	Согласует решения, влияющие на защищённость, и требования к обработке защищаемой информации
Руководитель ОТИ	Формирует бюджет отдела, инициирует закупки в рамках бюджета, участвует в технической оценке предложений
ИТ-директор	Согласует бюджет и расходы, принимает решения по внеплановым и крайним случаям, утверждает отклонения от стандарта
Подразделение закупок	Проводит закупочную процедуру, заключает договоры, ведёт коммерческие переговоры и работу с поставщиками

Таблица 56. Роли в процессе обеспечения ИТ-потребностей

17.2. Последствия закупки в обход установленного порядка

- оборудование и программное обеспечение, приобретённые подразделением самостоятельно, не принимаются на поддержку ОТИ;
- такое оборудование не подключается к корпоративной сети до проверки соответствия стандарту и согласования отдела ИБ;
- решение о легализации (принятии на поддержку) или об изъятии принимает ИТ-директор по представлению руководителя ОТИ;

- факт закупки в обход порядка фиксируется и включается в отчётность; при повторении вопрос выносится на уровень руководства Компании.

17.3. Процесс закупки для проектной деятельности

Для проектной деятельности применяется полная последовательность: **потребность** → **техническое обоснование** → **бюджет** → **закупка** → **внедрение** → **ввод в эксплуатацию**.

Этап	Содержание	Результат этапа	Ответственный
Потребность	Формулировка задачи, ожидаемый результат, сроки, ограничения	Заявка или проектная инициатива	Инициатор
Техническое обоснование	Варианты решения, сравнение, требования к ресурсам, риски, влияние на действующую инфраструктуру, стоимость владения	Техническое обоснование (приложение Р)	ОТИ
Бюджет	Проверка наличия средств, приоритизация, согласование	Включение в бюджет или решение о внеплановом расходе	Руководитель ОТИ, ИТ-директор
Закупка	Закупочная процедура, договор, поставка	Поставленное оборудование или лицензии	Подразделение закупок
Внедрение	Монтаж, настройка, тестирование по плану, обучение	Работающее решение, подтверждённое тестированием	ОТИ
Ввод в эксплуатацию	Учёт, паспорт сервиса, мониторинг, резервное копирование, документация, передача в поддержку	Сервис в каталоге и на поддержке	ОТИ

Таблица 57. Этапы обеспечения проектной потребности

17.4. Бюджет отдела технической инфраструктуры

Бюджет ОТИ формирует руководитель отдела технической инфраструктуры и согласует с ИТ-директором. В рамках утверждённого бюджета и действующих стандартов руководитель ОТИ вправе принимать решения самостоятельно.

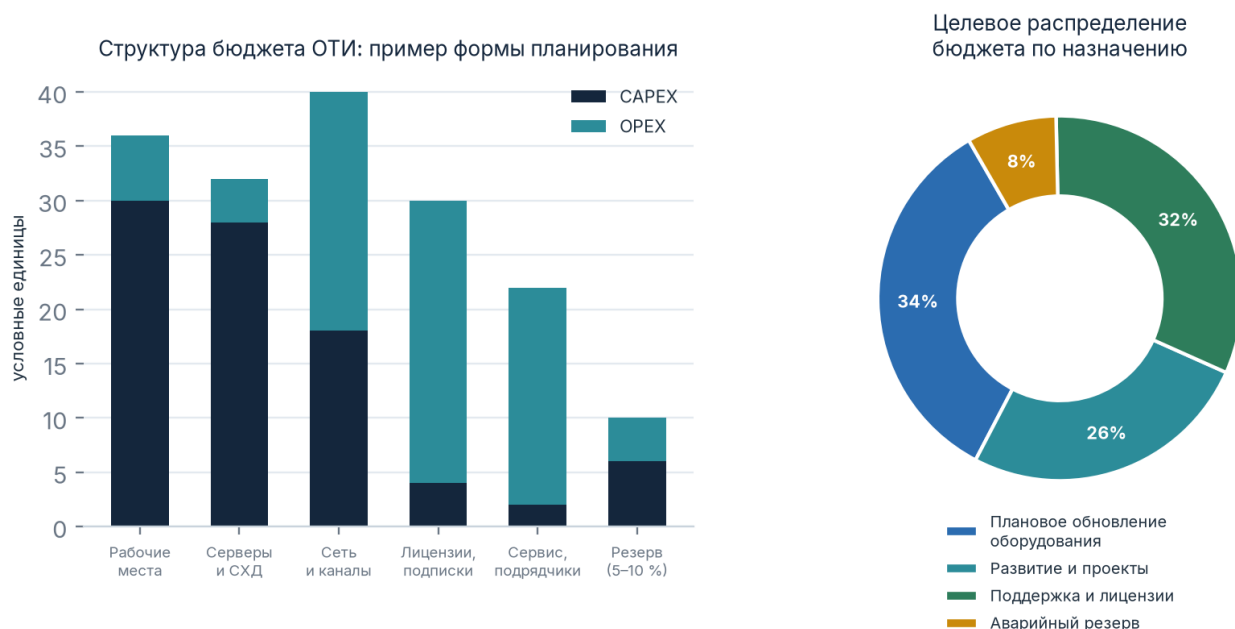


Рис. 29. Структура бюджета отдела: пример формы планирования по категориям (CAPEX/OPEX) и целевое распределение по назначению.

Статья бюджета	Что включает	Основание для планирования
Плановое обновление парка	Замена оборудования, вышедшего за нормативный срок эксплуатации или снятого с поддержки	Данные учёта, нормативные сроки эксплуатации

Статья бюджета	Что включает	Основание для планирования
Расширение ёмкости	Дополнительные ресурсы серверов, СХД, портов, каналов	Отчёты о утилизации и прогноз роста
Развитие и проекты	Новые сервисы, модернизация, внедрения	Проектные инициативы, план развития ИТ
Лицензии и подписки	Продление и расширение лицензий, облачные подписки	Реестр лицензий, прогноз численности пользователей
Техническая поддержка	Договоры поддержки оборудования и ПО, продление гарантий	Реестр договоров, классы критичности систем
Подрядные работы	Монтажные работы, пусконаладка, специализированные работы	План работ, оценка собственных ресурсов
Расходные материалы и запасные части	Комплектующие, подменный фонд, расходные материалы	Статистика отказов и потребления
Аварийный резерв	Резерв на непредвиденные замены и восстановление (рекомендуется 5–10 % бюджета)	Статистика инцидентов и отказов оборудования

Таблица 58. Структура бюджета ОТИ и основания для планирования

- закупка производится в соответствии с утверждённым бюджетом; в крайних случаях — по отдельному согласованию с ИТ-директором;
- внеплановые расходы обосновываются служебной запиской с описанием последствий отказа от расхода;
- расходы, вызванные аварийной заменой оборудования критичных систем, приоритетны и согласуются в ускоренном порядке;
- исполнение бюджета отдела контролируется ежеквартально и включается в отчётность.

17.5. Technology Standard: внутренний технический стандарт

Technology Standard — обязательный внутренний документ, определяющий допустимые технические решения. Стандарт разрабатывается ОТИ, согласуется с отделом ИБ и утверждается ИТ-директором. Стандарт формируется с **разбивкой по подразделениям** в части рабочих мест и по категориям — в части инфраструктуры.

Категория стандарта	Что фиксируется
Рабочие места по категориям сотрудников	Типовые конфигурации для офисных сотрудников, инженеров, руководителей, мобильных сотрудников, производственных и складских рабочих мест
Операционные системы	Допустимые версии и редакции, срок поддержки, порядок перехода на новые версии
Серверное оборудование	Допустимые производители и линейки, требования к отказоустойчивости и гарантии
Виртуализация	Платформа, версии, требования к кластеризации и хранению
Системы хранения	Допустимые решения, требования к производительности и резервированию
Сетевое оборудование	Допустимые производители и линейки, требования к управляемости, поддержке протоколов и резервированию
Резервное копирование	Решение, схема хранения, требования к изоляции копий
Мониторинг	Решение, обязательный состав наблюдения, требования к оповещениям
Периферия и печать	Допустимые модели принтеров и МФУ, требования к сетевой печати и расходным материалам
Телефония и связь	Допустимые решения, требования к каналам связи и резервированию
Программное обеспечение	Перечень разрешённого ПО по категориям, порядок включения нового ПО
Облачные сервисы	Допустимые сценарии использования, требования к размещению данных и интеграции

Таблица 59. Состав Technology Standard

Пример структуры стандарта рабочих мест по подразделениям

Категория сотрудников	Типовое устройство	Минимальная конфигурация	Периферия	Срок замены
Офисный сотрудник	Рабочая станция	4 ядра, 16 ГБ, SSD 512 ГБ	Монитор 24", клавиатура, мышь, гарнитура	5 лет
Мобильный сотрудник	Ноутбук 14"	4 ядра, 16 ГБ, SSD 512 ГБ	Док-станция, монитор, гарнитура	4 года
Руководитель	Ноутбук 14" повышенной автономности	6–8 ядер, 32 ГБ, SSD 1 ТБ	Док-станция, монитор, гарнитура	4 года
Инженер / технический специалист	Ноутбук или рабочая станция	8 ядер, 32 ГБ, SSD 1 ТБ	Два монитора	4 года
Складское и производственное место	Рабочая станция или терминал в защищённом исполнении	По требованиям прикладной системы	Сканер, принтер этикеток	6 лет
Общее (сменное) рабочее место	Рабочая станция	4 ядра, 8–16 ГБ, SSD 256 ГБ	Монитор 24"	6 лет

Таблица 60. Пример структуры стандарта рабочих мест (конкретные конфигурации утверждаются отдельно и обновляются не реже одного раза в год)

17.6. Отклонение от стандарта

- отклонение допускается только при наличии обоснованной потребности, которую невозможно закрыть стандартным решением;
- заявка на отклонение готовится ОТИ с описанием причины, риска, стоимости и последствий для поддержки;
- отклонение утверждает ИТ-директор; отклонения, влияющие на защищённость, дополнительно согласуются отделом ИБ;
- утверждённое отклонение вносится в реестр исключений (приложение Q) с указанием срока действия и условий возврата к стандарту.

18. Документирование инфраструктуры

Что документируем, где храним, в какие сроки и кто отвечает за актуальность.

18.1. Базовый принцип

Требование раздела 18

Не задокументировано — не сделано. Работа считается завершённой только после документирования результата. Что-то подняли, настроили, изменили — сразу задокументировали. Наличие критичной инфраструктуры, информация о которой существует только «в голове» одного сотрудника, **прямо запрещается** настоящей Политикой и рассматривается как недопустимый операционный риск.

- документирование выполняется одновременно с работами, но не позднее **3 рабочих дней** после их завершения;
- для аварийных работ срок документирования — не позднее следующего рабочего дня в части фактически выполненных действий;
- заявка или RFC не могут быть закрыты, если документация не обновлена; контроль — руководитель ОТИ и руководитель службы поддержки;
- документация пишется для коллеги, который будет разбираться в системе без автора: критерий качества — возможность выполнить восстановление или типовую операцию по документу без обращения к автору.

18.2. Место хранения



Рис. 30. Структура хранения технической документации на сетевом диске и порядок хранения бумажных копий ключевых документов.

Носитель	Что хранится	Доступ	Ответственный
Сетевой диск (основное хранилище)	Вся техническая документация: политики и регламенты, каталог сервисов, схемы, реестры, инструкции, отчёты	По ролям: сотрудники ОТИ — чтение и запись в своих разделах; ИТ-директор и отдел ИБ — чтение всего; иные — по согласованию	Руководитель ОТИ
Бумажная копия в отделе ИБ	Политика, схемы критичной инфраструктуры, план аварийного восстановления, матрица доступа, пароли аварийного доступа (в запечатанном виде)	По порядку, установленному отделом ИБ	Отдел ИБ (хранение), ОТИ (актуальность содержания)
Система учёта (Итилиум)	Заявки, RFC, журнал изменений, история работ по сервисам	По ролям в системе	Руководитель службы поддержки
Хранилище секретов	Пароли административных, сервисных и технических учётных записей	Персонально, по ролям, с журналированием	Руководитель ОТИ совместно с отделом ИБ

Таблица 61. Хранилища документации и разграничение доступа

Резервное копирование раздела документации на сетевом диске обязательно и выполняется в режиме, соответствующем классу А.

18.3. Обязательный перечень документов

Документ	Содержание	Ответственный	Актуализация
Каталог и реестр сервисов	Перечень сервисов, владельцы, классы, ответственные, параметры восстановления	Руководитель ОТИ	При изменениях; ревизия ежегодно
Паспорт сервиса	Назначение, состав, зависимости, порядок восстановления, контакты	Ответственный инженер	При изменениях
Схемы сети L1/L2/L3	Физическая, коммутационная и логическая схемы по площадкам	Сетевой инженер	При каждом изменении
IP-план и реестр VLAN	Распределение адресов и сегментов	Сетевой инженер	При каждом изменении
Реестр правил межсетевого экрана	Правила, обоснования, сроки, согласования	Сетевой инженер	При изменении; ревизия раз в полгода
Реестр серверов и виртуальных машин	Перечень, назначение, ресурсы, размещение, ответственные	Системный администратор	При изменениях; сверка ежеквартально
Паспорта серверов	Конфигурация, установленное ПО, зависимости, порядок обслуживания	Системный администратор	При изменениях
Схема и регламент резервного копирования	Что, куда, как часто, сроки хранения, порядок восстановления	Системный администратор	При изменениях; ревизия ежегодно
Матрица доступа	Кто имеет доступ к каким системам и в каком объёме	Руководитель ОТИ	При изменениях; ревизия ежеквартально
Реестр административных учётных записей	Перечень, владельцы, назначение	Руководитель ОТИ	Ревизия ежеквартально
Перечень объектов мониторинга	Объекты, параметры, пороги, получатели оповещений	Системный администратор	При изменениях
Паспорта площадок	Каналы, оборудование, серверные, контакты, схемы	Сетевой инженер совместно с 1-й линией	При изменениях; сверка ежегодно
Инструкции и runbook	Пошаговые инструкции типовых операций и восстановления	Ответственные инженеры	При изменениях; проверка при тестовом восстановлении
Реестр подрядчиков и договоров	Предмет, условия поддержки, контакты, сроки	Руководитель ОТИ	При изменениях
Реестр лицензий	Наименования, количество, сроки, привязка	Сервис-менеджер совместно с ОТИ	При изменениях; сверка ежегодно
Журнал изменений	Все выполненные изменения инфраструктуры	Исполнители	Непрерывно
Разборы инцидентов	Постмортемы и корректирующие меры	Руководитель ОТИ	По факту инцидентов
Реестр исключений из Политики	Действующие отклонения, сроки, условия	Руководитель ОТИ	При изменениях; ревизия ежеквартально
Реестр рисков ОТИ	Известные риски, оценка, предложенные меры, статус	Руководитель ОТИ	Ежеквартально

Таблица 62. Обязательный перечень документов ОТИ

18.4. Требования к оформлению документа

Элемент	Требование
Заголовок документа	Наименование, версия, дата, автор, владелец документа
Область применения	К каким системам, площадкам и процессам относится
Дата следующей ревизии	Обязательна для регламентов, схем и инструкций критичных систем
История изменений	Кто, когда и что изменил
Понятность	Документ должен быть достаточным для выполнения описанных действий сотрудником соответствующей квалификации без автора
Схемы	Обязательны для сетевой инфраструктуры, кластеров, схем резервного копирования и интеграций
Именование файлов	По утверждённой схеме: тип документа, объект, версия, дата

Таблица 63. Требования к оформлению технической документации

18.5. Контроль актуальности

- ответственный за актуальность документа — сотрудник, отвечающий за соответствующую область (см. перечень выше); общий контроль — руководитель ОТИ;
- ежеквартально проводится выборочная проверка актуальности: сверка документации с фактическим состоянием не менее трёх случайно выбранных систем или схем;
- ежегодно проводится полный аудит документации; результаты включаются в годовой отчёт с планом устранения пробелов;
- выявленное несоответствие документации фактическому состоянию устраняется в течение 5 рабочих дней; для критичных систем — в течение 2 рабочих дней;
- показатель полноты и актуальности документации входит в число кандидатов на KPI отдела (раздел 20).

18.6. Запрет уникального знания и передача знаний

Ситуация	Требование Политики
Систему настроил один сотрудник, документации нет	Документирование в течение 5 рабочих дней; до этого система считается находящейся в зоне риска и включается в реестр рисков
Есть область без резервного ответственного	Назначение резервного ответственного и передача знаний в течение 10 рабочих дней
Сотрудник уходит в отпуск	Передача статуса работ и незакрытых задач резервному ответственному с фиксацией
Сотрудник увольняется	Обязательная передача дел по перечню: доступы, документация, незавершённые работы, особенности систем; приёмку подтверждает руководитель ОТИ
Работы выполнял подрядчик	Передача документации и инструктаж сотрудников ОТИ — обязательное условие приёмки работ

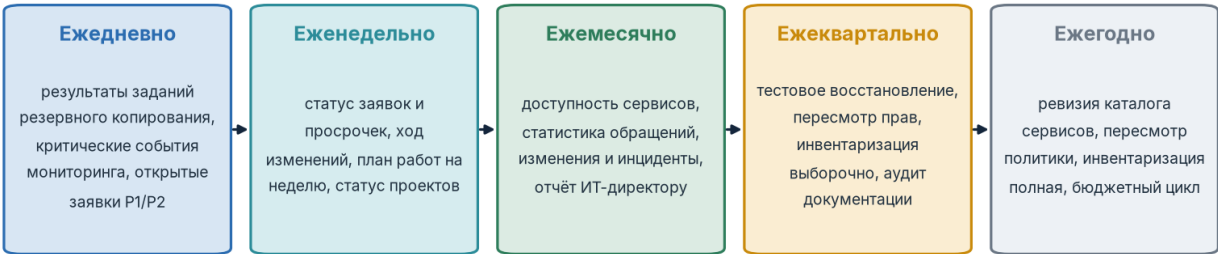
Таблица 64. Меры против концентрации знаний у одного сотрудника

19. Контроль, аудит и отчётность

Как проверяется соблюдение Политики и как отдел отчитывается о своей работе.

19.1. Цикл отчётности

Цикл отчётности и контроля



Отчётность за действия: каждое действие в инфраструктуре имеет след — заявку, RFC, запись в журнале изменений или запись в журнале доступа

Рис. 31. Цикл отчётности и контроля: от ежедневных проверок до годовой ревизии.

Период	Состав	Готовит	Получатель
Ежедневно	Результаты заданий резервного копирования; критические события мониторинга; открытые заявки Р1 и Р2; события дежурства	2-я линия, руководитель службы поддержки	Руководитель ОТИ
Еженедельно	Статус заявок и просрочек; выполненные и планируемые изменения; статус проектов; кадровые и ресурсные вопросы	Руководитель ОТИ	ИТ-директор
Ежемесячно	Доступность сервисов; статистика обращений по категориям и приоритетам; изменения (включая аварийные и несанкционированные); инциденты и разборы; состояние резервного копирования; утилизация ресурсов; риски	Руководитель ОТИ	ИТ-директор
Ежеквартально	Результаты тестовых восстановлений; ревизия прав доступа; выборочная инвентаризация; выборочный аудит документации; исполнение бюджета; реестр исключений и рисков	Руководитель ОТИ	ИТ-директор, отдел ИБ (в части ИБ)
Ежегодно	Ревизия каталога сервисов; полная инвентаризация; полный аудит документации; оценка зрелости процессов; итоги года; план развития и бюджет; пересмотр Политики	Руководитель ОТИ	ИТ-директор, руководство Компании

Таблица 65. Регламент отчётности ОТИ

19.2. Состав ежемесячного отчёта

Пример ежемесячного дашборда ОТИ (состав и целевые значения утверждаются отдельным документом)



Рис. 32. Пример состава ежемесячного отчёта (дашборда) ОТИ. Конкретные целевые значения устанавливаются при утверждении SLA и KPI.

- отчёт формируется на основе данных систем учёта и мониторинга, а не на основе экспертных оценок;
- показатели, которые невозможно получить автоматически, помечаются как оценочные с указанием источника;
- отчёт содержит не только показатели, но и выводы: что улучшилось, что ухудшилось, какие решения требуются от руководства;
- отчёт публикуется в разделе документации и хранится не менее 3 лет.

19.3. Внутренний аудит соблюдения Политики

Аудит проводится руководителем ОТИ (самопроверка) и, по решению ИТ-директора, с участием отдела ИБ или внешнего эксперта. Аудит носит характер проверки процессов, а не оценки конкретных сотрудников.

Проверяемая область	Что проверяется	Периодичность
Обращения	Доля обращений, зарегистрированных в системе учёта; полнота заполнения заявок; обоснованность приоритетов; соблюдение целевых сроков	Ежемесячно
Изменения	Наличие RFC по выполненным изменениям; наличие планов тестирования и отката; доля аварийных и несанкционированных изменений	Ежемесячно
Каталог сервисов	Полнота каталога; наличие паспортов и владельцев; отсутствие неучтённых систем	Ежеквартально
Доступы	Актуальность матрицы доступа; отсутствие излишних прав; состояние административных и сервисных учётных записей; аварийная учётная запись	Ежеквартально
Резервное копирование	Покрытие систем; успешность заданий; наличие актов тестового восстановления	Ежеквартально
Мониторинг	Покрытие сервисов; отсутствие «слепых зон»; качество оповещений	Ежеквартально

Проверяемая область	Что проверяется	Периодичность
Документация	Актуальность выборочно проверяемых документов и схем; соответствие фактическому состоянию	Ежеквартально
Оборудование и учёт	Соответствие учётных данных фактическому состоянию; отсутствие неучтённого оборудования	Ежеквартально
Подрядчики	Наличие журналов доступа; отзыв доступов по завершении работ; наличие документации по выполненным работам	Ежеквартально
Исключения	Действительность и обоснованность исключений; истёкшие исключения	Ежеквартально

Таблица 66. Программа внутреннего аудита соблюдения Политики (чек-лист — приложение Т)

- результаты аудита оформляются с перечнем выявленных отклонений, причин и корректирующих мер с ответственными и сроками;
- устранение отклонений контролируется как обычные задачи в системе учёта;
- систематически повторяющиеся отклонения выносятся на уровень ИТ-директора с оценкой необходимости изменения процесса или выделения ресурсов.

20. SLA и KPI: рамочные положения

Соглашение об уровне обслуживания и показатели эффективности разрабатываются отдельными документами; Политика закрепляет рамку.

20.1. Статус SLA и KPI

Статус документов

SLA (соглашение об уровне обслуживания) и KPI (показатели эффективности отдела) будут разработаны отдельными документами после накопления статистики в системе учёта. Настоящая Политика фиксирует обязательность их разработки, перечень показателей-кандидатов и источники данных. До утверждения SLA приведённые в Политике целевые значения применяются как внутренние ориентиры ОТИ и не являются обязательствами перед бизнесом.

Документ	Что закрепляет	Срок разработки	Кто утверждает
SLA (каталог услуг с параметрами)	Целевое время реакции и решения по категориям и приоритетам, целевую доступность сервисов, режим поддержки, исключения	После 3 месяцев накопления статистики	ИТ-директор по согласованию с владельцами процессов
KPI отдела	Показатели результативности ОТИ и порядок их расчёта	Одновременно с SLA или после него	ИТ-директор
Перечень стандартных изменений	Операции, не требующие отдельного согласования	В течение 2 месяцев с даты утверждения Политики	Руководитель ОТИ

Таблица 67. Документы, разрабатываемые в развитие раздела 20

20.2. Показатели-кандидаты

Показатель	Формула или способ расчёта	Источник данных	Назначение
Доступность сервисов класса А	$1 - (\text{время недоступности} / \text{период}) \times 100\%$, по каждому сервису	Система мониторинга	Оценка непрерывности
Выполнение целевого времени реакции	Доля заявок, по которым реакция выполнена в целевой срок	Итилиум	Оценка работы поддержки
Выполнение целевого времени решения	Доля заявок, решённых в целевой срок, по приоритетам	Итилиум	Оценка работы поддержки
Доля обращений через единую точку входа	Заявки, поступившие через help@ и портал / все обращения	Итилиум, выборочный контроль	Дисциплина процесса
Доля решений на 1-й линии	Заявки, закрытые 1-й линией / все закрытые заявки	Итилиум	Эффективность поддержки
Количество инцидентов по уровням	Число инцидентов Sev-1, Sev-2, Sev-3 за период	Итилиум, мониторинг	Оценка стабильности
Повторные инциденты	Доля инцидентов, повторившихся в течение 30 дней	Итилиум	Качество устранения причин
Доля изменений с оформленным RFC	Изменения с RFC / все выполненные изменения	Итилиум, журнал изменений	Управляемость изменений
Неуспешные изменения	Доля изменений, завершившихся откатом или инцидентом	Журнал изменений	Качество планирования
Несанкционированные изменения	Количество выявленных изменений без согласования (цель — ноль)	Аудит, журналы систем	Дисциплина процесса
Успешность резервного копирования	Успешные задания / все задания за период	Система резервного копирования	Защита данных
Подтверждённая восстанавливаемость	Доля систем класса А с актом успешного тестового восстановления за период	Акты восстановления	Реальная готовность к аварии
Покрытие мониторингом	Сервисы с мониторингом уровней 1–3 / все сервисы классов А и В	Система мониторинга, каталог	Наблюдаемость
Полнота и актуальность документации	Доля объектов с актуальной документацией по результатам выборочной проверки	Результаты аудита	Снижение зависимости от людей
Выполнение плановых работ	Выполненные плановые изменения и работы / запланированные	План работ, Итилиум	Предсказуемость
Доля оборудования за пределами срока службы	Оборудование старше нормативного срока / весь парк	Система учёта	Управление устареванием
Исполнение бюджета	Фактические расходы / плановые, с анализом отклонений	Бюджетная отчётность	Финансовая дисциплина

Таблица 68. Показатели-кандидаты для KPI отдела (целевые значения устанавливаются отдельным документом)

Ограничение на использование KPI

Принцип применения показателей: показатели измеряют **процессы**, а не личную старательность сотрудников. Показатель, который стимулирует скрывать проблемы (например, «ноль инцидентов любой ценой» или «быстрое закрытие заявок без решения»), подлежит пересмотру. Данные для показателей должны собираться автоматически; ручной сбор допускается только временно.

21. Ответственность за нарушение Политики

Соразмерные меры при нарушениях и защита сотрудников, действующих по правилам.

21.1. Виды нарушений

Категория	Примеры	Реакция
Незначительное отклонение	Несвоевременное заполнение заявки, задержка документирования в пределах нескольких дней	Замечание руководителя, устранение в установленный срок
Существенное нарушение	Выполнение изменения без согласования; отсутствие плана отката при работах с критичным сервисом; работа в обход системы учёта на регулярной основе; отсутствие документации по внедрённой системе	Разбор с участием руководителя ОТИ, письменная фиксация, корректирующие меры, при повторении — дисциплинарные меры в порядке, установленном Компанией
Грубое нарушение	Соккрытие факта или последствий своих действий; искажение информации при разборе инцидента; несанкционированное использование аварийной учётной записи; предоставление доступа подрядчику в обход отдела ИБ; умышленное уничтожение журналов или документации	Разбор с участием ИТ-директора и отдела ИБ, дисциплинарные меры в порядке, установленном законодательством и внутренними документами Компании
Нарушение со стороны подразделений	Самостоятельная закупка ИТ-решений; самовольная установка серверного ПО или оборудования; требование выполнить работы в обход процедуры	Информирование руководителя подразделения и ИТ-директора; отказ в принятии на поддержку; при повторении — вынесение на уровень руководства Компании
Нарушение со стороны подрядчика	Работы вне согласованного объёма или окна; передача доступа третьим лицам; отсутствие документации по работам	Приостановка работ, фиксация, отказ в приёмке, претензионная работа через подразделение закупок

Таблица 69. Категории нарушений Политики и соразмерная реакция

21.2. Гарантии для сотрудников

Принцип безопасной среды

Сотрудник, действовавший в рамках согласованной процедуры, зафиксировавший свои действия и своевременно сообщивший о проблеме, не несёт ответственности за наступившие технические последствия. Ответственность в таком случае рассматривается как ответственность процесса: анализируются требования, ресурсы и качество процедуры. Это прямое следствие принципа «Enterprise с человеческим подходом».

- сотрудник вправе отказаться от выполнения работ, если они требуют нарушения Политики или создают неприемлемый риск, — с обязательным письменным уведомлением руководителя ОТИ;
- сотрудник вправе сообщить о выявленном нарушении или риске напрямую руководителю ОТИ, а при конфликте интересов — ИТ-директору или отделу ИБ;
- сообщение о собственной ошибке, сделанное своевременно и полно, рассматривается как ожидаемое поведение и не является основанием для взыскания;
- требования, поступающие в обход руководителя ОТИ и противоречащие Политике, сотрудник обязан переадресовать руководителю ОТИ.

22. Исключения из Политики

Управляемые отклонения вместо негласных нарушений.

Политика допускает отклонения от своих требований, если отклонение обосновано, ограничено по сроку, сопровождается компенсирующими мерами и зафиксировано. Незафиксированное отклонение является нарушением, а не исключением.

Этап	Содержание	Ответственный
Запрос	Описание требуемого отклонения, причины, альтернатив, оценка риска, предлагаемые компенсирующие меры и срок	Инициатор (сотрудник ОТИ, руководитель подразделения, подрядчик через ОТИ)
Оценка	Оценка технического риска, влияния на сервисы, на безопасность и на поддержку	Руководитель ОТИ, отдел ИБ (при влиянии на защищённость)
Утверждение	Решение об исключении с указанием срока действия и условий	Руководитель ОТИ — в пределах своих полномочий; ИТ-директор — при отклонении от Technology Standard и при влиянии на бизнес; отдел ИБ — при влиянии на защищённость
Регистрация	Внесение в реестр исключений (приложение Q)	Руководитель ОТИ
Контроль	Ежеквартальная проверка действительности исключений; закрытие истёкших; продление — только с повторным обоснованием	Руководитель ОТИ

Таблица 70. Порядок оформления исключений

Требование Политики	Возможно ли исключение	Условия
Регистрация обращений в системе учёта	Нет	—
Согласование изменений	Нет (кроме аварийных изменений с оформлением по факту)	—
Наличие плана отката для систем класса А	Да, в исключительных случаях	Согласование ИТ-директора, компенсирующие меры, резервная копия
Мониторинг сервиса	Да, временно	Срок не более 30 дней, план подключения мониторинга
Резервное копирование системы	Да, для класса D	Решение руководителя ОТИ с фиксацией
Соответствие Technology Standard	Да	Утверждение ИТ-директора, запись в реестре исключений
Требования отдела ИБ	Только по решению отдела ИБ	Согласование ИБ обязательно
Документирование	Да, по срокам (не по факту наличия)	Продление срока документирования по решению руководителя ОТИ, не более 10 рабочих дней

Таблица 71. Допустимость исключений по ключевым требованиям Политики

23. Внедрение Политики: план-график

Поэтапное внедрение, чтобы требования заработали на практике, а не остались на бумаге.

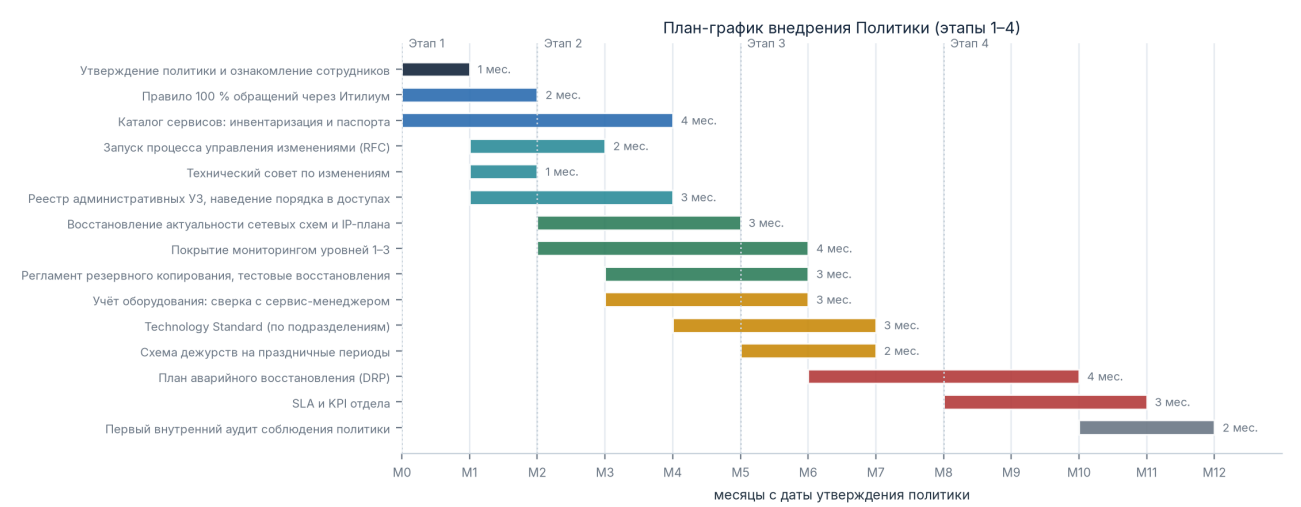


Рис. 33. План-график внедрения Политики. Этап 1 — дисциплина обращений и каталог сервисов; этап 2 — управление изменениями и доступами; этап 3 — мониторинг, копирование и учёт; этап 4 — стандарты, DRP, SLA и KPI.

Этап	Содержание	Ключевой результат	Ответственный
Этап 1 (M0–M2): дисциплина и прозрачность	Утверждение и доведение Политики под подпись; перевод 100 % обращений в систему учёта; инвентаризация и описание сервисов; назначение владельцев и ответственных; матрица замещения	Каталог сервисов с паспортами, единая очередь работ	Руководитель ОТИ, руководитель службы поддержки
Этап 2 (M2–M5): управляемость	Запуск процесса RFC и технического совета; перечень стандартных изменений; реестр административных учётных записей; наведение порядка в доступах; актуализация сетевых схем и IP-плана	Все изменения — через согласование и план; порядок в доступах	Руководитель ОТИ, 2-я линия
Этап 3 (M3–M7): наблюдаемость и восстанавливаемость	Покрытие мониторингом уровней 1–3; регламент резервного копирования; первые тестовые восстановления с актами; сверка учёта оборудования с сервис-менеджером	Нет «слепых зон»; подтверждённая восстанавливаемость критичных систем	2-я линия, сервис-менеджер
Этап 4 (M4–M12): стандарты и зрелость	Technology Standard с разбивкой по подразделениям; схема дежурств; разработка DRP и первые учения; SLA и KPI; первый внутренний аудит соблюдения Политики	Стандартизованная инфраструктура, измеряемые обязательства, проверенный план восстановления	Руководитель ОТИ, ИТ-директор

Таблица 72. Этапы внедрения Политики

23.1. Условия успешного внедрения

- поддержка руководства: Политика доводится до руководителей подразделений на уровне ИТ-директора, а не только внутри ИТ;
- единство правил: исключений «для отдельных лиц» не существует, иначе процесс теряет силу;
- обучение пользователей: короткая инструкция «как обращаться в ИТ» рассылается всем сотрудникам и выдаётся при приёме на работу;
- обучение сотрудников ОТИ: разбор Политики на встрече отдела с примерами типовых ситуаций;
- терпимость к переходному периоду: в первые 2 месяца нарушения дисциплины обращений исправляются разъяснением, а не взысканием;
- видимый результат: отчётность публикуется, улучшения фиксируются и доводятся до подразделений.

24. Связанные регламенты и документы

Политика — рамочный документ; технические детали живут в отдельных регламентах.

№	Документ	Что регулирует	Статус	Ответственный
1	SLA: каталог услуг и параметры обслуживания	Целевые сроки реакции и решения, доступность сервисов, режим поддержки	Разрабатывается	Руководитель ОТИ
2	KPI отдела технической инфраструктуры	Показатели и целевые значения	Разрабатывается	Руководитель ОТИ
3	Регламент управления изменениями	Детальный порядок работы с RFC, классификация, окна, постконтроль	Разрабатывается	Руководитель ОТИ
4	Перечень стандартных изменений	Операции без отдельного согласования	Разрабатывается	Руководитель ОТИ
5	Регламент управления доступом	Порядок предоставления, изменения, отзыва и ревизии прав	Разрабатывается совместно с ИБ	Руководитель ОТИ, отдел ИБ
6	Регламент резервного копирования и восстановления	Схемы, расписания, сроки хранения, порядок восстановления и тестирования	Разрабатывается	Системный администратор (ответственный)
7	План аварийного восстановления (DRP)	Сценарии и процедуры восстановления при авариях	Разрабатывается	Руководитель ОТИ
8	Технический стандарт (Technology Standard)	Допустимые решения по категориям и подразделениям	Разрабатывается	Руководитель ОТИ
9	Стандарт сетевой инфраструктуры	Схема адресации, сегментация, именование, требования к оборудованию	Разрабатывается	Ведущий сетевой инженер
10	Стандарт серверной инфраструктуры	Базовые конфигурации, шаблоны, именование, размещение	Разрабатывается	Ведущие системные администраторы
11	Регламент мониторинга	Объекты, параметры, пороги, оповещения, дежурные процедуры	Разрабатывается	Системный администратор (ответственный)
12	Регламент управления инцидентами	Классификация, порядок работы с крупными инцидентами, постмортемы	Разрабатывается	Руководитель ОТИ
13	Регламент дежурств	Схема, график, обязанности, компенсация	Разрабатывается	Руководитель ОТИ
14	Регламент работы с подрядчиками	Выбор, доступ, сопровождение, приёмка	Разрабатывается	Руководитель ОТИ
15	Регламент учёта оборудования и лицензий	Учёт, движение, инвентаризация, списание	Разрабатывается совместно с сервис-менеджером	Сервис-менеджер, ОТИ
16	Инструкция пользователя «Как обращаться в ИТ»	Порядок обращения, что указывать, чего ожидать	Разрабатывается	Руководитель службы поддержки
17	Классификатор критичности систем	Классы, критерии, перечень систем по классам	Часть Политики (раздел 6), детализируется	Руководитель ОТИ
18	Политика информационной безопасности и связанные документы	Требования ИБ, парольная политика, порядок работы с инцидентами ИБ	Действует / ведётся отделом ИБ	Отдел ИБ

Таблица 73. Перечень связанных документов и их статус

Иерархия документов

Порядок соотнесения документов: Политика устанавливает **что** обязательно и **кто** отвечает; регламенты описывают **как** это делается; инструкции и runbook описывают **конкретные шаги**. Изменение регламента не требует изменения Политики, если не меняются зоны ответственности и обязательные требования.

Приложение А. Паспорт ИТ-сервиса

Заполняется на каждый сервис каталога. Без паспорта сервис не принимается на поддержку.

Наименование сервиса	
Код сервиса в каталоге	
Назначение и краткое описание <i>для чего сервис нужен бизнесу</i>	
Владелец сервиса (подразделение, Ф. И. О., должность)	
Ответственный инженер ОТИ (основной)	
Ответственный инженер ОТИ (резервный)	
Класс критичности (А / В / С / D)	
Целевая доступность	
RPO (допустимая потеря данных)	
RTO (целевой срок восстановления)	
Пользователи и площадки <i>кто и где использует сервис</i>	
Состав сервиса <i>серверы, ВМ, службы, базы данных, оборудование</i>	
Сетевое размещение <i>сегменты, адреса, порты, публикация</i>	
Зависимости от других сервисов	
Сервисы, зависящие от данного	
Лицензии и договоры поддержки	
Режим резервного копирования <i>что, куда, как часто, срок хранения</i>	
Объекты и параметры мониторинга	
Порядок восстановления <i>ссылка на инструкцию или runbook</i>	
Матрица доступа к сервису <i>ссылка на документ</i>	
Согласование отдела ИБ <i>требуется / не требуется, дата, кто согласовал</i>	
Дата ввода в эксплуатацию	
Дата последней ревизии паспорта	
Плановая дата следующей ревизии	

Форма 2. Паспорт ИТ-сервиса

Приложение В. Реестр ИТ-сервисов

Сводный реестр ведётся руководителем ОТИ в электронном виде; печатная форма используется для ревизии и аудита.

№	Сервис	Класс	Владелец сервиса	Ответственный ОТИ	Резервный ответственный	RPO	RTO	Мониторинг (да/нет)	Резервное копирование (да/нет)	Паспорт (дата)
1										
2										
3										
4										
5										
6										
7										
8										
9										
10										
11										
12										
13										
14										
15										
16										
17										
18										

Форма 3. Реестр ИТ-сервисов

Приложение С. Заявка на изменение (RFC) с планами внедрения, тестирования и отката

Обязательна для обычных, существенных и (по факту выполнения) аварийных изменений.

Номер RFC / номер заявки	
Дата подачи	
Инициатор (Ф. И. О., подразделение)	
Исполнитель (Ф. И. О., роль)	
Класс изменения <i>стандартное / обычное / существенное / аварийное</i>	
Описание изменения <i>что именно меняется</i>	
Обоснование <i>какую проблему решаем, последствия отказа от изменения</i>	
Затрагиваемые сервисы и их классы	
Затрагиваемые площадки и пользователи	
Оценка влияния <i>ожидаемый простой, деградация, влияние на пользователей</i>	
Оценка риска <i>вероятность и последствия неуспеха, меры снижения</i>	
Требуется согласование отдела ИБ <i>да / нет, основание</i>	
Требуется согласование владельца сервиса <i>да / нет, кто</i>	
Окно проведения работ <i>дата, время начала и окончания</i>	
Порядок уведомления пользователей <i>кто, когда, каким способом</i>	

Форма 4. RFC: общие сведения

План внедрения

№	Шаг	Действие	Исполнитель	Оценка времени	Отметка о выполнении
1					
2					
3					
4					
5					
6					
7					
8					

Форма 5. План внедрения изменения

План тестирования

№	Что проверяется	Метод проверки	Ожидаемый результат	Кто проверяет	Факт. результат
1					
2					
3					
4					
5					
6					
7					

Форма 6. План тестирования после изменения

Критерии успеха и план отката

Критерии успеха <i>измеримые признаки успешного изменения</i>	
Критерии неуспеха (условия отката)	
Точка невозврата <i>после какого шага откат невозможен</i>	
Резервная копия перед работами <i>что скопировано, где, когда, кем</i>	
План отката (шаги) <i>последовательность возврата в исходное состояние</i>	
Оценка времени отката	
Ответственный за принятие решения об откате	

Форма 7. Критерии и план отката

Согласование и результат

Роль	Ф. И. О.	Решение (согласовано / отклонено / с условиями)	Дата	Подпись
Руководитель ОТИ				
Отдел информационной безопасности				
Владелец сервиса				
ИТ-директор (для существенных изменений)				
Фактическое время выполнения работ				
Результат <i>успешно / успешно с замечаниями / откат</i>				
Фактически выполненные отклонения от плана				
Обновлённая документация <i>какие документы и схемы обновлены, дата</i>				
Подтверждение ввода в эксплуатацию <i>кто и когда подтвердил</i>				

Форма 8. Результат выполнения изменения

Приложение D. Журнал изменений инфраструктуры

Ведётся непрерывно; при наличии соответствующей функциональности в системе учёта журнал формируется автоматически.

№	Дата и время	Номер RFC / заявки	Объект изменения	Суть изменения	Класс	Исполнитель	Согласовал	Результат	Документация обновлена
1									
2									
3									
4									
5									
6									
7									
8									
9									
10									
11									
12									
13									
14									
15									
16									
17									
18									
19									
20									

Форма 9. Журнал изменений инфраструктуры

Приложение Е. Чек-лист ввода сервера или виртуальной машины в эксплуатацию

Заполняется исполнителем, проверяется руководителем ОТИ до передачи системы в эксплуатацию.

Имя системы (по стандарту именования)	
Назначение	
Сервис из каталога / класс критичности	
Номер RFC	
Исполнитель	

Форма 10. Сведения о системе

№	Контрольный пункт	Выполнено (да/нет)	Дата	Ответственный
1	Система создана из утверждённого шаблона либо конфигурация согласована			
2	Имя и сетевые параметры соответствуют стандарту именования и IP-плану			
3	Размещение в корректном сетевом сегменте согласовано (при необходимости — с ИБ)			
4	Применена базовая конфигурация ОС и параметры усиления защиты (hardening)			
5	Заводские и типовые пароли изменены, учётные данные помещены в хранилище секретов			
6	Система включена в домен либо обосновано её нахождение вне домена			
7	Настроена система обновлений, установлены актуальные обновления			
8	Установлены и работоспособны средства защиты (антивирус / EDR)			
9	Настроено журналирование и передача журналов в соответствии с требованиями ИБ			
10	Система включена в мониторинг (уровни 1–3 согласно классу критичности)			
11	Настроено резервное копирование, выполнено контрольное восстановление			
12	Ресурсы (процессор, память, диски) соответствуют требованиям и имеют запас			
13	Права доступа настроены по принципу минимально необходимых, внесены в матрицу			
14	Оформлен паспорт системы, система внесена в реестр серверов и ВМ			
15	Обновлены схемы и документация, создан runbook по типовым операциям			
16	Назначены основной и резервный ответственные			
17	Учтены лицензии на ОС и прикладное ПО			
18	Проведено приёмочное тестирование, результат зафиксирован			
19	Согласование отдела ИБ получено (при обработке защищаемой информации)			

№	Контрольный пункт	Выполнено (да/нет)	Дата	Ответственный
20	RFC закрыт, инициатор уведомлён			

Форма 11. Чек-лист ввода серверной системы в эксплуатацию

Приложение F. Матрица доступа к инфраструктуре

Ведётся руководителем ОТИ; ревизия — не реже одного раза в квартал совместно с отделом ИБ.

№	Система / сервис	Класс	Роль или сотрудник	Тип учётной записи	Объём прав	Основание (заявка)	Дата предоставления	Срок действия	Дата последней ревизии
1									
2									
3									
4									
5									
6									
7									
8									
9									
10									
11									
12									
13									
14									
15									
16									
17									
18									

Форма 12. Матрица доступа к инфраструктуре

Приложение Г. Заявка на предоставление, изменение или отзыв доступа

Оформляется в системе учёта; печатная форма применяется при необходимости бумажного согласования.

Тип заявки <i>предоставление / изменение / отзыв / временный доступ</i>	
Сотрудник (Ф. И. О., должность, подразделение)	
Инициатор (руководитель сотрудника)	
Система / сервис	
Запрашиваемый объём прав <i>конкретные права, роли, ресурсы</i>	
Обоснование необходимости	
Срок действия доступа <i>постоянный / до даты</i>	
Аналогичный доступ у сотрудника (при наличии) <i>для сверки состава прав</i>	
Согласование владельца ресурса <i>Ф. И. О., дата</i>	
Согласование отдела ИБ (при необходимости) <i>Ф. И. О., дата</i>	
Исполнитель <i>Ф. И. О., дата выполнения</i>	
Отметка о внесении в матрицу доступа	

Форма 13. Заявка на управление доступом

Приложение Н. Акт тестового восстановления из резервной копии

Обязателен для систем класса А (ежеквартально) и класса В (раз в полгода).

Дата и время проведения	
Система / сервис, класс критичности	
Источник резервной копии <i>хранилище, задание, дата копии</i>	
Способ восстановления <i>полное / на тестовый стенд / выборочное</i>	
Целевой RTO / целевой RPO	
Фактическое время восстановления	
Фактическая точка восстановления (дата и время данных)	
Использованная инструкция <i>наименование, версия; применима без доработки — да/нет</i>	
Исполнитель <i>Ф. И. О., роль (основной / резервный ответственный)</i>	
Участие отдела ИБ <i>Ф. И. О., дата</i>	
Проверка корректности данных владельцем сервиса <i>Ф. И. О., результат, дата</i>	
Выявленные отклонения и проблемы	
Корректирующие меры, ответственные и сроки	
Вывод <i>восстановление подтверждено / подтверждено с замечаниями / не подтверждено</i>	

Форма 14. Акт тестового восстановления

Роль	Ф. И. О.	Подпись	Дата
Исполнитель (ОТИ)			
Руководитель ОТИ			
Представитель отдела ИБ			
Владелец сервиса			

Приложение I. Отчёт о крупном инциденте (постмортем)

Обязателен для инцидентов Sev-1 и Sev-2; срок подготовки — 5 рабочих дней после закрытия инцидента.

Номер инцидента	
Уровень (Sev-1 / Sev-2)	
Дата и время возникновения	
Дата и время обнаружения	
Дата и время восстановления	
Общая длительность влияния	
Затронутые сервисы и классы	
Затронутые площадки, подразделения, количество пользователей	
Влияние на бизнес-процессы <i>что было невозможно делать и как долго</i>	
Потери данных <i>да / нет, объём, за какой период</i>	
Координатор инцидента	
Участники устранения	

Форма 15. Постмортем: общие сведения

Хронология

№	Время	Событие или действие	Кто выполнил	Результат
1				
2				
3				
4				
5				
6				
7				
8				
9				
10				

Форма 16. Хронология инцидента

Анализ

Непосредственная техническая причина	
Системные причины <i>пробелы в процессах, мониторинге, документации, ресурсах</i>	
Почему не было обнаружено раньше	
Что сработало хорошо	
Что не сработало	
Возможность повторения <i>высокая / средняя / низкая, обоснование</i>	

Форма 17. Анализ причин инцидента

Корректирующие меры

№	Мера	Тип (техническая / процессная / организационная)	Ответственный	Срок	Номер заявки	Статус
1						
2						
3						
4						
5						
6						
7						
8						

Форма 18. Корректирующие меры по итогам инцидента

Разбор проводится без поиска виновных. Формулировки вида «сотрудник допустил ошибку» заменяются описанием условий, которые позволили ошибке привести к инциденту.

Приложение J. График дежурств и журнал дежурного

График формируется не позднее чем за 10 рабочих дней до начала периода и доводится до сотрудников под подпись.

№	Дата	Дежурный по серверам и сервисам	Дежурный по сети	Дежурный 1-й линии	Дежурный руководитель	Подпись об ознакомлении
1						
2						
3						
4						
5						
6						
7						
8						
9						
10						
11						
12						

Форма 19. График дежурств на период _____

Журнал дежурного

№	Дата и время	Событие или обращение	Выполненные действия	Результат	Эскалация (кому, когда)
1					
2					
3					
4					
5					
6					
7					
8					
9					
10					
11					
12					

Форма 20. Журнал дежурного

Период дежурства	
Дежурный (Ф. И. О.)	
Проверка готовности перед дежурством <i>доступы, удалённое подключение, контакты эскалации, инструкции — проверены (да/нет)</i>	
Незакрытые вопросы при передаче смены	
Передал смену (Ф. И. О., дата, подпись)	
Принял смену (Ф. И. О., дата, подпись)	

Форма 21. Передача дежурства

Приложение К. Журнал доступа подрядчика

Заполняется куратором от ОТИ; доступ предоставляется отделом ИБ.

№	Подрядчик (организация)	Сотрудник подрядчика	Основание (договор, RFC)	Состав доступа	Дата и время начала	Дата и время окончания	Решение отдела ИБ (кто, дата)	Куратор от ОТИ	Доступ отозван (дата, подпись)
1									
2									
3									
4									
5									
6									
7									
8									
9									
10									
11									
12									
13									
14									

Форма 22. Журнал доступа подрядчиков

Приложение L. Акт приёмки работ подрядчика

Техническую приёмку выполняет ОТИ, приёмку результата — владелец процесса.

Подрядчик, номер договора	
Предмет работ	
Период выполнения работ	
Номер RFC (при влиянии на сервисы)	
Куратор от ОТИ	
Соответствие результата техническому заданию <i>да / да с замечаниями / нет</i>	
Проведённое тестирование и его результаты	
Переданная документация <i>схемы, конфигурации, описание изменений, инструкции</i>	
Проведён инструктаж сотрудников ОТИ <i>да / нет, кто, дата</i>	
Внесённые изменения в инфраструктуру <i>перечень с указанием объектов</i>	
Доступ подрядчика отозван <i>да / нет, дата, кем</i>	
Замечания и сроки их устранения	
Гарантийные обязательства и условия поддержки	

Форма 23. Акт приёмки работ подрядчика

Роль	Ф. И. О.	Решение	Подпись	Дата
Куратор от ОТИ (техническая приёмка)				
Руководитель ОТИ				
Владелец процесса (приёмка результата)				
Представитель отдела ИБ (при необходимости)				

Приложение М. Акт инвентаризации оборудования

Полная инвентаризация — ежегодно, выборочная — ежеквартально.

Вид инвентаризации <i>полная / выборочная / внеплановая</i>	
Основание <i>приказ, распоряжение, план</i>	
Период проведения	
Площадка (площадки)	
Состав комиссии <i>Ф. И. О., должности</i>	

Форма 24. Инвентаризация: общие сведения

№	Инвентарный номер	Наименование и модель	Серийный номер	Место нахождения по учёту	Фактическое место	Ответственный по учёту	Фактический пользователь	Состояние	Расхождение	Примечание
1										
2										
3										
4										
5										
6										
7										
8										
9										
10										
11										
12										
13										
14										
15										
16										

Форма 25. Ведомость инвентаризации оборудования

Всего проверено единиц	
Выявлено расхождений	
Не найдено оборудования	
Выявлено неучтённого оборудования	
Причины расхождений	
Корректирующие меры, ответственные и сроки	

Форма 26. Итоги инвентаризации

Приложение N. Акт передачи и возврата оборудования

Оформляется при выдаче оборудования сотруднику и при его возврате.

Сотрудник (Ф. И. О., должность, подразделение, площадка)	
Основание приём на работу / замена / ремонт / увольнение / перемещение	
Номер заявки	

Форма 27. Общие сведения

№	Наименование и модель	Инвентарный номер	Серийный номер	Комплектность	Состояние	Выдано (дата)	Возвращено (дата)
1							
2							
3							
4							
5							
6							
7							
8							

Форма 28. Перечень передаваемого оборудования

Сотрудник ознакомлен с правилами использования оборудования: оборудование используется для выполнения служебных обязанностей; самостоятельная установка программного обеспечения не допускается; данные, хранящиеся только на локальном диске, не резервируются и могут быть утрачены; о неисправностях и утере оборудования необходимо незамедлительно сообщать в ИТ через help@exon-group.ru.

Действие	Ф. И. О.	Подпись	Дата
Передал (1-я линия)			
Принял (сотрудник)			
Возврат: принял (1-я линия), проверена комплектность			
Передано на склад (сервис-менеджер)			

Приложение О. Чек-лист приёма и увольнения сотрудника

Заполняется 1-й линией; блокировку учётных записей при увольнении инициирует отдел информационной безопасности.

Приём сотрудника

№	Контрольный пункт	Выполнено	Дата	Исполнитель
1	Заявка получена не позднее чем за 2 рабочих дня до даты начала работы			
2	Профиль доступа определён по должности и согласован руководителем			
3	Создана учётная запись, применены типовые групповые членства			
4	Подготовлено рабочее место: оборудование, периферия, подключение к сети			
5	Установлено программное обеспечение из разрешённого перечня			
6	Создан почтовый ящик, выполнено подключение к необходимым сервисам			
7	Настроен доступ к файловым ресурсам в минимально необходимом объёме			
8	При необходимости настроен удалённый доступ (согласование ИБ получено)			
9	Оформлен акт передачи оборудования (приложение N)			
10	Проведён инструктаж: как обращаться в ИТ, правила использования оборудования и ПО			
11	Сотрудник ознакомлен с настоящей Политикой в части правил для пользователей			
12	Данные внесены в систему учёта оборудования			

Форма 29. Чек-лист приёма сотрудника

Увольнение сотрудника

№	Контрольный пункт	Выполнено	Дата	Исполнитель
1	Получено уведомление службы персонала о дате увольнения			
2	Отдел ИБ инициировал блокировку учётных записей; блокировка выполнена технически			
3	Отозван удалённый доступ и доступ к внешним сервисам			
4	Отозваны административные и сервисные права (при наличии)			
5	Определён порядок обработки рабочих данных (передача руководителю, архивация)			
6	Настроена переадресация или автоответ на почтовом ящике по решению руководителя			
7	Оборудование принято и проверено 1-й линией (комплектность, работоспособность)			
8	Оборудование передано сервис-менеджеру, данные учёта обновлены			
9	Носители информации обработаны по требованиям отдела ИБ			
10	Высвобождены лицензии, отражено в реестре лицензий			
11	Для сотрудников ОТИ: передана документация, доступы, незавершённые работы			
12	Для сотрудников ОТИ: обновлена матрица замещения по областям ответственности			

Форма 30. Чек-лист увольнения сотрудника

Приложение Р. Техническое обоснование закупки

Готовится ОТИ; является основанием для включения в бюджет и для закупочной процедуры.

Наименование потребности	
Инициатор потребности <i>подразделение, Ф. И. О.</i>	
Проблема или задача <i>что не работает или чего не хватает сейчас</i>	
Последствия отказа от решения <i>риски, потери, ограничения</i>	
Затрагиваемые сервисы и процессы	
Соответствие Technology Standard <i>соответствует / требуется исключение</i>	
Рассмотренные варианты решения <i>не менее двух вариантов, включая отказ от закупки</i>	
Обоснование выбранного варианта	
Технические требования <i>конфигурация, характеристики, совместимость, гарантия и поддержка</i>	
Влияние на действующую инфраструктуру <i>необходимые изменения, простои, риски</i>	
Требования к внедрению <i>собственные силы / подрядчик, сроки, ресурсы</i>	
Стоимость владения <i>закупка, лицензии, поддержка, обучение, электроэнергия, места в стойках</i>	
Влияние на бюджет <i>в бюджете / вне бюджета, статья, период</i>	
Согласование отдела ИБ <i>требуется / не требуется, отметка</i>	
Предложение по срокам	

Форма 31. Техническое обоснование закупки

Роль	Ф. И. О.	Решение	Подпись	Дата
Подготовил: руководитель ОТИ				
Согласовал: отдел информационной безопасности				
Согласовал: ИТ-директор				
Принял к исполнению: подразделение закупок				

Приложение Q. Реестр исключений из Политики

Ведётся руководителем ОТИ; ревизия — ежеквартально.

№	Требование Политики (пункт)	Суть отклонения	Обоснование	Компенсирующие меры	Кто утвердил	Дата утверж- дения	Срок действия	Статус	Отметка о закрытии
1									
2									
3									
4									
5									
6									
7									
8									
9									
10									
11									
12									
13									
14									

Форма 32. Реестр исключений

Приложение R. Паспорт площадки

Заполняется на каждую из площадок Компании; сверка — не реже одного раза в год.

Наименование и адрес площадки	
Категория <i>основная (серверная) / крупная / малая</i>	
Количество пользователей	
Режим работы площадки	
Ответственный инженер ОТИ	
Контактное лицо на площадке <i>Ф. И. О., должность, телефон</i>	
Основной канал связи <i>провайдер, тип, пропускная способность, SLA, поддержка</i>	
Резервный канал связи <i>провайдер, тип, пропускная способность, порядок переключения</i>	
Серверное помещение <i>наличие, площадь, стойки, контроль доступа</i>	
Электропитание <i>вводы, ИБП, время автономной работы, дизель-генератор</i>	
Климат и контроль среды <i>охлаждение, мониторинг температуры, датчики протечки</i>	
Локальные серверы и сервисы <i>перечень</i>	
Сетевое оборудование <i>перечень моделей, размещение, версии прошивок</i>	
Схема сети площадки <i>ссылка на документ, дата актуализации</i>	
Телефония <i>решение, номерной план, количество абонентов</i>	
Видеонаблюдение <i>серверы, камеры, срок хранения архива</i>	
Печать <i>принтеры и МФУ, сервер печати</i>	
Подрядчики по обслуживанию <i>перечень, предмет, контакты</i>	
Порядок действий при отказе связи <i>обходные варианты, порядок уведомления</i>	
Дата последней сверки паспорта	

Форма 33. Паспорт площадки

Приложение S. Лист ознакомления с Политикой

Ознакомление обязательно для сотрудников ОТИ; для остальных сотрудников — в части правил для пользователей.

№	Ф. И. О.	Должность	Подразделение	Дата ознакомления	Подпись
1					
2					
3					
4					
5					
6					
7					
8					
9					
10					
11					
12					
13					
14					
15					
16					
17					
18					
19					
20					

Форма 34. Лист ознакомления с Политикой отдела технической инфраструктуры

Приложение Т. Чек-лист внутреннего аудита соблюдения Политики

Применяется при ежеквартальной самопроверке и при аудите с участием отдела ИБ.

№	Контрольный пункт	Соответствует	Замечания	Дата
1	Все обращения за проверяемый период зарегистрированы в системе учёта			
2	Заявки содержат обязательные поля, описание решения и категорию			
3	Приоритеты присвоены в соответствии с матрицей приоритетов			
4	Просроченные заявки эскалированы в установленном порядке			
5	Все выполненные изменения имеют оформленный RFC			
6	Существенные изменения содержат планы внедрения, тестирования и отката			
7	Аварийные изменения оформлены по факту и рассмотрены на техническом совете			
8	Несанкционированные изменения отсутствуют либо разобраны с корректирующими мерами			
9	Каталог сервисов актуален, паспорта заполнены, владельцы назначены			
10	Неучтённые системы и «серверы под столом» не выявлены			
11	Матрица доступа актуальна, излишние права отозваны			
12	Реестр административных учётных записей проверен, персональность соблюдена			
13	Аварийная учётная запись хранится в отделе ИБ, упаковка целостна, пароль актуален			
14	Задания резервного копирования выполняются, сбои разобраны			
15	Тестовые восстановления проведены в срок, акты оформлены			
16	Все сервисы классов А и В покрыты мониторингом на уровнях 1–3			
17	Оповещения мониторинга актуальны, шумовые правила пересмотрены			
18	Сетевые схемы, IP-план и реестр VLAN соответствуют фактическому состоянию			
19	Документация выборочно проверенных систем актуальна			
20	Учётные данные оборудования соответствуют фактическому состоянию			
21	Журналы доступа подрядчиков ведутся, доступы отозваны по завершении работ			
22	Реестр исключений актуален, истёкшие исключения закрыты			
23	Отчётность формировалась в установленные сроки			
24	Матрица замещения актуальна, области без резервного ответственного отсутствуют			

Форма 35. Чек-лист внутреннего аудита

Период аудита	
Проводил аудит <i>Ф. И. О., роль</i>	
Участие отдела ИБ <i>Ф. И. О., дата</i>	
Количество выявленных отклонений	
Критичные отклонения	
План устранения (ссылки на заявки)	
Дата следующего аудита	

Форма 36. Итоги внутреннего аудита